CÁC KỸ THUẬT VÀ CÔNG NGHỆ ĐẢM BẢO ATTT

2.1. Đảm bảo ATTT dựa trên mật mã học

2.2. Điều khiển truy nhập

2.3 . Tường lửa

2.4. IDS và IPS

NỘI DUNG CHÍNH

1. MÃ HÓA DỮ LIỆU

2. HÀM BĂM VÀ MÃ XÁC THỰC THÔNG ĐIỆP HMAC DỰA TRÊN HÀM BĂM

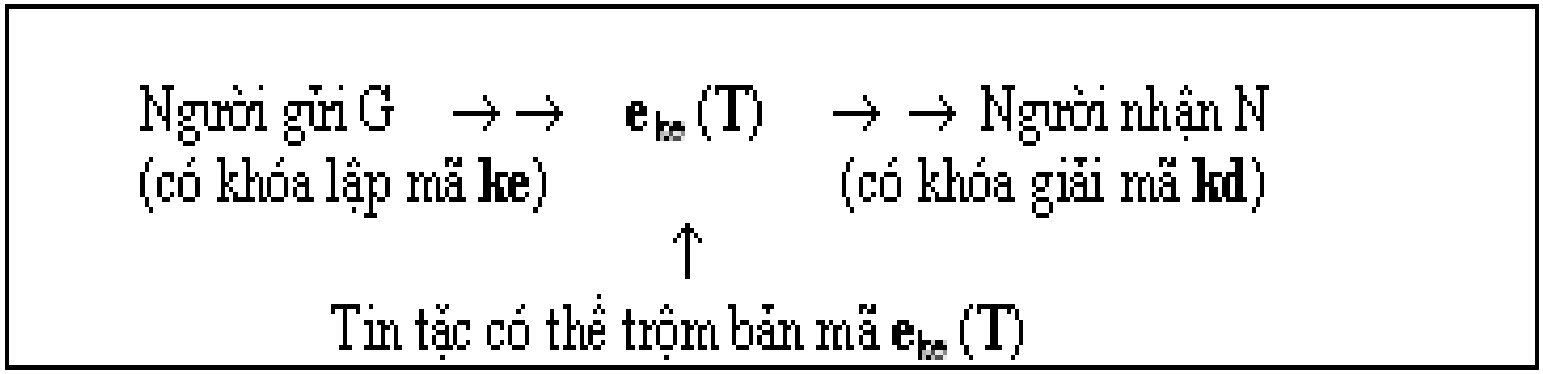
3. CHỮ KÝ SỐ

4. QUẢN LÝ KHÓA

2.3.1. MÃ HÓA DỮ LIỆU

3.1.1. Khái niệm mã hóa dữ liệu

- Che thông tin và Giấu thông tin
- **Hệ mã hóa (P, K, C, E, D)**
- **Sơ đồ mã hóa và giải mã**



3.1. MÃ HÓA DỮ LIỆU

3.1.2. Các cách phân loại

- Theo đặc trưng của Khóa
  - Hệ mã hóa khóa đối xứng
  - Hệ mã hóa khóa công khai

- Theo đặc trưng bản rõ
  - Mã hoá khối
  - Mã hoá dòng

3.1. MÃ HÓA DỮ LIỆU

3.1.3. Hệ mã hóa Khóa đối xứng

- Khái niệm
- Đặc điểm
  - Ưu điểm
  - Nhược điểm
- Nơi sử dụng

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Giới thiệu

- Trước đây, DES (Data Encryption Standard) được FIPS (Tiêu chuẩn xử lý thông tin liên bang) chọn làm chuẩn mã hóa dữ liệu chính thức vào năm 1976.
- Hiện nay, DES không đủ an toàn do độ dài 56 bits của khóa là quá nhỏ. Mặc dù, DES được thay thế bằng Triple DES (3DES) nhưng trên lý thuyết vẫn có thể bị phá.

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Giới thiệu

- AES (Advanced Encryption Standard) là thuật toán mã hóa khối thay thế cho DES.
- Thuật toán AES gốc (Rijndael) được thiết kế bởi hai nhà mật mã học người Bỉ: Joan Daemen và Vincent Rijmen.
- Năm 2001, AES được chính thức đưa vào sử dụng ở Mỹ và AES nằm trong tiêu chuẩn quốc gia Việt Nam TCVN/JTC1/SC 27 "Các kỹ thuật mật mã" năm 2007-2008.

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Giới thiệu

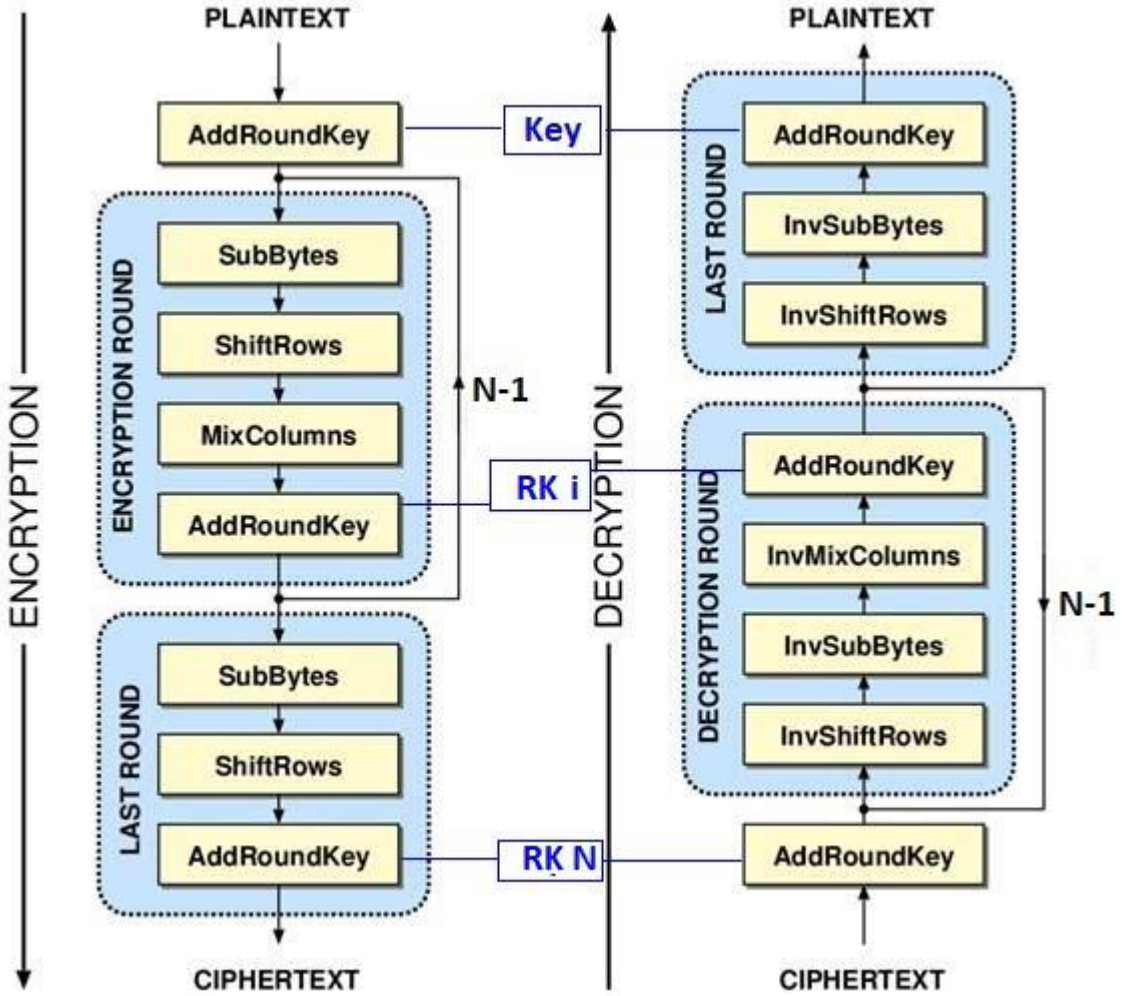
- Dữ liệu đầu vào và Khóa Key ở hệ Hex.
- Độ dài khóa: 128 bits (4x4 bytes), 192 bits (6x4 bytes), 256 bits (8x4 bytes).
- Kích thước khối dữ liệu: 128 bits (4x4 bytes).

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Giới thiệu

	Độ dài khóa	Số lần lặp
AES 128	4x4	10
AES 192	6x4	12
AES 256	8x4	14



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Giới thiệu

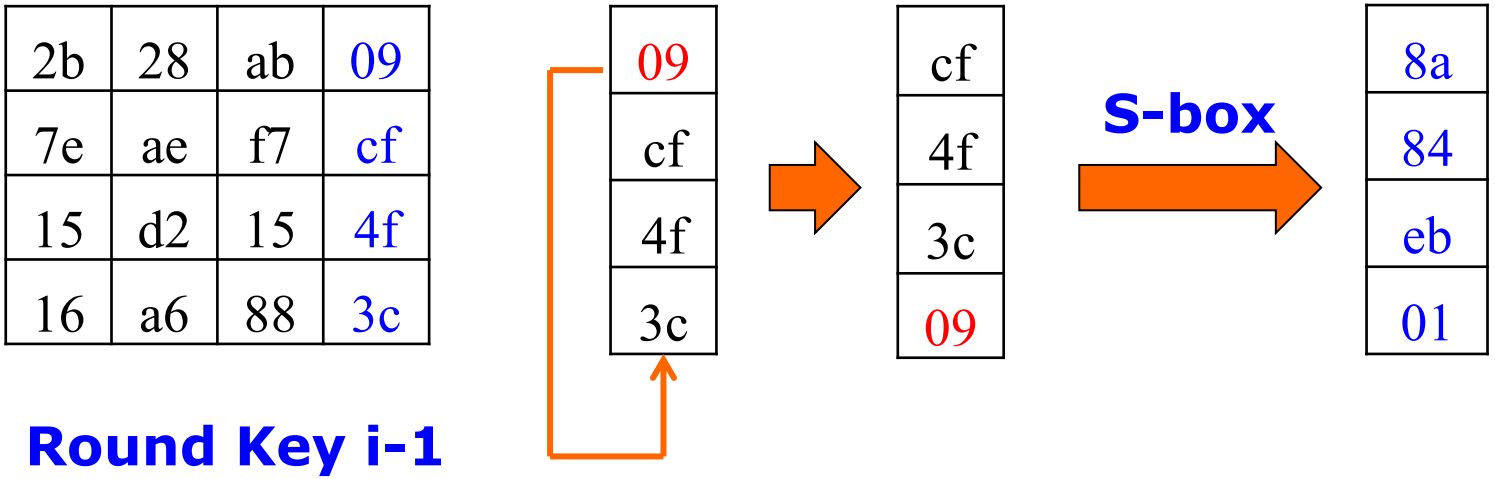
		y														
		0	1	2	3	4	5	6	7	8	9	a	b	c	d	e	f
x	0	63	7c	77	7b	f2	6b	6f	c5	30	01	67	2b	fe	d7	ab	76
	1	ca	82	c9	7d	fa	59	47	f0	ad	d4	a2	af	9c	a4	72	c0
	2	b7	fd	93	26	36	3f	f7	cc	34	a5	e5	f1	71	d8	31	15
	3	04	c7	23	c3	18	96	05	9a	07	12	80	e2	eb	27	b2	75
	4	09	83	2c	1a	1b	6e	5a	a0	52	3b	d6	b3	29	e3	2f	84
	5	53	d1	00	ed	20	fc	b1	5b	6a	cb	be	39	4a	4c	58	cf
	6	d0	ef	aa	fb	43	4d	33	85	45	f9	02	7f	50	3c	9f	a8
	7	51	a3	40	8f	92	9d	38	f5	bc	b6	da	21	10	ff	f3	d2
	8	cd	0c	13	ec	5f	97	44	17	c4	a7	7e	3d	64	5d	19	73
	9	60	81	4f	dc	22	2a	90	88	46	ee	b8	14	de	5e	0b	db
	a	e0	32	3a	0a	49	06	24	5c	c2	d3	ac	62	91	95	e4	79
	b	e7	c8	37	6d	8d	d5	4e	a9	6c	56	f4	ea	65	7a	ae	08
	c	ba	78	25	2e	1c	a6	b4	c6	e8	dd	74	1f	4b	bd	8b	8a
	d	70	3e	b5	66	48	03	f6	0e	61	35	57	b9	86	c1	1d	9e
	e	e1	f8	98	11	69	d9	8e	94	9b	1e	87	e9	ce	55	28	df
	f	8c	a1	89	0d	bf	e6	42	68	41	99	2d	0f	b0	54	bb	16

Bảng S-box

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

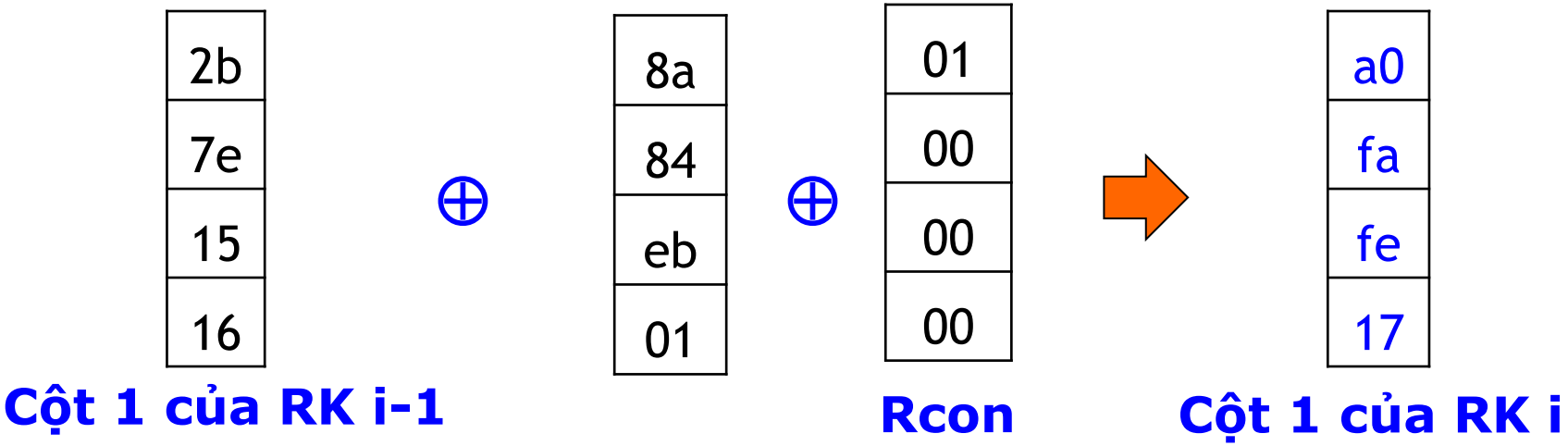
Chuẩn bị khóa: tính khóa cho mỗi vòng lặp – Round Key i với i = 1,2,…,10 và Round Key 0 là Khóa gốc ban đầu Key



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

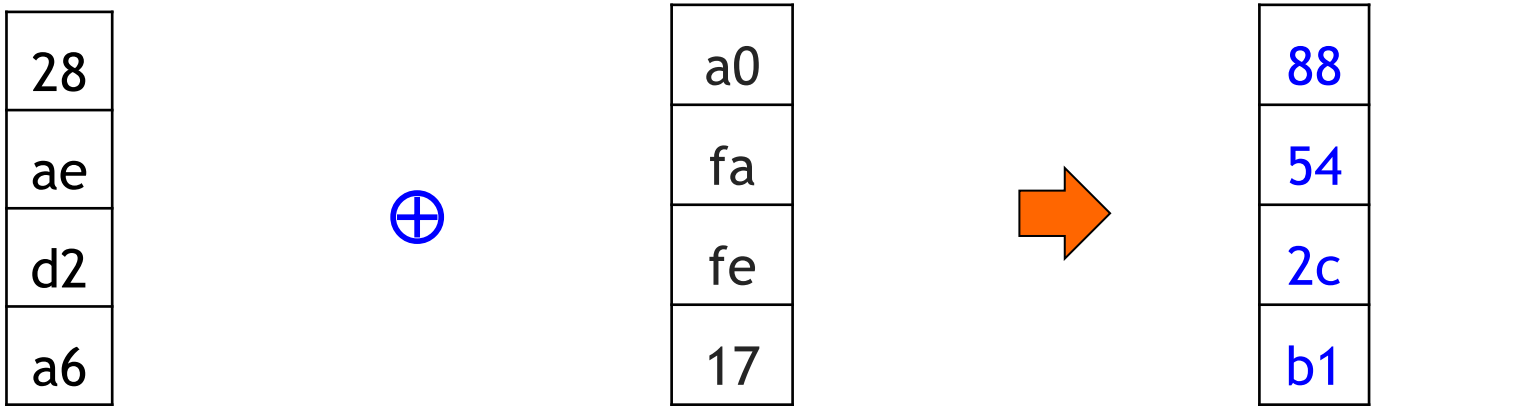
Chuẩn bị khóa: tính khóa cho mỗi vòng lặp – Round Key i với i = 1,2,…,10 và Round Key 0 là Khóa gốc ban đầu Key



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Chuẩn bị khóa: ***t***ính khóa cho mỗi vòng lặp – Round Key i với i = 1,2,…,10 và Round Key 0 là Khóa gốc ban đầu Key

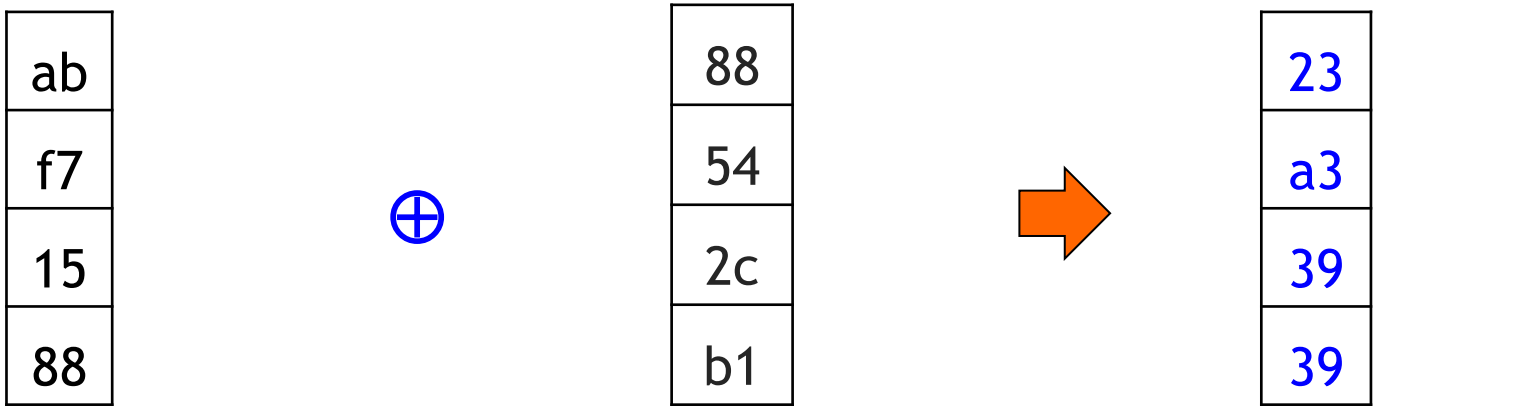


Cột 2 của RK i-1 **Cột 1 của RK i** **Cột 2 của RK i**

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Chuẩn bị khóa: ***t***ính khóa cho mỗi vòng lặp – Round Key i với i = 1,2,…,10 và Round Key 0 là Khóa gốc ban đầu Key

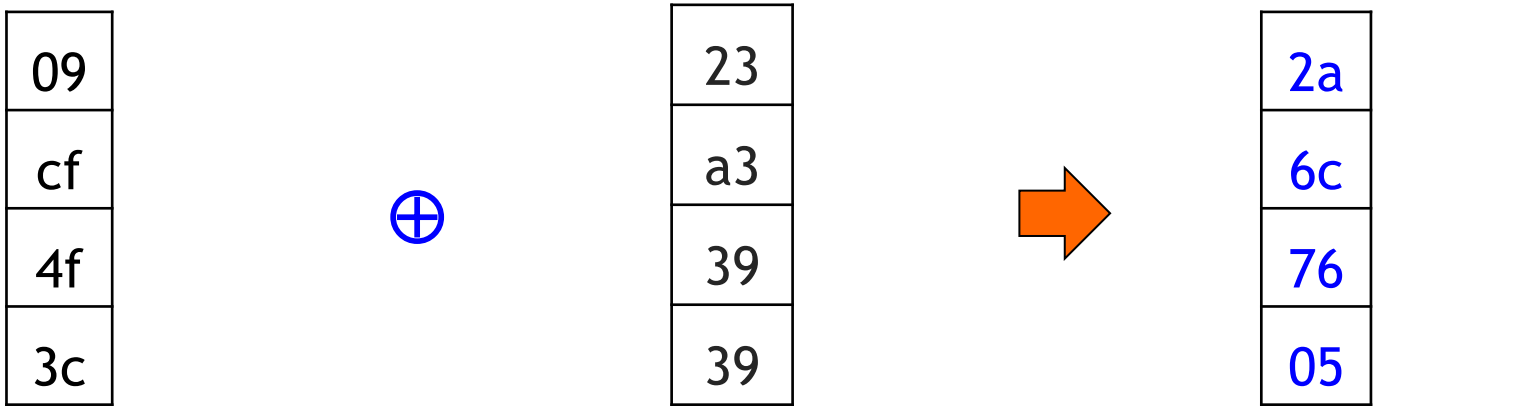


Cột 3 của RK i-1 **Cột 2 của RK i** **Cột 3 của RK i**

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Chuẩn bị khóa: ***t***ính khóa cho mỗi vòng lặp – Round Key i với i = 1,2,…,10 và Round Key 0 là Khóa gốc ban đầu Key



Cột 4 của RK i-1 **Cột 3 của RK i** **Cột 4 của RK i**

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Chuẩn bị khóa: ***t***ính khóa cho mỗi vòng lặp – Round Key i với i = 1,2,…,10 và Round Key 0 là Khóa gốc ban đầu Key

2b	28	ab	09
7e	ae	f7	cf
15	d2	15	4f
16	a6	88	3c

Round Key i-1



a0	88	23	2a
fa	54	a3	6c
fe	2c	39	76
17	b1	39	05

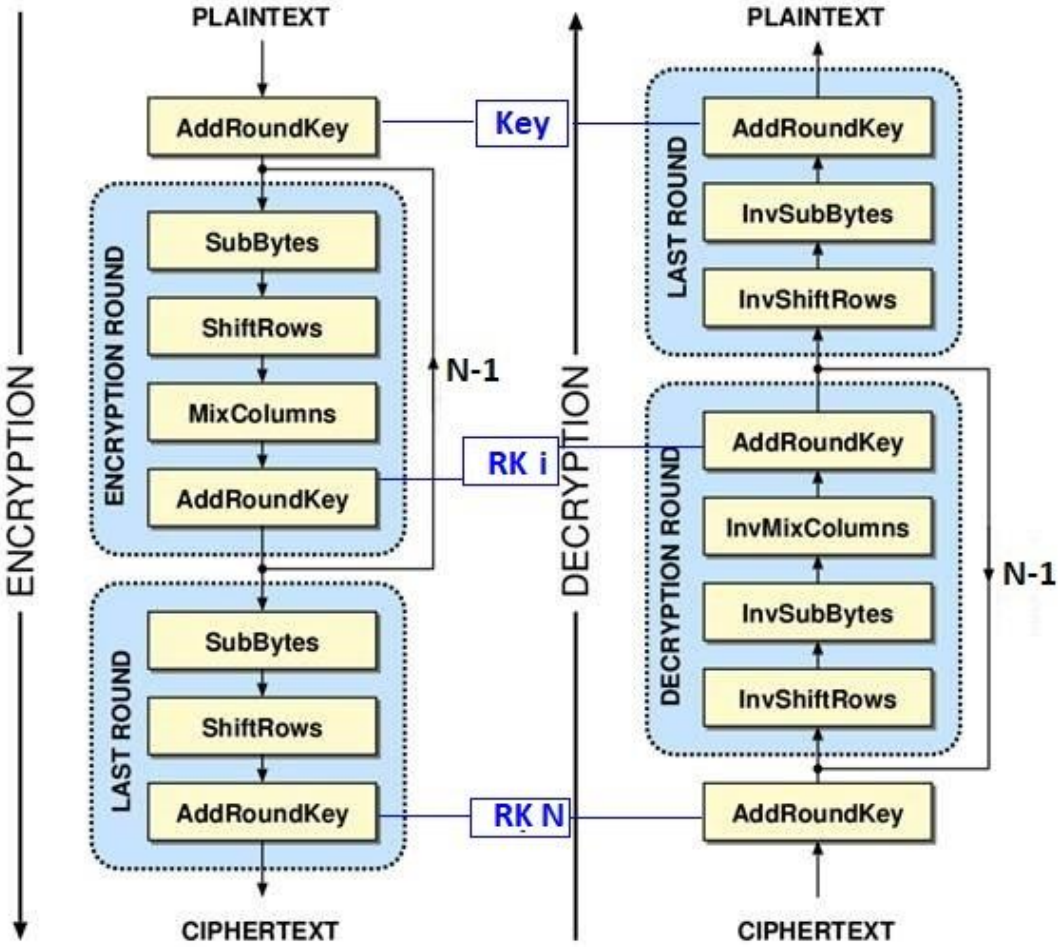
Round Key i

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Mã hóa dữ liệu với AES-128

- Plaintext là các khối dữ liệu: 128 bits (4x4 bytes) được chia ra từ thông điệp M cần mã hóa.
- Nếu độ dài L của M không chia hết cho 128 thì thêm vào K bits dạng 10…0 sao cho $(L + K) : 128$
- Output của bước trước là Input của bước sau.



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Mã hóa dữ liệu với AES-128

		y														
		0	1	2	3	4	5	6	7	8	9	a	b	c	d	e	f
x	0	63	7c	77	7b	f2	6b	6f	c5	30	01	67	2b	fe	d7	ab	76
	1	ca	82	c9	7d	fa	59	47	f0	ad	d4	a2	af	9c	a4	72	c0
	2	b7	fd	93	26	36	3f	f7	cc	34	a5	e5	f1	71	d8	31	15
	3	04	c7	23	c3	18	96	05	9a	07	12	80	e2	eb	27	b2	75
	4	09	83	2c	1a	1b	6e	5a	a0	52	3b	d6	b3	29	e3	2f	84
	5	53	d1	00	ed	20	fc	b1	5b	6a	cb	be	39	4a	4c	58	cf
	6	d0	ef	aa	fb	43	4d	33	85	45	f9	02	7f	50	3c	9f	a8
	7	51	a3	40	8f	92	9d	38	f5	bc	b6	da	21	10	ff	f3	d2
	8	cd	0c	13	ec	5f	97	44	17	c4	a7	7e	3d	64	5d	19	73
	9	60	81	4f	dc	22	2a	90	88	46	ee	b8	14	de	5e	0b	db
	a	e0	32	3a	0a	49	06	24	5c	c2	d3	ac	62	91	95	e4	79
	b	e7	c8	37	6d	8d	d5	4e	a9	6c	56	f4	ea	65	7a	ae	08
	c	ba	78	25	2e	1c	a6	b4	c6	e8	dd	74	1f	4b	bd	8b	8a
	d	70	3e	b5	66	48	03	f6	0e	61	35	57	b9	86	c1	1d	9e
	e	e1	f8	98	11	69	d9	8e	94	9b	1e	87	e9	ce	55	28	df
	f	8c	a1	89	0d	bf	e6	42	68	41	99	2d	0f	b0	54	bb	16

Bảng S-box

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Mã hóa dữ liệu với AES-128

a. AddRoundKey i (i = 0,1,…,N)

32	88	31	e0
43	5a	31	37
f6	30	98	07
a8	8d	a2	34

Input i

⊕

2b	28	ab	09
7e	ae	f7	cf
15	d2	15	4f
16	a6	88	3c

Round Key i



19	a0	9a	e9
3d	f4	c6	f8
e3	e2	8d	48
be	2b	2a	08

- **Input 0 = PlainText và Round Key 0 = Key**

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Mã hóa dữ liệu với AES-128

b. SubBytes: chuyển đổi dựa vào bảng S-box

19	a0	9a	e9
3d	f4	c6	f8
e3	e2	8d	48
be	2b	2a	08

S-box



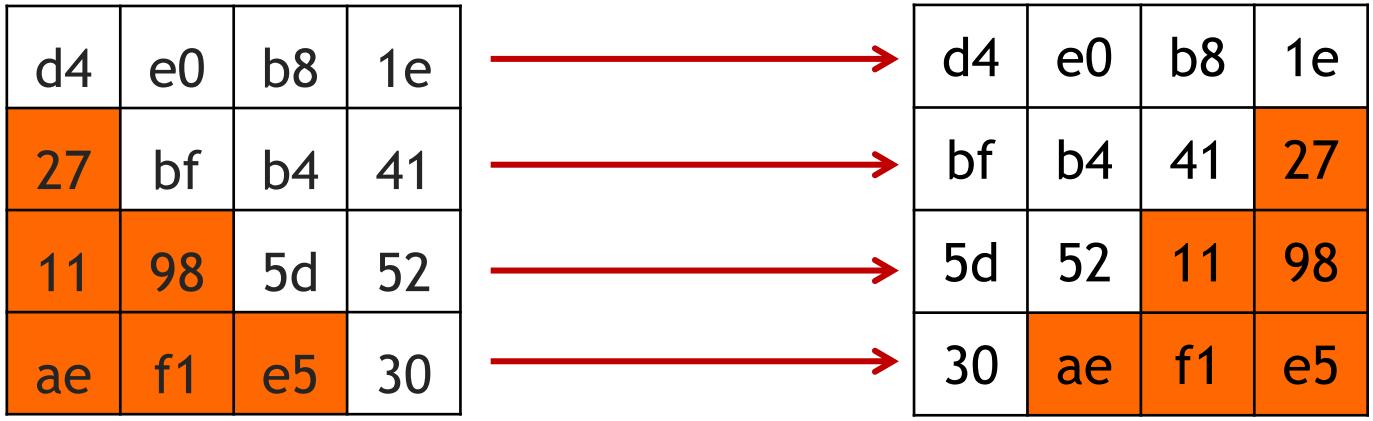
d4	e0	b8	1e
27	bf	b4	41
11	98	5d	52
ae	f1	e5	30

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Mã hóa dữ liệu với AES-128

c. ShiftRows: dòng i dịch vòng trái (i-1) lần



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Mã hóa dữ liệu với AES-128

d. MixColumns

d4	e0	b8	1e
bf	b4	41	27
5d	52	11	98
30	ae	f1	e5

[X]

02	03	01	01
01	02	03	01
01	01	02	03
03	01	01	02

=

04	e0	48	28
66	cb	f8	06
81	19	d3	26
e5	9a	7a	4c

Quy tắc: $04 = d4 \bullet 02 \oplus bf \bullet 03 \oplus 5d \bullet 01 \oplus 30 \bullet 01$

$B_1B_2 \bullet 01 = B_1B_2$

$B_1B_2 \bullet 02$: $B_1B_2 \rightarrow b_1b_2b_3b_4b_5b_6b_7b_8 \rightarrow b_2b_3b_4b_5b_6b_7b_80 \oplus 00011011$

$B_1B_2 \bullet 03 = B_1B_2 \bullet 02 \oplus B_1B_2 \bullet 01 = B_1B_2 \bullet 02 \oplus B_1B_2$

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Mã hóa dữ liệu với AES-128

d. MixColumns

d4	e0	b8	1e
bf	b4	41	27
5d	52	11	98
30	ae	f1	e5

[X]

02	03	01	01
01	02	03	01
01	01	02	03
03	01	01	02

=

04	e0	48	28
66	cb	f8	06
81	19	d3	26
e5	9a	7a	4c

VD: 04=d4•02 ⊕ bf•03 ⊕ 5d•01 ⊕ 30•01 = 00000100

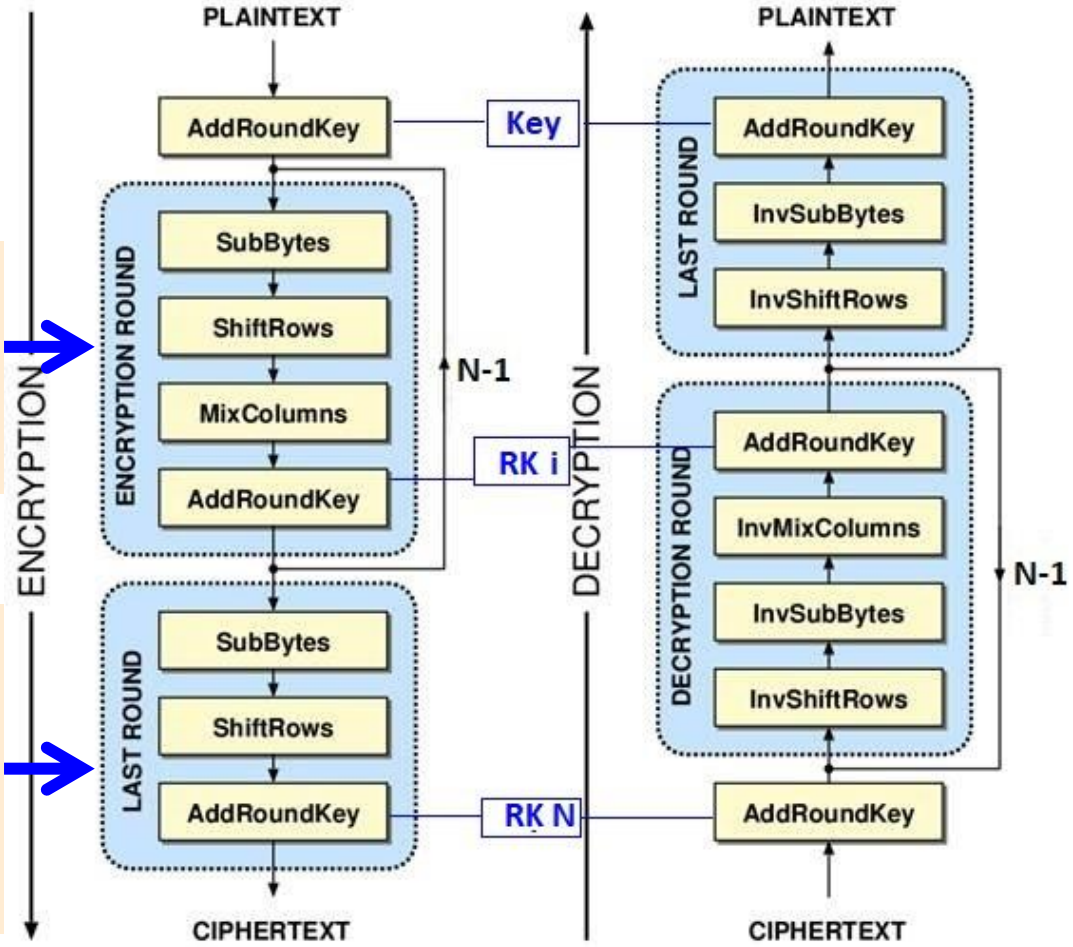
- **d4•02:d4**→11010100→10101000⊕00011011= 10110011
- **bf•01 = bf** = 10111111
- **bf•02: bf**→10111111→01111110⊕00011011=01100101
- **bf•03=bf•02 ⊕ bf** = 01100101⊕10111111= 11011010
- **5d•01 = 5d** = 01011101; **30.01 = 30** = 00110000

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Mã hóa dữ liệu với AES-128

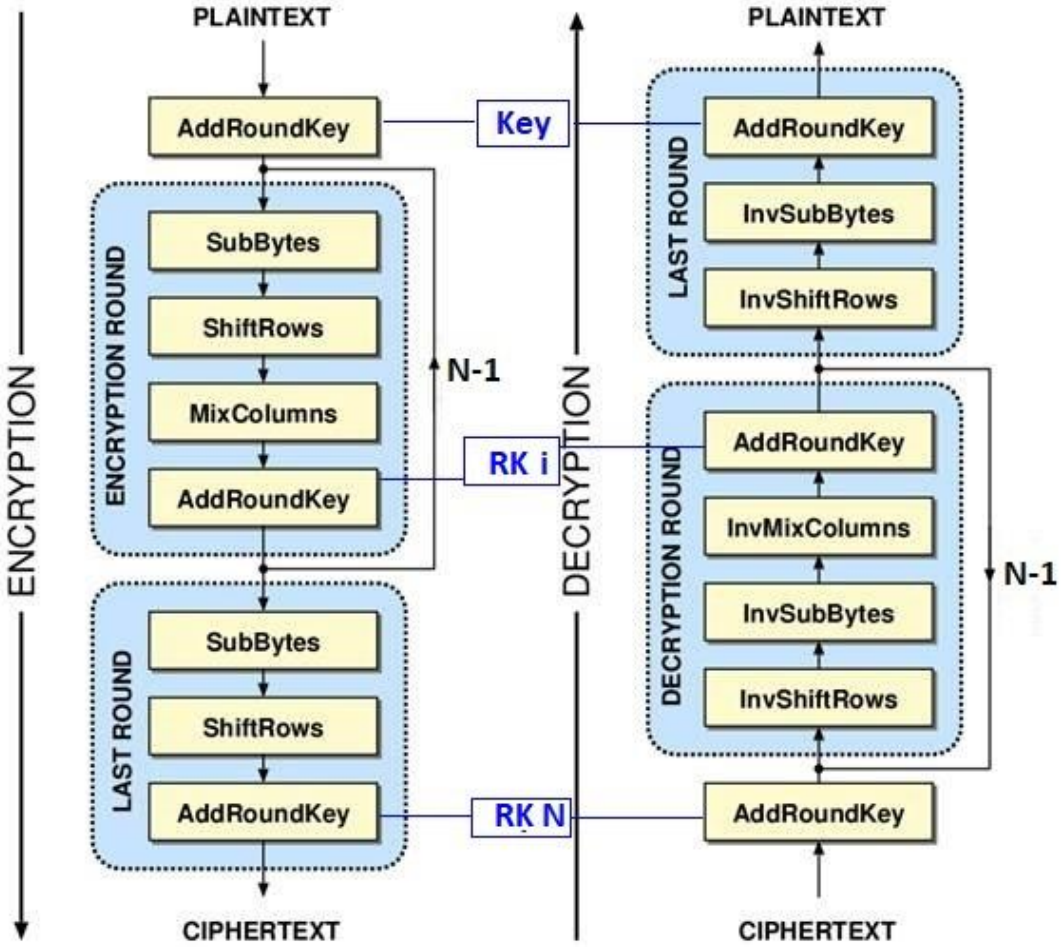
- Thực hiện 9 lần tổ hợp 04 phép biến đổi (theo đúng thứ tự)
- Tại bước lặp 10: thực hiện tổ hợp 03 phép biến đổi (ngoại trừ MixColumns)



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Giải mã dữ liệu với AES-128



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Giải mã dữ liệu với AES-128

		y														
		0	1	2	3	4	5	6	7	8	9	a	b	c	d	e	f
x	0	52	09	6a	d5	30	36	a5	38	bf	40	a3	9e	81	f3	d7	fb
	1	7c	e3	39	82	9b	2f	ff	87	34	8e	43	44	c4	de	e9	cb
	2	54	7b	94	32	a6	c2	23	3d	ee	4c	95	0b	42	fa	c3	4e
	3	08	2e	a1	66	28	d9	24	b2	76	5b	a2	49	6d	8b	d1	25
	4	72	f8	f6	64	86	68	98	16	d4	a4	5c	cc	5d	65	b6	92
	5	6c	70	48	50	fd	ed	b9	da	5e	15	46	57	a7	8d	9d	84
	6	90	d8	ab	00	8c	bc	d3	0a	f7	e4	58	05	b8	b3	45	06
	7	d0	2c	1e	8f	ca	3f	0f	02	c1	af	bd	03	01	13	8a	6b
	8	3a	91	11	41	4f	67	dc	ea	97	f2	cf	ce	f0	b4	e6	73
	9	96	ac	74	22	e7	ad	35	85	e2	f9	37	e8	1c	75	df	6e
	a	47	f1	1a	71	1d	29	c5	89	6f	b7	62	0e	aa	18	be	1b
	b	fc	56	3e	4b	c6	d2	79	20	9a	db	c0	fe	78	cd	5a	f4
	c	1f	dd	a8	33	88	07	c7	31	b1	12	10	59	27	80	ec	5f
	d	60	51	7f	a9	19	b5	4a	0d	2d	e5	7a	9f	93	c9	9c	ef
	e	a0	e0	3b	4d	ae	2a	f5	b0	c8	eb	bb	3c	83	53	99	61
	f	17	2b	04	7e	ba	77	d6	26	e1	69	14	63	55	21	0c	7d

Bảng S-box nghịch đảo

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Giải mã dữ liệu với AES-128

b. InvAddRoundKey i (i=0,1,…,N) ⇔ AddRoundKey^2

19	a0	9a	e9
3d	f4	c6	f8
e3	e2	8d	48
be	2b	2a	08

Input i

⊕

2b	28	ab	09
7e	ae	f7	cf
15	d2	15	4f
16	a6	88	3c

Round Key i



32	88	31	e0
43	5a	31	37
f6	30	98	07
a8	8d	a2	34

- Input 0 = CipherText và Round Key N = Key

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Giải mã dữ liệu với AES-128

c. InvSubBytes: chuyển đổi dựa vào bảng S-box nghịch đảo

19	a0	9a	e9
3d	f4	c6	f8
e3	e2	8d	48
be	2b	2a	08

S-box nghịch đảo



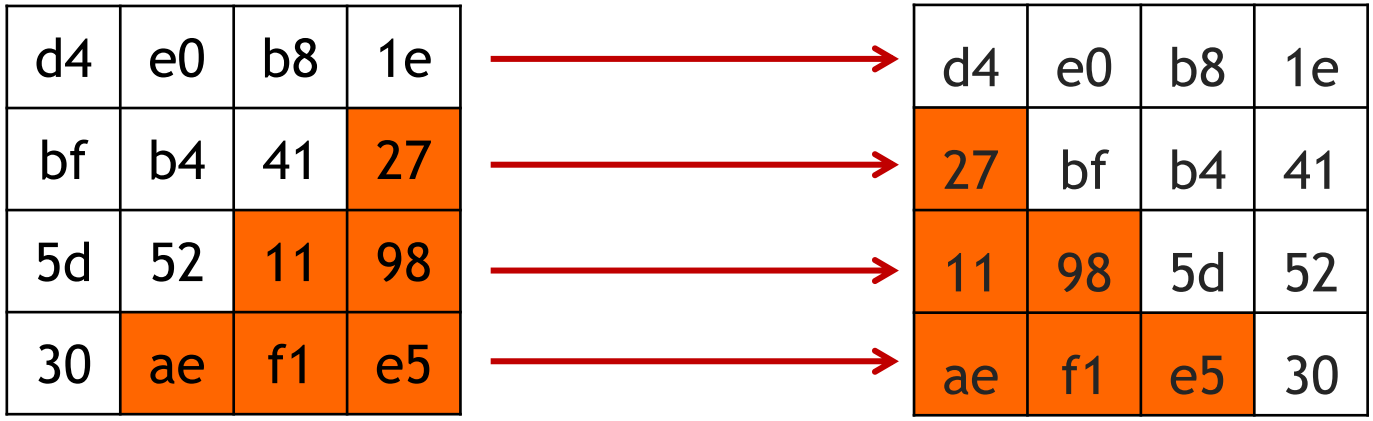
d4	e0	b8	1e
27	bf	b4	41
11	98	5d	52
ae	f1	e5	30

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Giải mã dữ liệu với AES-128

d. ShiftRows: dòng i dịch vòng phải (i-1) lần



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Giải mã dữ liệu với AES-128

e. InvMixColumns

d4	e0	b8	1e
bf	b4	41	27
5d	52	11	98
30	ae	f1	e5

Ma trận cần tìm

[X]

02	03	01	01
01	02	03	01
01	01	02	03
03	01	01	02

Ma trận mặc định

=

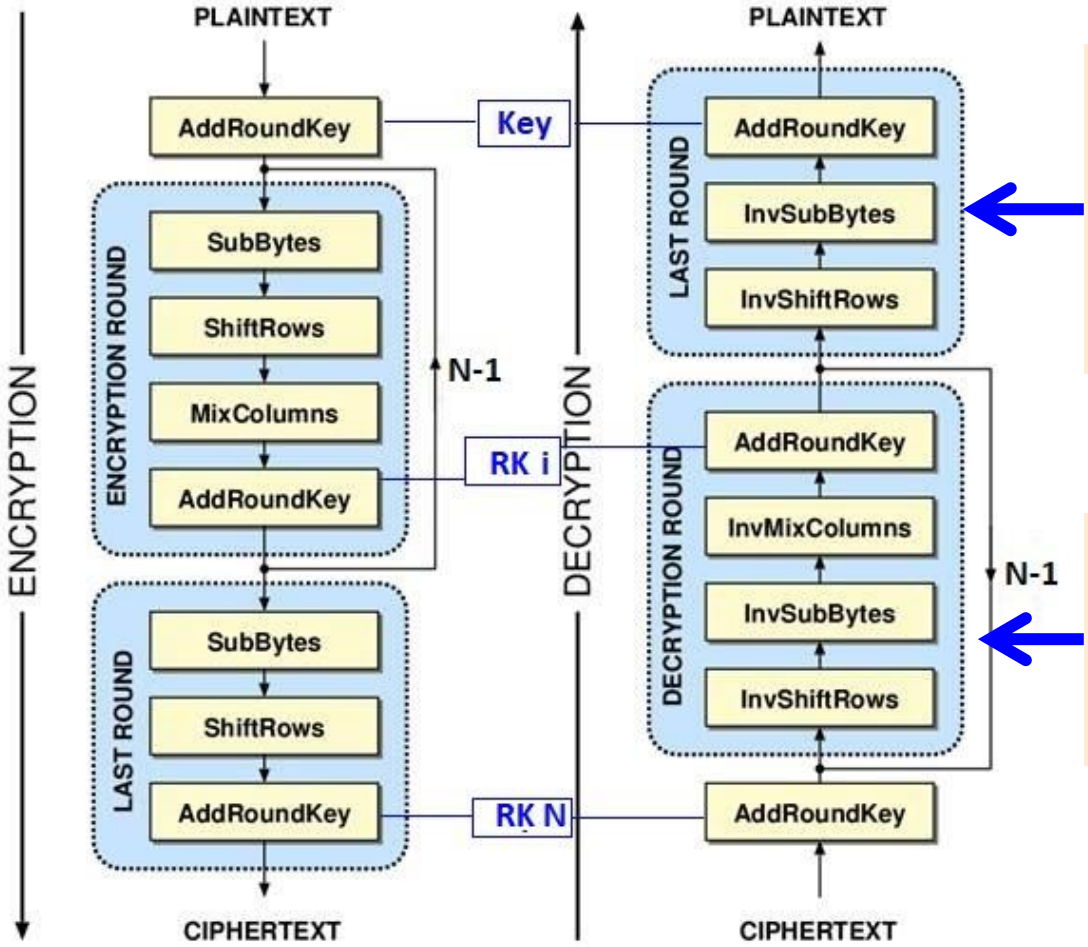
04	e0	48	28
66	cb	f8	06
81	19	d3	26
e5	9a	7a	4c

Ma trận đầu vào

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Giải mã dữ liệu với AES-128



- Tại bước lặp 10: thực hiện tổ hợp 03 phép biến đổi (ngoại trừ InvMixColumns)
- Thực hiện 9 lần tổ hợp 04 phép biến đổi (theo đúng thứ tự)

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

Độ an toàn của AES

- AES-128 đủ an toàn để bảo vệ các thông tin được xếp vào loại TỐI MẬT (secret). Các thông tin TUYỆT MẬT (top secret) sẽ phải dùng khóa 192 hoặc 256 bits.
- Tấn công thuật toán: thuật toán đơn giản nhưng tới nay chưa tìm được điểm yếu.
- Tấn công khóa vét cạn: không khả thi!
- Tấn công kênh bên (Side channel attacks): dựa vào lỗ hổng của thiết bị thực thi thuật toán.

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa khóa đối xứng AES

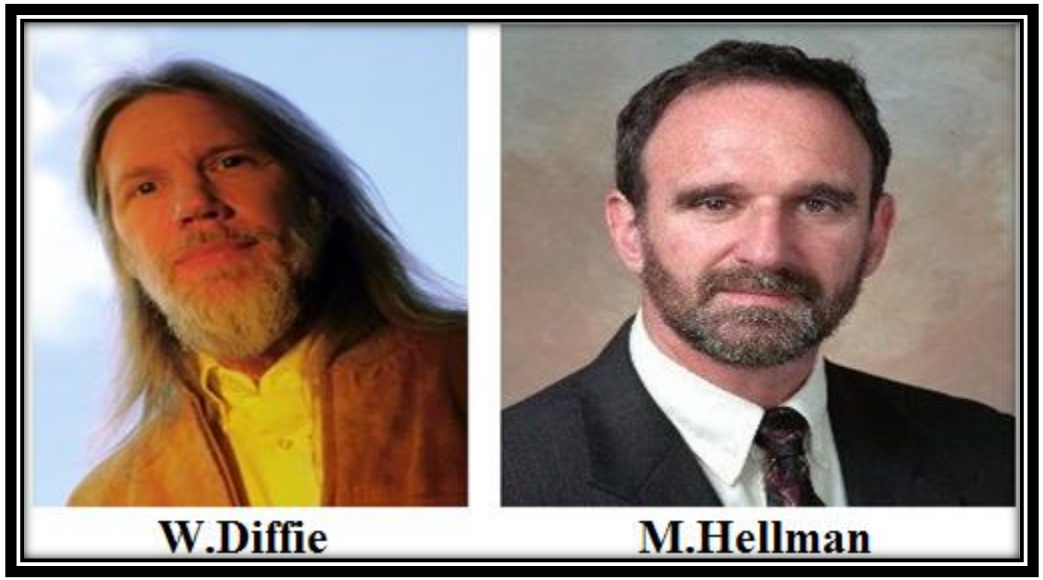
Ứng dụng của AES

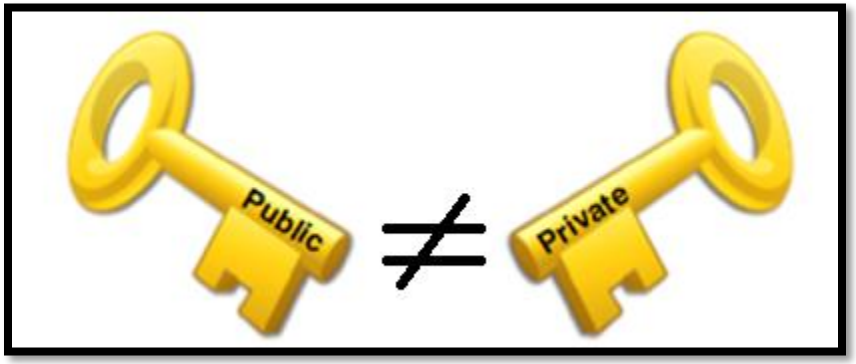
- Mã hóa dữ liệu
  - Lưu trữ dữ liệu an toàn
  - Truyền dữ liệu an toàn
- An toàn giao dịch sử dụng thẻ ngân hàng

3.1. MÃ HÓA DỮ LIỆU

3.1.4. Hệ mã hóa Khóa bất đối xứng (công khai)

- Khái niệm
- Đặc điểm
  - Ưu điểm
  - Nhược điểm
- Nơi sử dụng

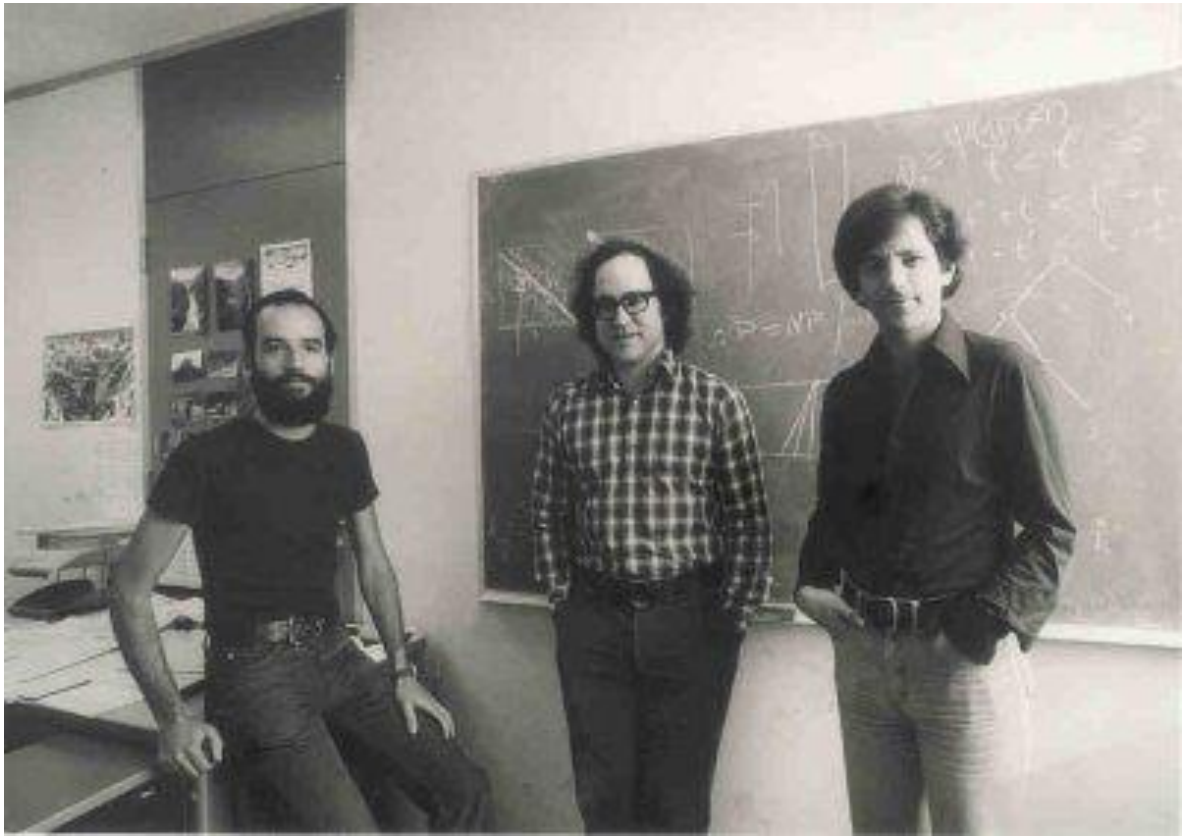




3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa RSA

Giới thiệu

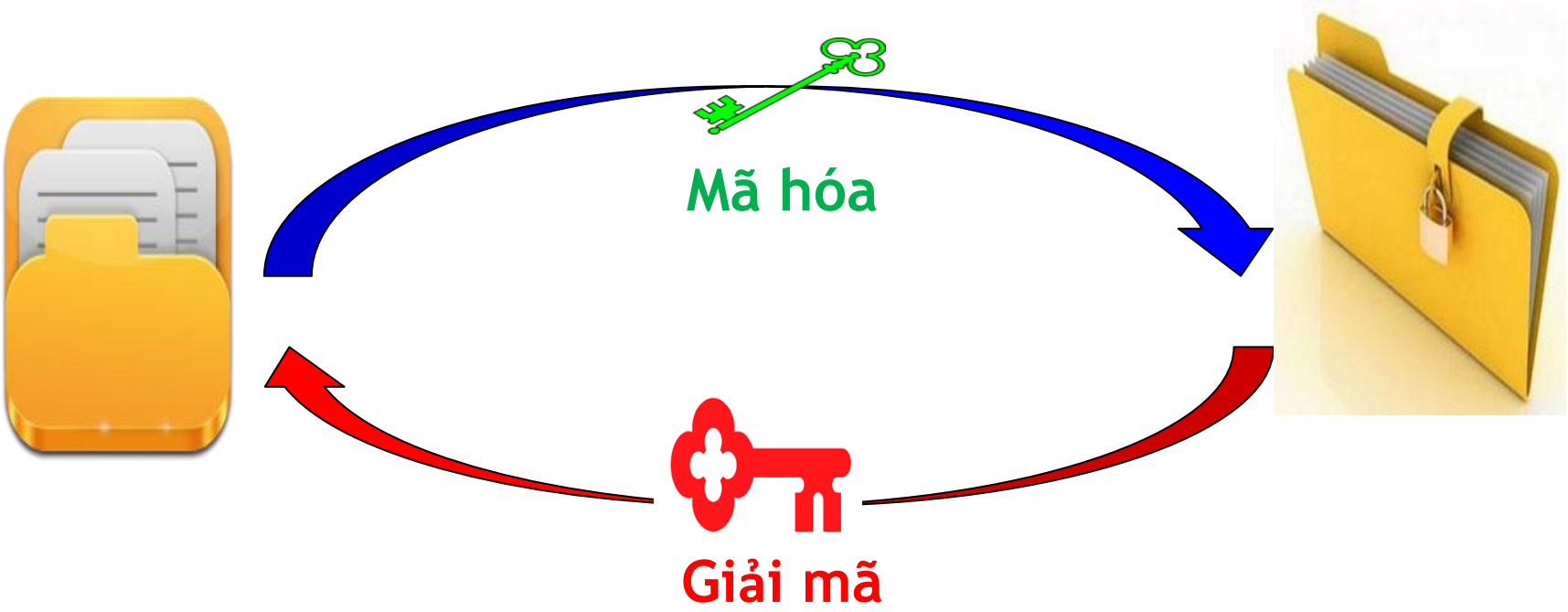


Ronald Rivest, Adi Shamir, Leonard Adleman

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa RSA

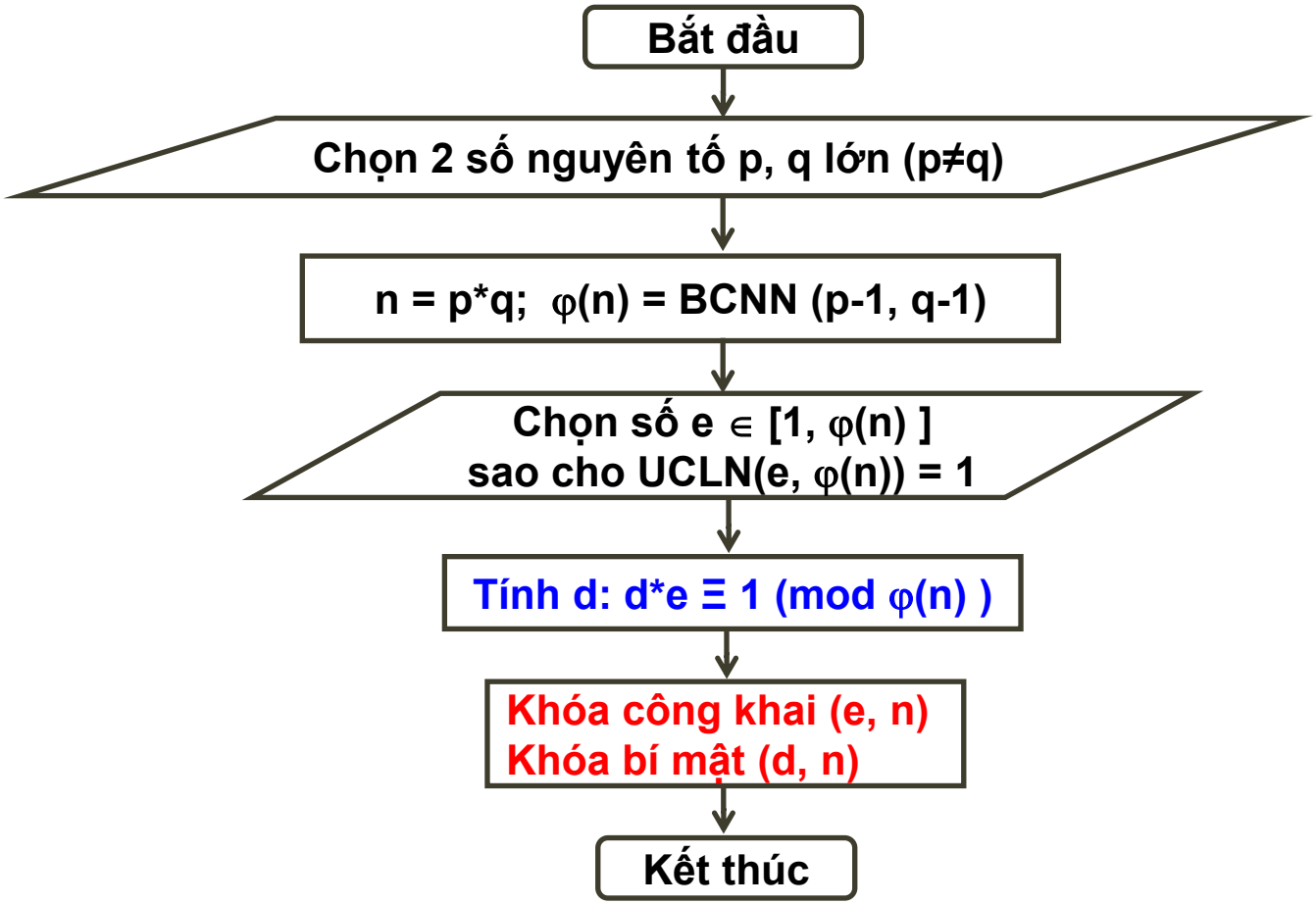
- Giới thiệu



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa RSA

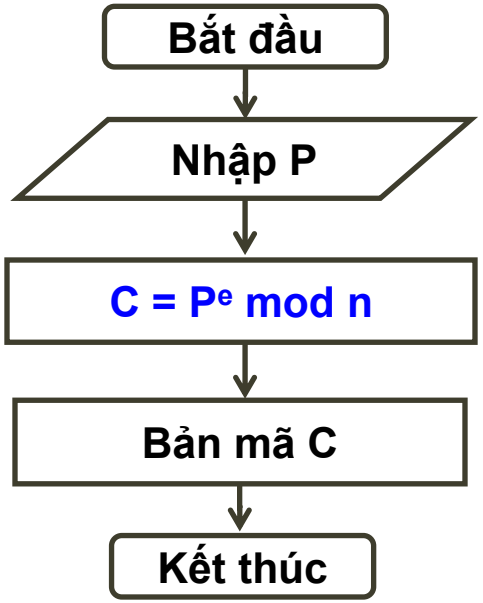
- Giai đoạn tạo khóa



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa RSA

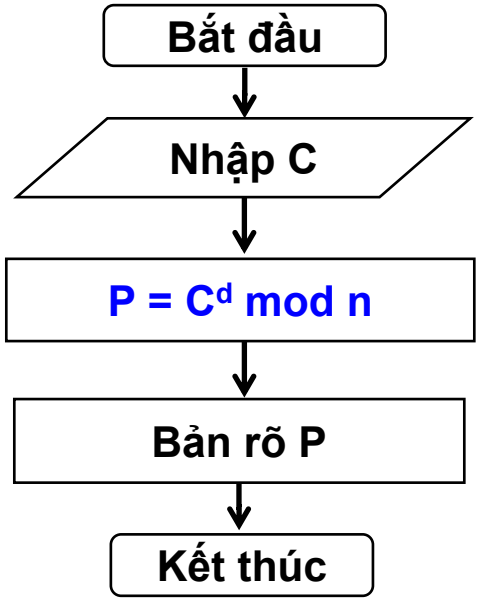
- Giai đoạn mã hóa
  - Input: số nguyên dương P và khóa công khai (e,n)
  - Ouput: bản mã C của P



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa RSA

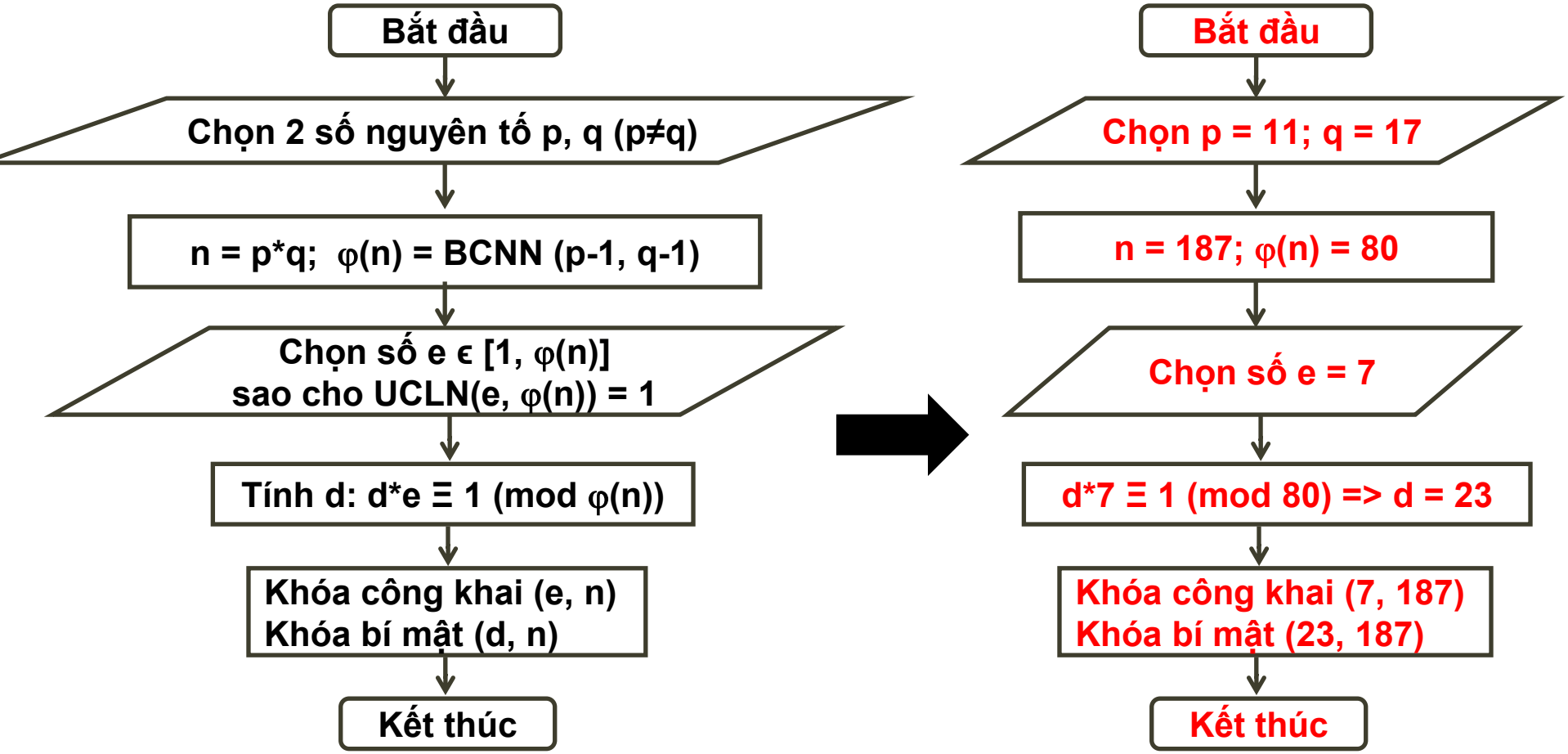
- Giai đoạn giải mã
  - Input: bản mã C và khóa bí mật (d,n)
  - Ouput: bản rõ P



3.1. MÃ HÓA DỮ LIỆU

Ví dụ minh họa hệ mã hóa RSA

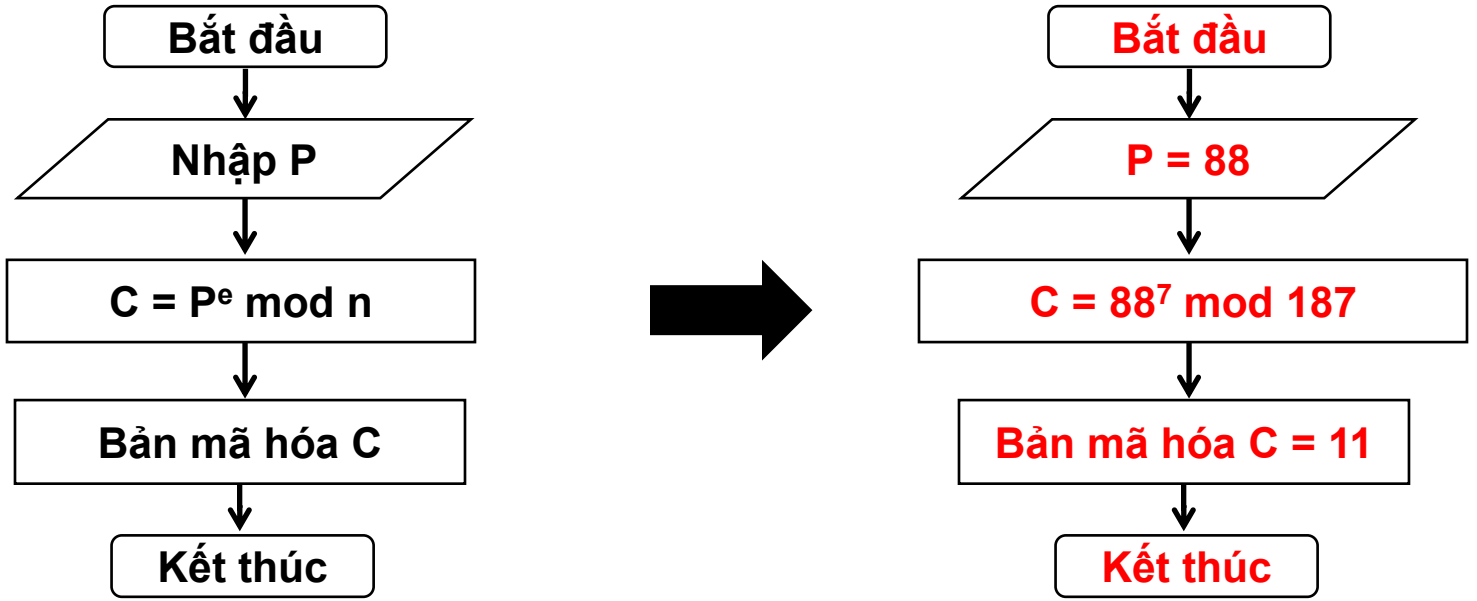
- Giai đoạn tạo khóa



3.1. MÃ HÓA DỮ LIỆU

Ví dụ minh họa hệ mã hóa RSA

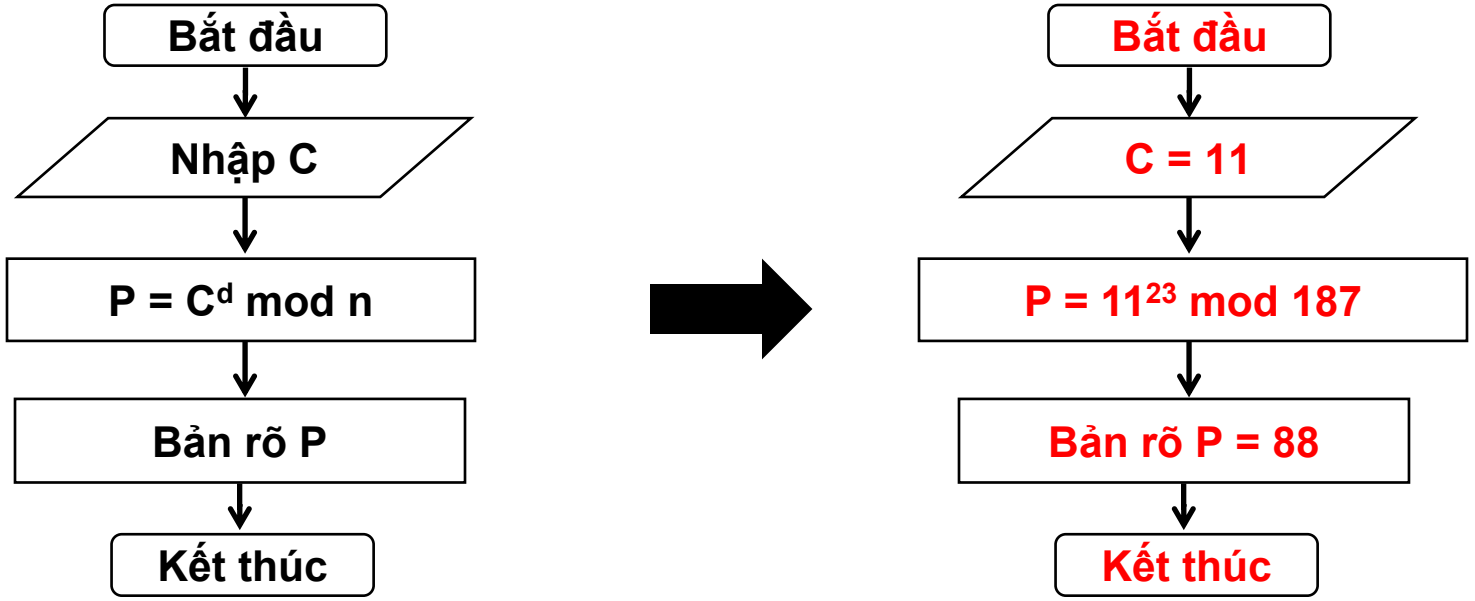
- Giai đoạn mã hóa



3.2. MÃ HÓA DỮ LIỆU VÀ CHỮ KÝ SỐ

Ví dụ minh họa hệ mã hóa RSA

- Giai đoạn giải mã



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa RSA

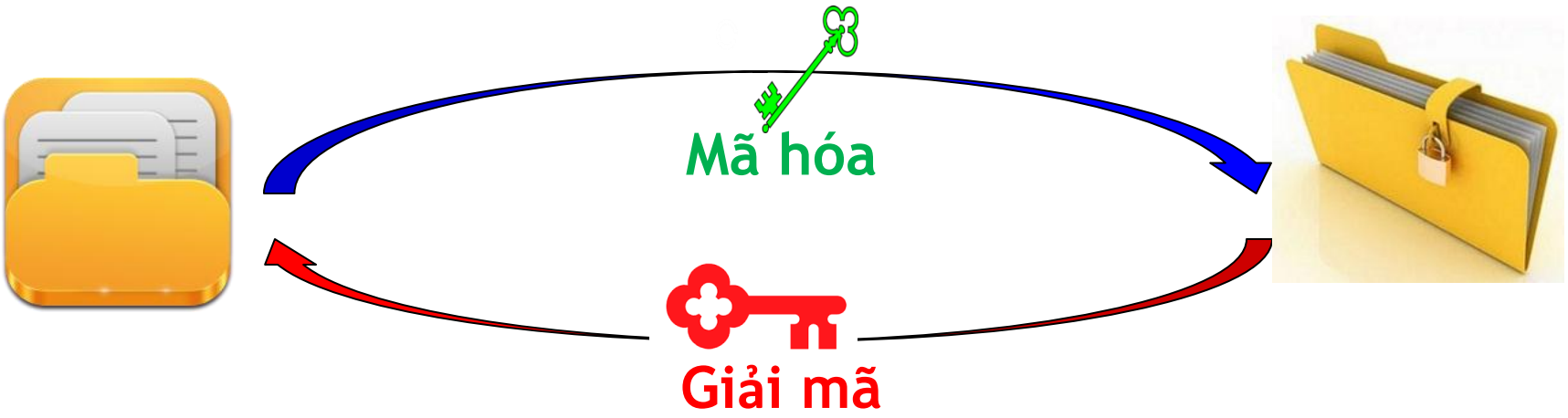
Đánh giá độ an toàn

- Bài toán RSA: tìm P sao cho $P^e \bmod n = C$ (trong đó (e, n) là khóa công khai và C là bản mã hóa).
- Bài toán phân tích số nguyên dương lớn ra thừa số nguyên tố: n = p * q (trong đó p và q là 2 số nguyên tố lớn).
- Độ dài của n: Khuyến cáo sử dụng khóa có độ dài tối thiểu 2048 Bits và khóa có độ dài 4096 Bit thì hầu như không có khả năng bị phá vỡ trong tương lai gần.

3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa ElGamal (tự đọc)

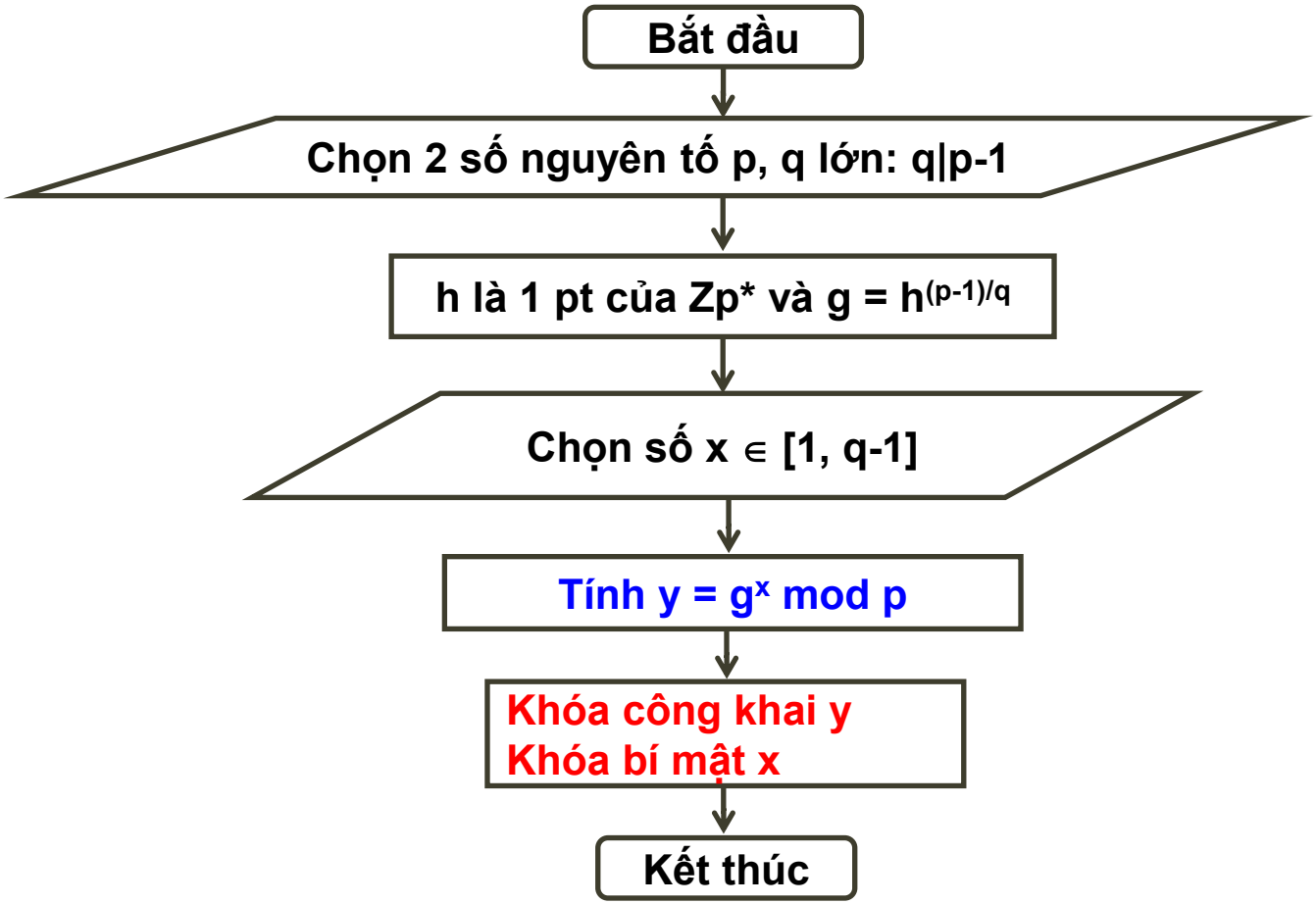
Giới thiệu



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa ElGamal

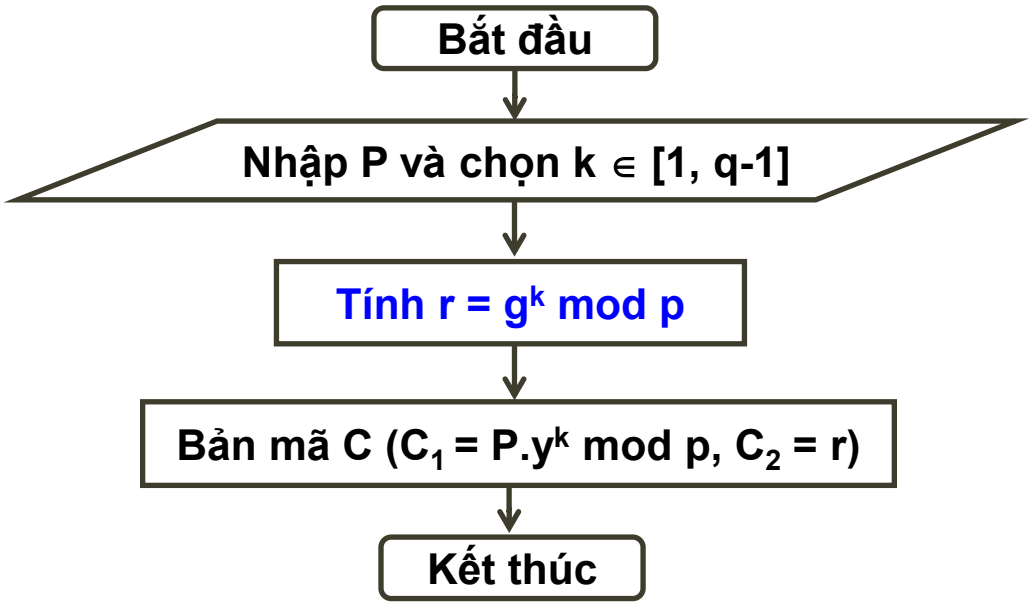
- Giai đoạn tạo khóa



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa ElGamal

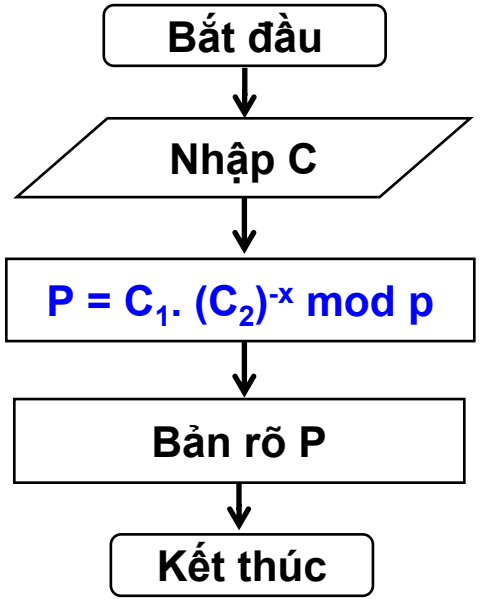
- Giai đoạn mã hóa
  - Input: số nguyên dương P và khóa công khai y
  - Ouput: bản mã C của P



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa ElGamal

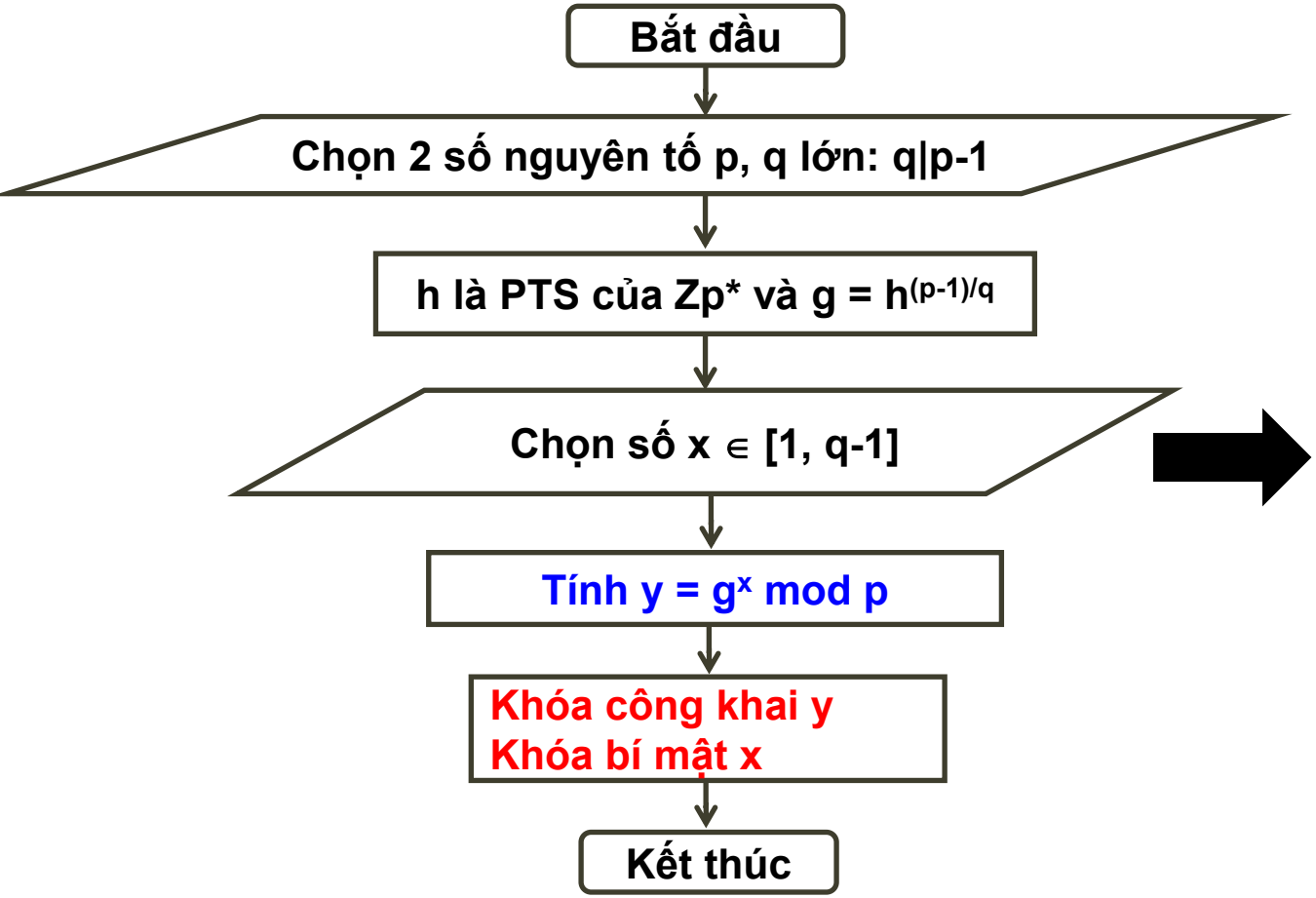
- Giai đoạn giải mã
  - Input: bản mã C và khóa bí mật x
  - Ouput: bản rõ P



3.1. MÃ HÓA DỮ LIỆU

Ví dụ minh họa hệ mã hóa ElGamal

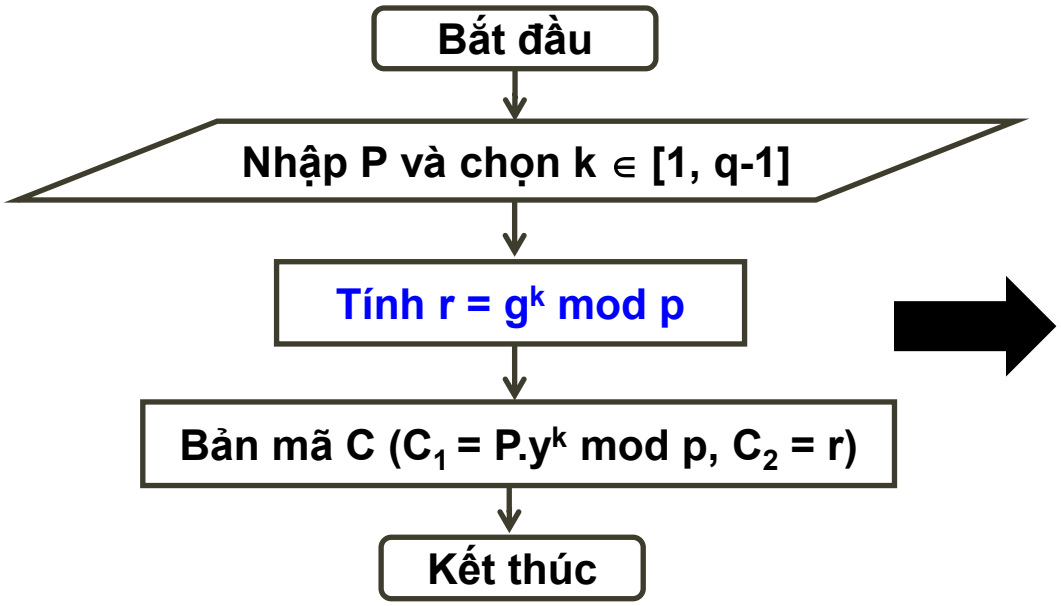
- Giai đoạn tạo khóa



3.1. MÃ HÓA DỮ LIỆU

Ví dụ minh họa hệ mã hóa ElGamal

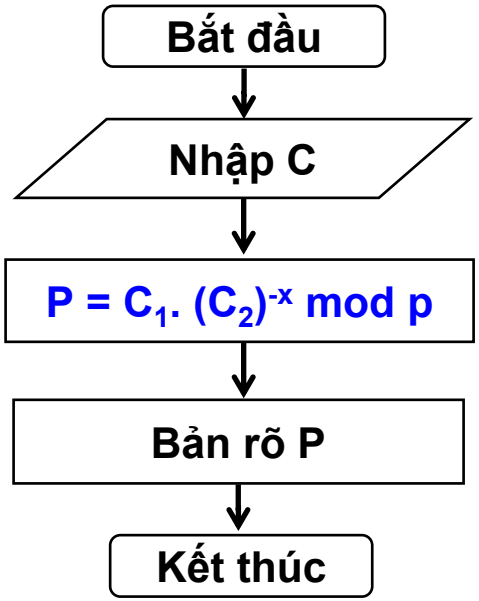
- Giai đoạn mã hóa



3.1. MÃ HÓA DỮ LIỆU

Ví dụ minh họa hệ mã hóa ElGamal

- Giai đoạn giải mã



3.1. MÃ HÓA DỮ LIỆU

Hệ mã hóa ElGamal

Đánh giá độ an toàn

- Bài toán logarithm rời rạc: tìm x: $y = g^x \ mod \ p$
- Độ dài khóa: p = 2048 bits, q = 256 bits

3.2. HÀM BĂM VÀ HMAC

3.2.1. Khái niệm "Hàm băm"

- **Hàm băm là** thuật toán dùng để "tóm tắt" (băm) tài liệu, bản tin hoặc thông điệp có kích thước bất kỳ và cho ra kết quả là một giá trị "băm" có kích thước cố định.
- Giá trị băm này còn được gọi là "đại diện tài liệu", "đại diện bản tin" hay "đại diện thông điệp".

3.2. HÀM BĂM VÀ HMAC

3.2.2. Các tính chất của hàm băm

- **Tính chất 1:** Hàm băm **h** là **không va chạm yếu.**
  - Hàm băm **h** được gọi là **không va chạm yếu**, nếu cho trước thông điệp **x**, "khó" thể tính toán để tìm ra **x'** ≠ **x** mà **h(x')** = **h(x)**.
- **Tính chất 2**: Hàm băm **h** là **không va chạm mạnh.**
  - Hàm băm **h** được gọi là **không va chạm mạnh** nếu "khó" thể tính toán để tìm ra hai thông điệp khác nhau **x'** và **x** (với **x'** ≠ **x**) mà có **h(x')** = **h(x)**.
- **Tính chất 3**: Hàm băm **h** là **hàm một chiều.**

3.2. HÀM BĂM VÀ HMAC

3.2.3. Ứng dụng của hàm băm

- Kết hợp với chữ ký số: người ta dùng hàm băm **h** để tạo đại diện bản tin **z** = **h**(**x**), nó thường ngắn (VD: 256 bit). Sau đó ký trên **z** nên chữ ký trên **z** sẽ nhỏ hơn rất nhiều so với chữ ký trên bản tin gốc x.
- Hàm băm dùng để xác định tính toàn vẹn dữ liệu.
- Hàm băm dùng để bảo mật một số dữ liệu đặc biệt. Ví dụ: bảo vệ mật khẩu, bảo vệ khóa mật,…
- Một số hàm băm thông dụng: các hàm băm MD, các hàm băm SHA, các hàm băm RIPEMD,…

3.2. HÀM BĂM VÀ HMAC

3.2.4. Hàm băm SHA-256

3.2.4.1. Giới thiệu

- Secure Hash Algorithm (SHA) được công bố trong Hồ sơ Liên bang năm 1992 và được chấp nhận làm tiêu chuẩn vào năm 1993 do Viện Tiêu Chuẩn và Công Nghệ Quốc Gia (NIST).

- SHA-256 nằm trong nhóm SHA-2 cùng với SHA-512 là các hàm băm an toàn được sử dụng rộng rãi.

3.2. HÀM BĂM VÀ HMAC

3.2.4. Hàm băm SHA-256

3.2.4.1. Giới thiệu

- Ý tưởng thuật toán băm SHA-256 được thực hiện trong các bước sau:
  - **Bước 1**: Thông điệp ban đầu được tiền xử lý thành thông điệp M rồi được chia nhỏ thành N khối 512 bits: $M^{(1)}$, $M^{(2)}$, …, $M^{(N)}$.
  - **Bước 2**: Khởi tạo giá trị cho mỗi $H_j^{(0)}$ $(1 \le j \le 8)$ tính toán tuần tự các giá trị $H_j^{(i)}$ $(1 \le i \le N)$ theo công thức:
    - $H^{(i)} = H^{(i-1)} + C_M^{(i)}(H^{(i-1)})$ với C là hàm nén SHA-256 và phép + là phép cộng theo modulo 2^{32}.
    - $H^{(N)} = (H_1^{(N)}, \ldots, H_8^{(N)})$ là giá trị băm của M.

3.2. HÀM BĂM VÀ HMAC

3.2.4. Hàm băm SHA-256

3.2.4.2. Mô tả thuật toán

- Tiền xử lý dữ liệu
  - **Bước 1: nhồi thêm dữ liệu**
    - Thông điệp ban đầu có độ dài L bit được nhồi thêm k bit (k là số nguyên nhỏ nhất) sao cho (L + k) mod 512 = 448 hay (L + k) = n * 512 + 448 (n, k, L nguyên); kể cả khi L ≡ 448 mod 512 k bit này vẫn được nhồi thêm.
    - Số bit k nằm trong khoảng [1, 512].
    - Trong k bit nhồi thêm bao gồm: 100…00 (k-1 bit 0).

3.2. HÀM BĂM VÀ HMAC

3.2.4. Hàm băm SHA-256

3.2.4.2. Mô tả thuật toán

- Tiền xử lý dữ liệu
  - **Bước 2:**
    - Độ dài của khối dữ liệu ban đầu L được biểu diễn sang dạng nhị phân 64 bit và được thêm vào cuối chuỗi nhị phân kết quả của bước 1 để thành thông điệp M.
    - Thông điệp M có độ dài là bội số của 512.
    - Chia thông điệp M thành N khối 512 bits $M^{(1)}$, $M^{(2)}$, …, $M^{(N)}$. Mỗi khối $M^{(i)}$ lại được chia thành 16 phần bằng nhau 32 bits là $M_j^{(i)}$ (j = 0, 1,…,15)

3.2. HÀM BĂM VÀ HMAC

3.2.4. Hàm băm SHA-256

3.2.4.2. Mô tả thuật toán

- Các phép toán cơ bản
  - $\oplus$: **phép XOR**
  - $\wedge$: **phép AND**
  - $\vee$: **phép OR**
  - $\neg$: **phép NOT**
  - **+ : phép cộng modulo 2^32**
  - R_n : **phép dịch phải (Shift Right) n bit**
  - S_n : **phép xoay vòng phải n bit**

3.2. HÀM BĂM VÀ HMAC

3.2.4. Hàm băm SHA-256

3.2.4.2. Mô tả thuật toán

- Khởi tạo các giá trị
  - $H_1^{(0)}$ = 0x6A09E667
  - $H_2^{(0)}$ = 0xBB67AE85
  - $H_3^{(0)}$ = 0x3C6EF372
  - $H_4^{(0)}$ = 0xA54FF53A
  - $H_5^{(0)}$ = 0x510E527F
  - $H_6^{(0)}$ = 0x9B05688C
  - $H_7^{(0)}$ = 0x1F83D9AB
  - $H_8^{(0)}$ = 0x5BE0CD19

3.2. HÀM BĂM VÀ HMAC

3.2.4. Hàm băm SHA-256

3.2.4.2. Mô tả thuật toán

- Mã giả

```
For i = 1 to N
{
  //Khởi tạo 8 thanh ghi
  a←H1(i-1); b←H2(i-1); c←H3(i-1); d←H4(i-1);
  e←H5(i-1); f←H6(i-1); g←H7(i-1); h←H8(i-1);
  //Cập nhật giá trị cho các thanh ghi
  For j = 0 to 63
  {
    T1 ← h + ∑1(e)+ Ch(e,f,g) + Kj + Wj;
    T2 ← ∑0(a)+ Maj(a,b,c);
    h ← g; g ← f; f ← e; e ← d + T1;
    d←c;
    c ← b; b ← a; a ← T1 + T2;
  }
  // Tính toán các giá trị băm Hj(i)
  H1(i) ← a + H1(i-1); H2(i) ← b + H2(i-1);
  H3(i) ← c + H3(i-1); H4(i) ← d + H4(i-1);
  H5(i) ← e + H5(i-1); H6(i) ← f + H6(i-1);
  H7(i) ← g + H7(i-1); H8(i) ← h + H8(i-1);
}
```

Trong đó:

$Ch(x,y,z) = (x \wedge y) \oplus (\neg x \wedge z)$

$Maj(x,y,z) = (x \wedge y) \oplus (x \wedge z) \oplus (y \wedge z)$

$\sum_0(x) = S^{(2)}(x) \oplus S^{(13)}(x) \oplus S^{(22)}(x)$

$\sum_1(x) = S^{(6)}(x) \oplus S^{(11)}(x) \oplus S^{(25)}(x)$

Tính W_j bằng cách:

```
For j = 0 to 15
  Wj = Mj(i);

For j = 16 to 63
  Wj ← σ1(Wj-2) + Wj-7 + σ0(Wj-15) +Wj-16;
```

Với:

$\sigma_0(x) = S^{(7)}(x) \oplus S^{(18)}(x) \oplus R^{(3)}(x)$

$\sigma_1(x) = S^{(17)}(x) \oplus S^{(19)}(x) \oplus R^{(10)}(x)$

3.2. HÀM BĂM VÀ HMAC

3.2.5. Mã xác thực thông điệp HMAC

- **HMAC:** là mã xác thực (MAC) của thông điệp m sử dụng một hàm băm H kết hợp với một khóa bí mật K.

$$\mathbf{HMAC(K, m) = H((K' \oplus opad) \,||\, H((K' \oplus ipad)||m))}$$

  - H: hàm băm mật mã an toàn; K: khóa bí mật;
  - m: thông điệp cần xác thực
  - ||: phép nối; $\oplus$: phép XOR
  - opad: đệm ngoài (0x5c5c5c ... 5c5c)
  - ipad: đệm trong (0x363636...3636)
  - K' sinh ra từ khóa mật ban đầu K

3.2. HÀM BĂM VÀ HMAC

3.2.5. Mã xác thực thông điệp HMAC

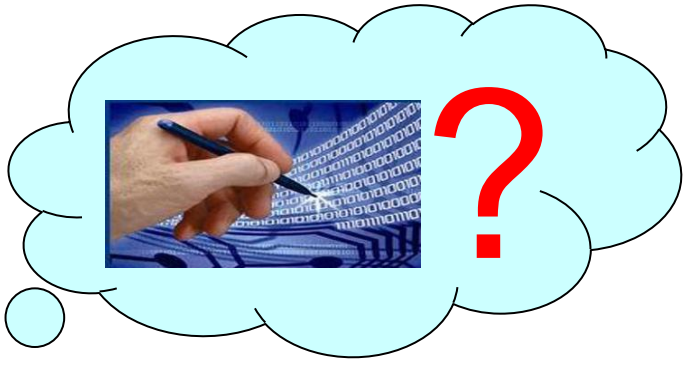
```
function HMAC (K, m)
    if (length(K) > blocksize) then
        K′ = hash(K);
    if (length(K) < blocksize) then
        K′ = K ‖ [0x00 * (blocksize - length(K))];
    opad = [0x5c * blocksize];
    ipad = [0x36 * blocksize];
    return hash((K′ ⊕ opad) ‖ hash((K′ ⊕ ipad) ‖ m));
end function
```

3.3. CHỮ KÝ SỐ

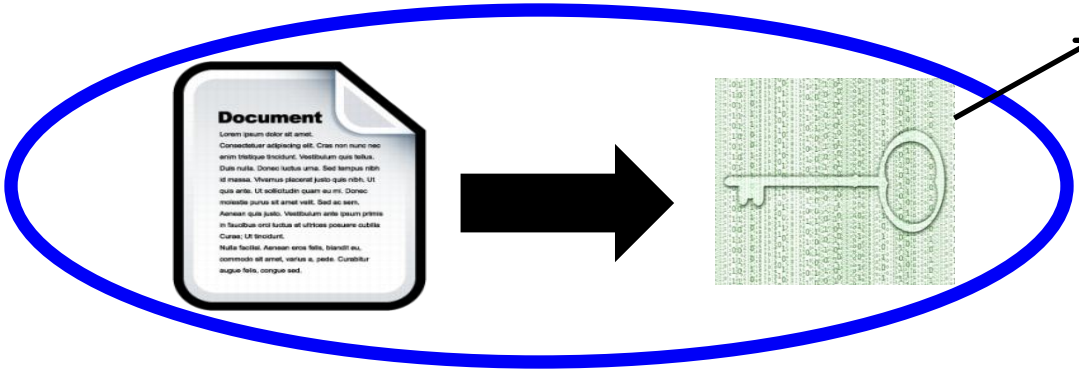
3.3.1. Các khái niệm cơ bản về chữ ký số

3.3.1.1. Khái niệm





Chữ ký số



Phân biệt: Chữ ký số và Chữ ký điện tử

3.3. CHỮ KÝ SỐ

3.3.1. Các khái niệm cơ bản về chữ ký số

3.3.1.1. Khái niệm

- Sơ đồ chữ ký (P, A, K, S, V)

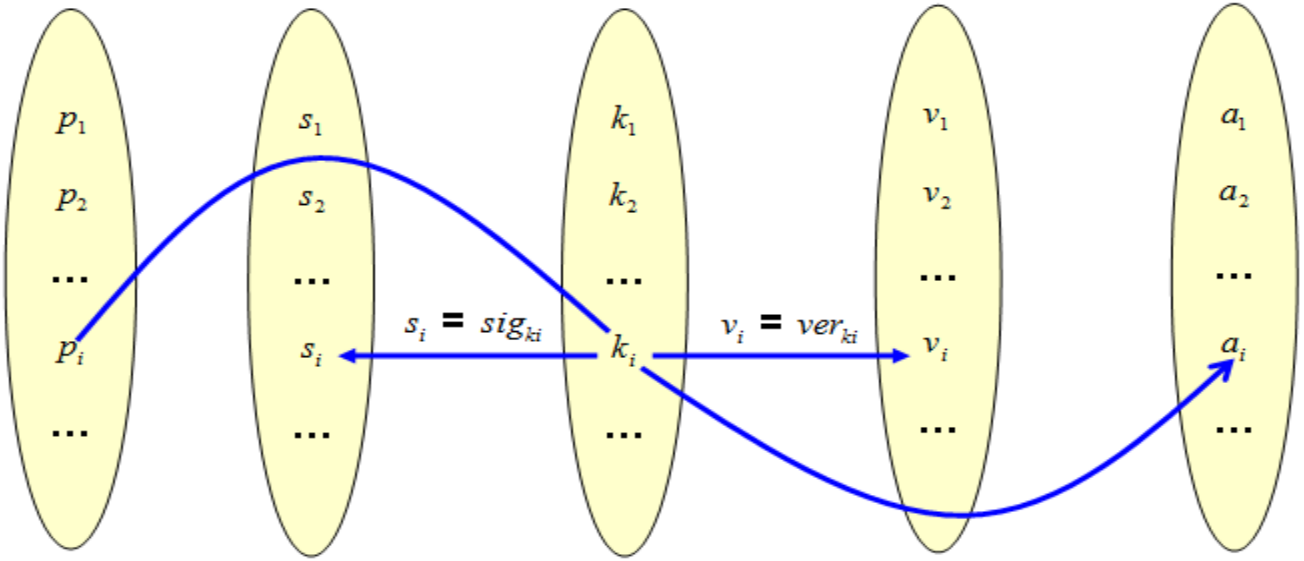
  - P: tập hữu hạn các văn bản
  - A: tập hữu hạn các chữ ký
  - K: tập hữu hạn các khóa
  - S: tập các thuật toán dùng để ký
  - V: tập các thuật toán kiểm thử

3.3. CHỮ KÝ SỐ

3.3.1. Các khái niệm cơ bản về chữ ký số

3.3.1.1. Khái niệm

- Sơ đồ chữ ký (P, A, K, S, V)

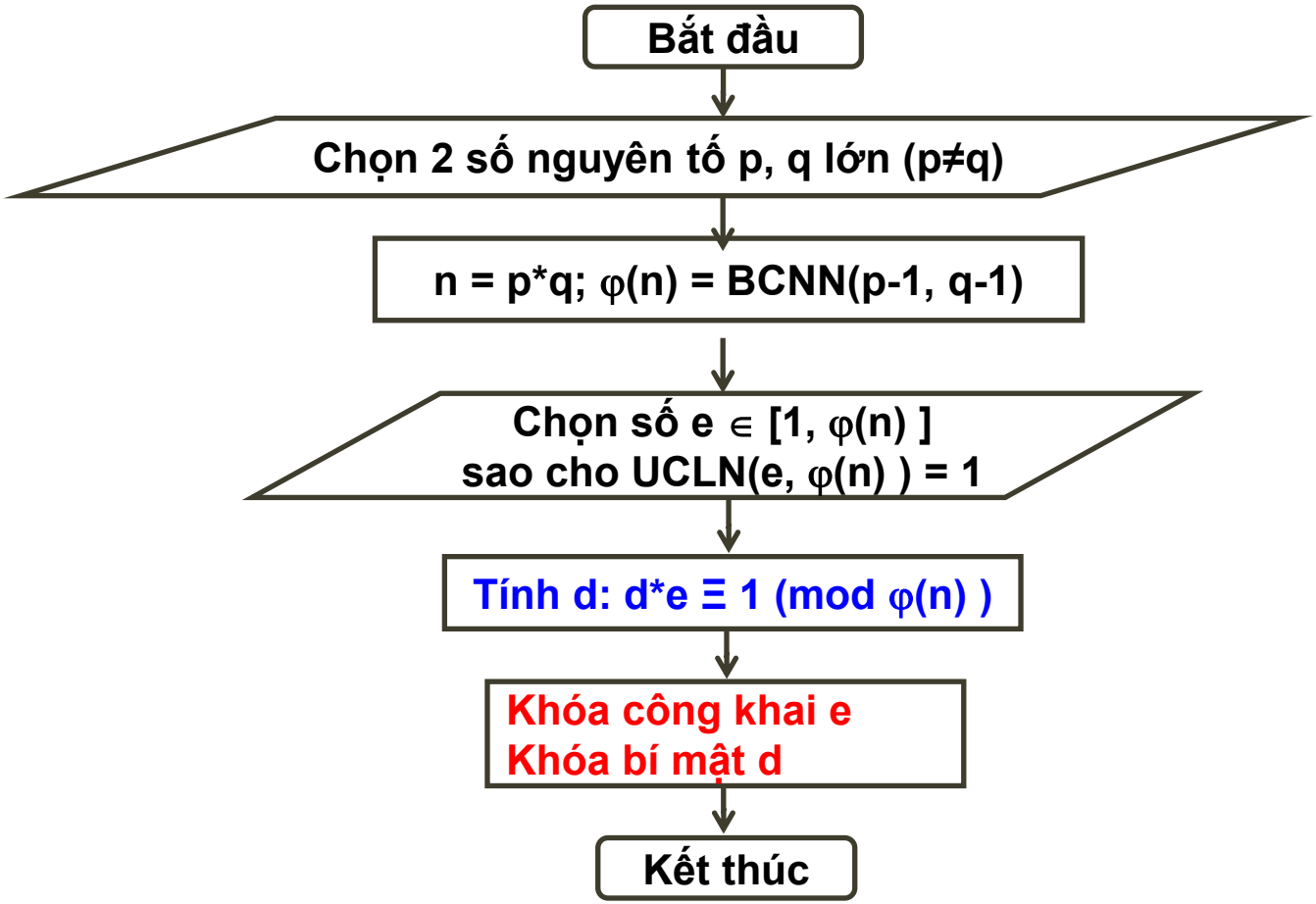


$$ver_{ki}(p_i, a_i) = \begin{cases} \text{True nếu } a_i = sig_{ki}(p_i) \\ \text{False nếu } a_i \neq sig_{ki}(p_i) \end{cases}$$

3.3. CHỮ KÝ SỐ

3.3.2. Chữ ký số RSA

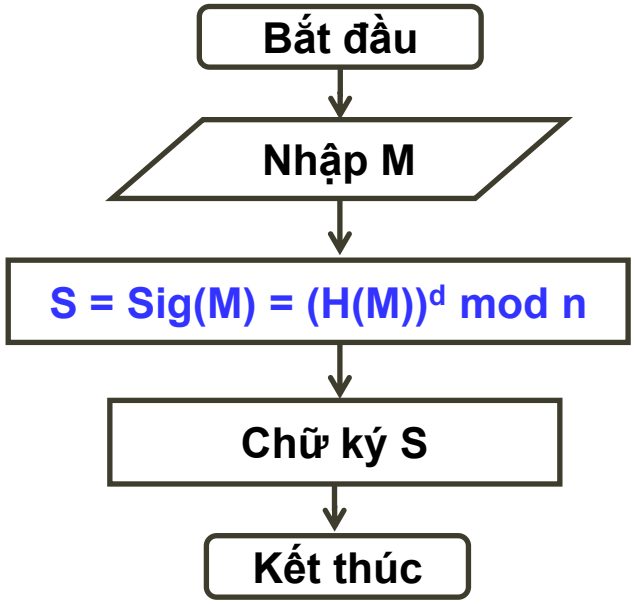
- Giai đoạn tạo khóa



3.3. CHỮ KÝ SỐ

3.3.2. Chữ ký số RSA

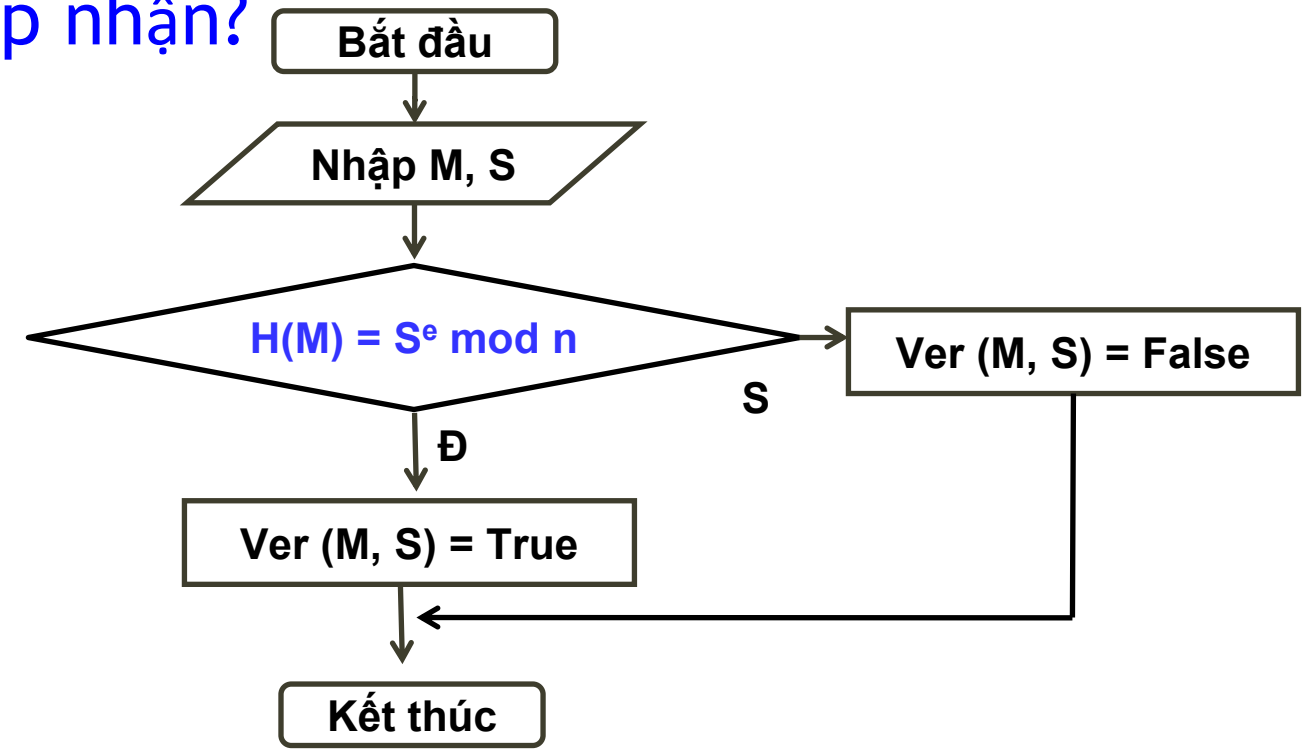
- Ký số
  - Input: thông điệp M, hàm băm H và khóa bí mật d
  - Ouput: chữ ký S của M



3.3. CHỮ KÝ SỐ

3.3.2. Chữ ký số RSA

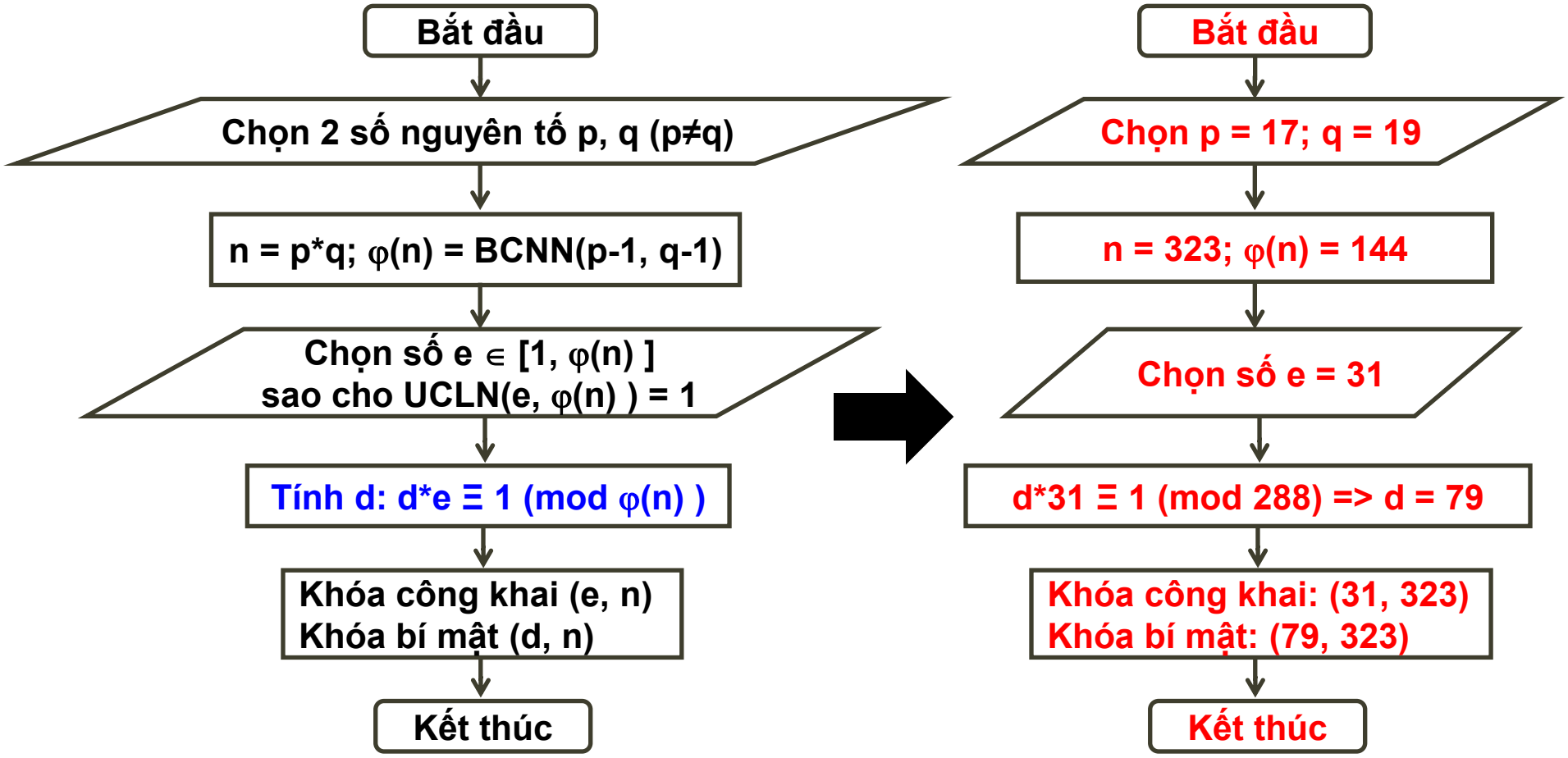
- Kiểm tra chữ ký
  - Input: chữ ký S, thông điệp M, hàm băm H, khóa công khai e
  - Ouput: Chấp nhận?



3.3. CHỮ KÝ SỐ

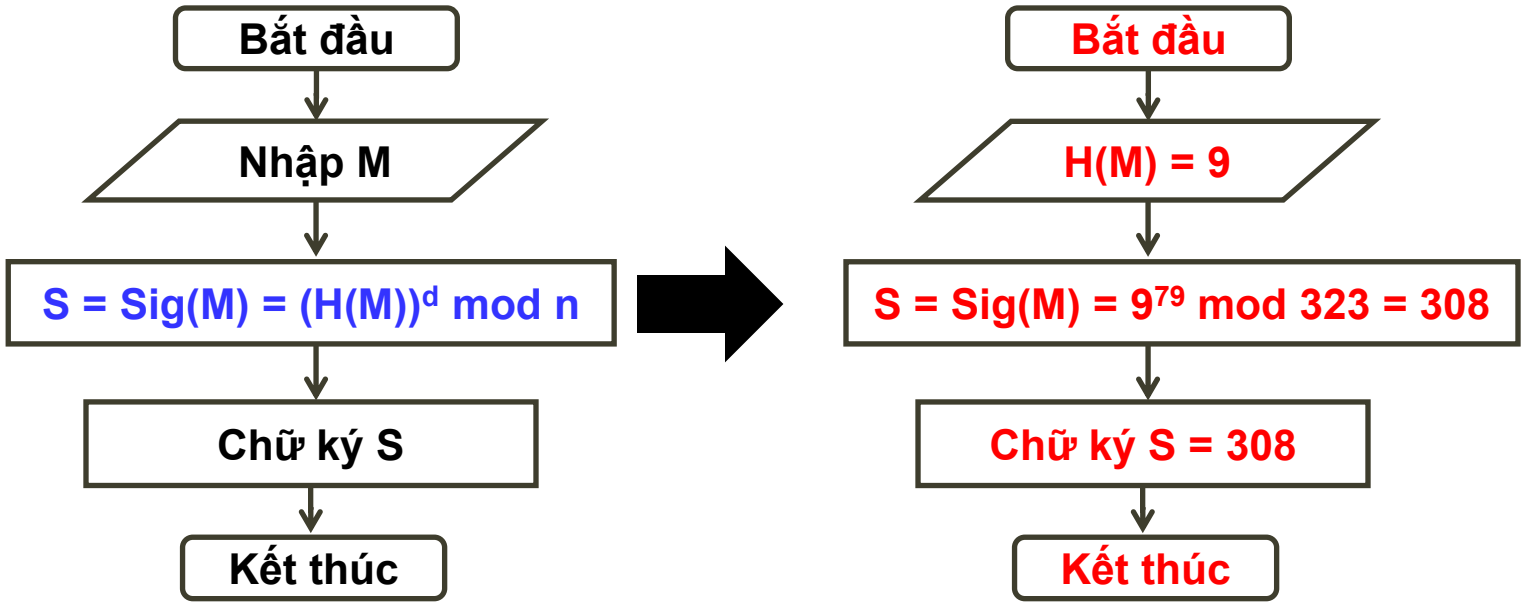
Ví dụ minh họa chữ ký số RSA

Tạo khóa



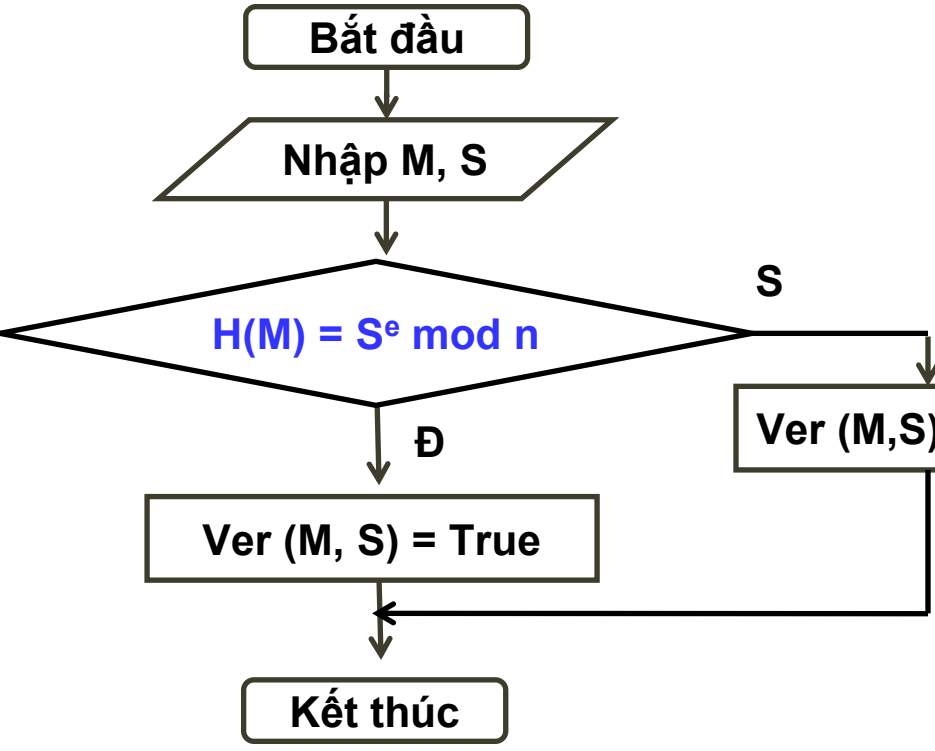
3.3. CHỮ KÝ SỐ

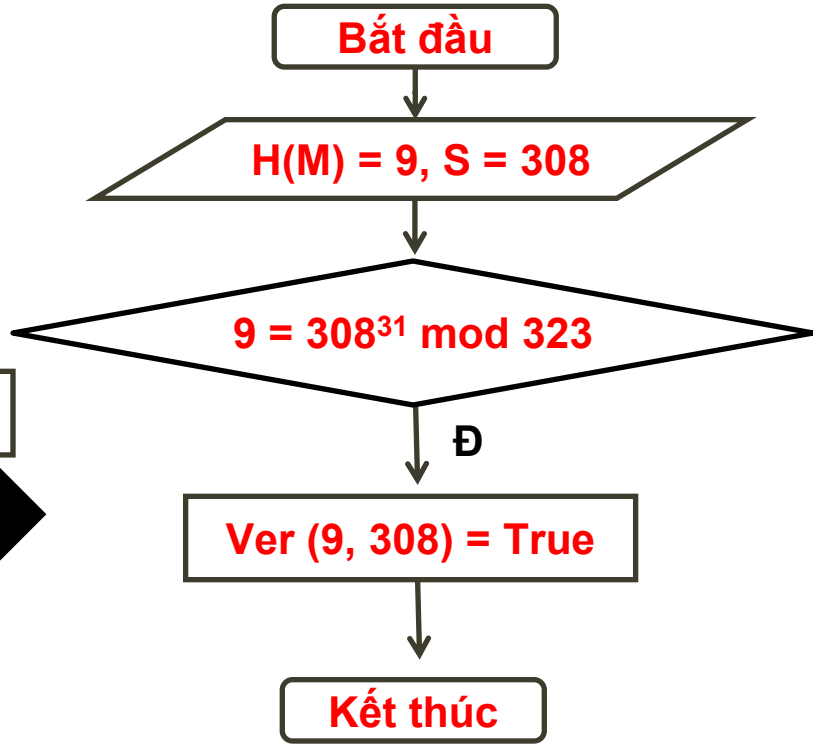
- **Ví dụ minh họa chữ ký số RSA**
  - **Ký số**



3.3. CHỮ KÝ SỐ

- **Ví dụ minh họa chữ ký số RSA**
  - **Kiểm tra chữ ký**





3.3. CHỮ KÝ SỐ

3.3.2. Chữ ký số RSA

Đánh giá độ an toàn

- Bài toán RSA: tìm P sao cho $P^e \bmod n = C$ (trong đó (e, n) là khóa công khai và C là bản mã hóa).

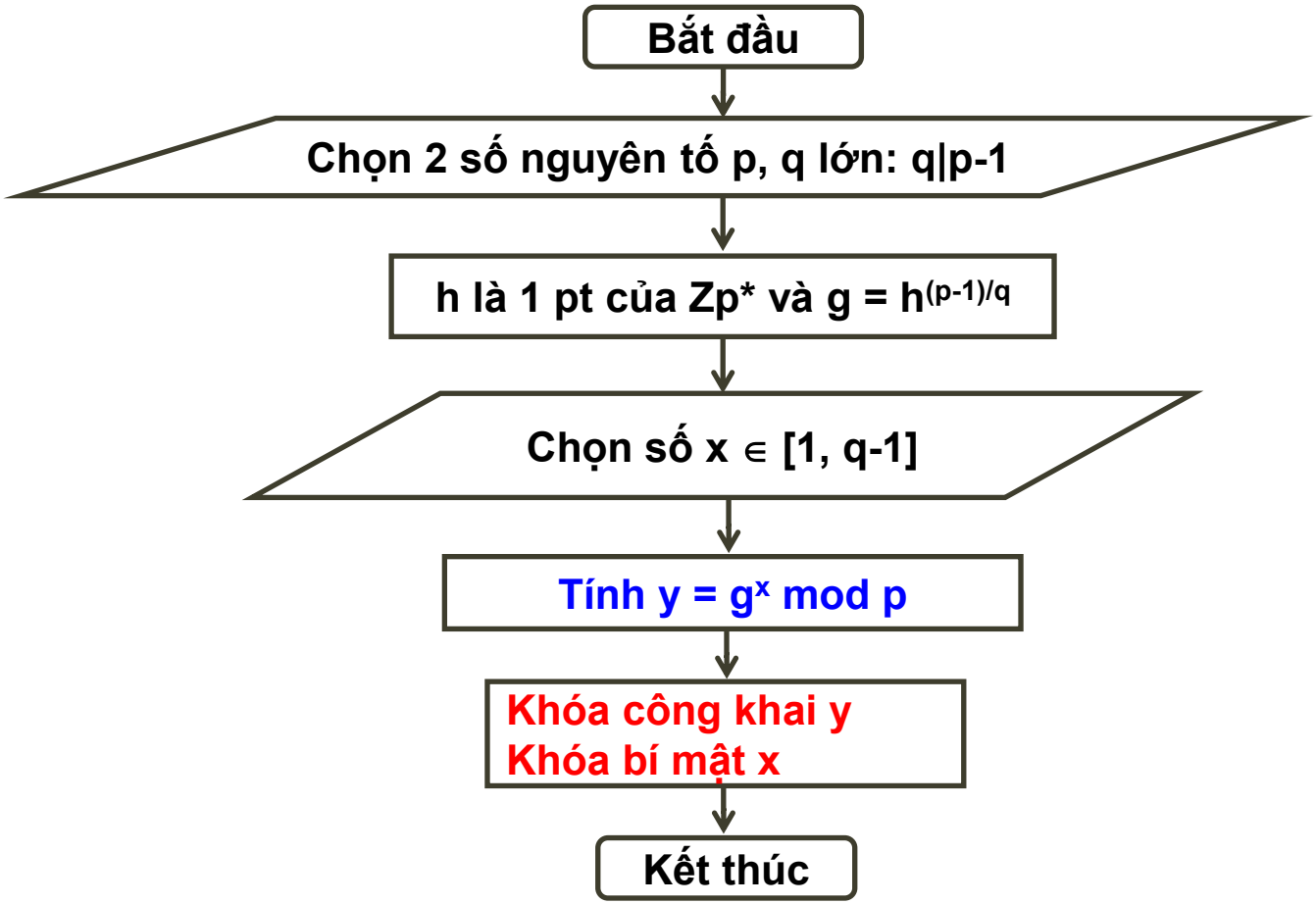
- Bài toán phân tích số nguyên dương lớn ra thừa số nguyên tố: n = p * q (trong đó p và q là 2 số nguyên tố lớn).

- Độ dài của n: Khuyến cáo sử dụng khóa có độ dài tối thiểu 2048 Bits và khóa có độ dài 4096 Bit thì hầu như không có khả năng bị phá vỡ trong tương lai gần.

3.3. CHỮ KÝ SỐ

3.3.4. Chữ ký số DSS (tự đọc và thảo luận)

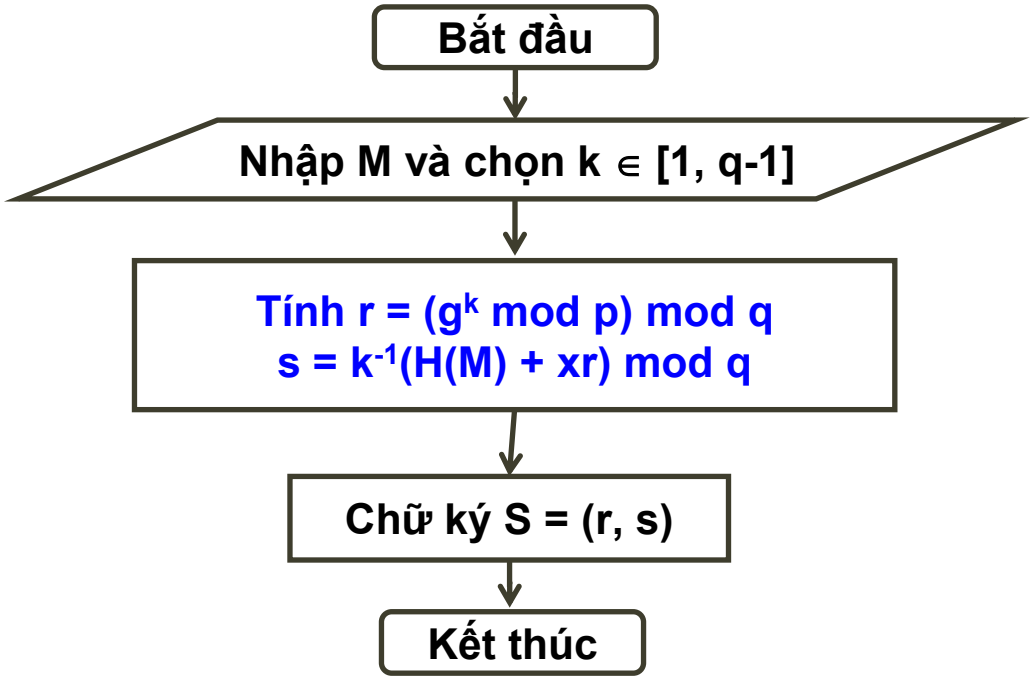
- Giai đoạn tạo khóa



3.3. CHỮ KÝ SỐ

3.3.4. Chữ ký số DSS

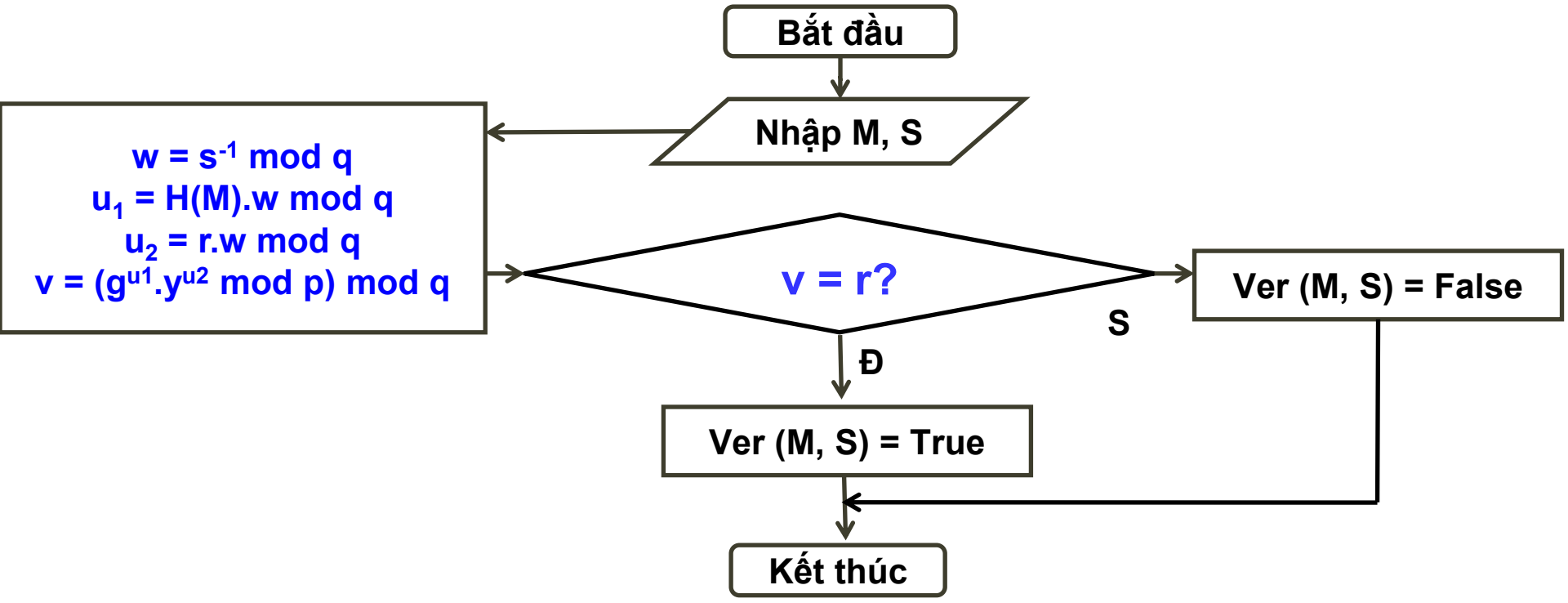
- Giai đoạn ký số
  - Input: thông điệp M, hàm băm H và khóa bí mật x
  - Ouput: chữ ký S của M



3.3. CHỮ KÝ SỐ

3.3.4. Chữ ký số DSS

- Kiểm tra chữ ký
  - Input: chữ ký S, thông điệp M, khóa công khai y
  - Ouput: Chấp nhận?



3.3. CHỮ KÝ SỐ

3.3.4. Chữ ký số DSS

Đánh giá độ an toàn

- Bài toán logarithm rời rạc: tìm x: $y = g^x \ mod \ p$
- Độ dài khóa: p = 2048 bits, q = 256 bits

TIÊU CHUẨN MẬT MÃ VÀ CHỮ KÝ SỐ

Tiêu chuẩn mật mã và chữ ký số

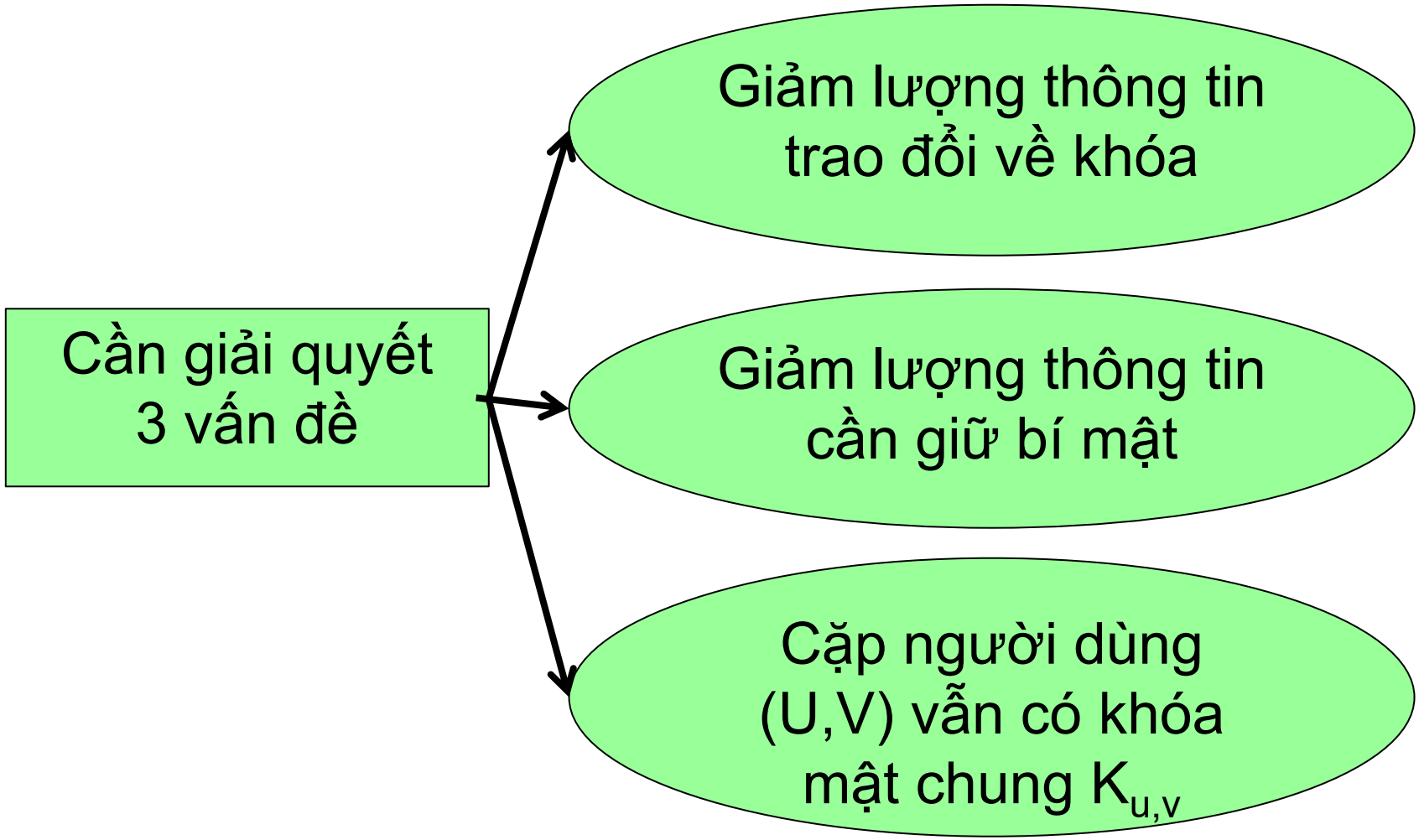
Loại tiêu chuẩn	Ký hiệu	Tên đầy đủ	Quy định áp dụng
Mật mã phi đối xứng và chữ ký số	PKCS#1	RSA Cryptography Standard	• Phiên bản 2.1 • Áp dụng lược đồ RSAES-OAEP để mã hóa • Áp dụng lược đồ RSASA-PSS để ký
Mật mã đối xứng	TCVN 7816-2007 (FIPS PUB 197)	AES	Áp dụng một trong hai
	NIST 800-67	Triple DES (3DES)	
Hàm băm an toàn	FIPS PUB 180-4	Secure Hash Standard	SHA-224; SHA-256; SHA-384; SHA-512; SHA-512/224; SHA-512/256

3.4. QUẢN LÝ KHÓA

- Với hệ mã hóa khóa đối xứng
  - Khóa mã hóa và khóa giải mã "giống" nhau.
  - Nếu biết được khóa mã hóa thì "dễ" tính được khóa giải mã, ngược lại => cả 2 đều phải giữ!
  - Nếu mạng có n người dùng thì số khóa giữ: C_n^2
  - Do đó nếu n lớn thì giải pháp này không thực tế.

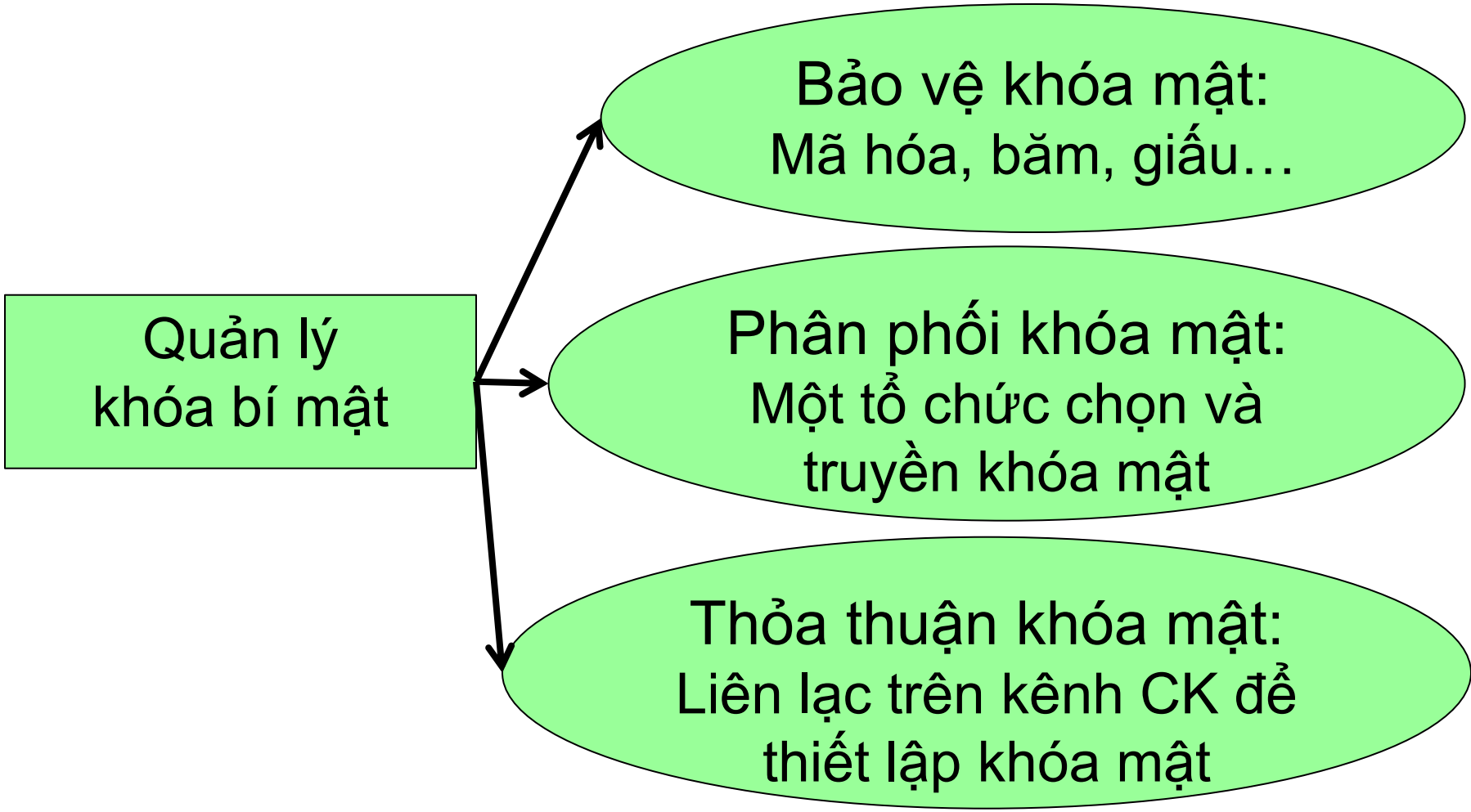
3.4. QUẢN LÝ KHÓA

- Với hệ mã hóa khóa đối xứng



3.4. QUẢN LÝ KHÓA

- Với hệ mã hóa khóa đối xứng



3.4. QUẢN LÝ KHÓA

- Với hệ mã hóa khóa công khai
  - Tốc độ mã hóa và giải mã chậm
  - Dùng mã hóa bản tin ngắn (VD: khóa bí mật)

  - Công khai thuật toán mã hoá và khóa mã hóa
  - “Khóa bí mật” chỉ do một người quản lý
  - Không cần kênh an toàn để “thống nhất“ khóa bí mật, nhưng họ phải “quản lý tốt khóa công khai”!

3.4. QUẢN LÝ KHÓA

- Tại sao cần "quản lý tốt khóa công khai"???



3.4. QUẢN LÝ KHÓA

- Ai lo quản lý "khóa công khai"???
  - Một tổ chức chuyên cung cấp và quản lý một "giấy chứng nhận" (có CSPL) để chứng thực "khóa công khai" nào đó hiện thời do ai sở hữu.
  - "Giấy chứng nhận" này được gọi là "chứng chỉ số" hay "chứng thư số" (Digital Certificate).
  - Tổ chức lo cung cấp và quản lý chứng chỉ số này được gọi là cơ quan chứng thực "khóa công khai" (CA-Certificate Authority).

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

Giao thức đảm bảo an toàn kết nối SSL/TLS

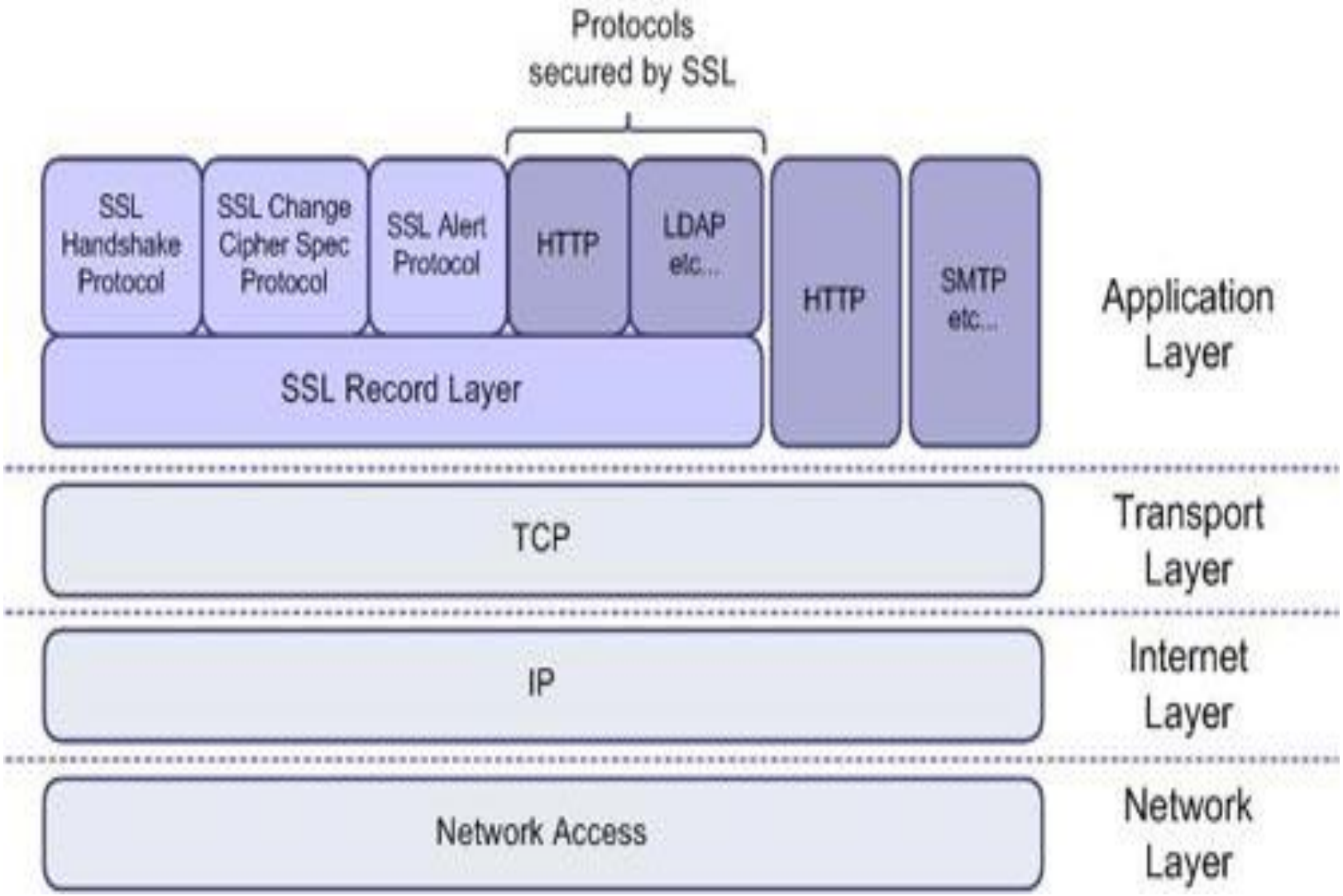
- **SSL** được tổ chức Netscape Communications công bố lần đầu tiên năm 1996. Tính đến thời điểm hiện tại SSL tồn tại 03 phiên bản:
  - **SSL 1.0**: được sử dụng nội bộ trong Netscape và không được công bố ra bên ngoài vì chứa một số khiếm khuyết nghiêm trọng.
  - **SSL 2.0**: cải tiến từ phiên bản SSL 1.0
  - **SSL 3.0** là phiên mới nhất được Netscape công bố. Qua từng năm, SSL lại được cải tiến và bổ sung một số tính năng quan trọng khác nhau.

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

SSL là giao thức nằm giữa tầng Transport và tầng Application (trong mô hình TCP/IP) nhằm đảm bảo dữ liệu truyền thông giữa máy chủ Web server và Client/trình duyệt (browser) được:

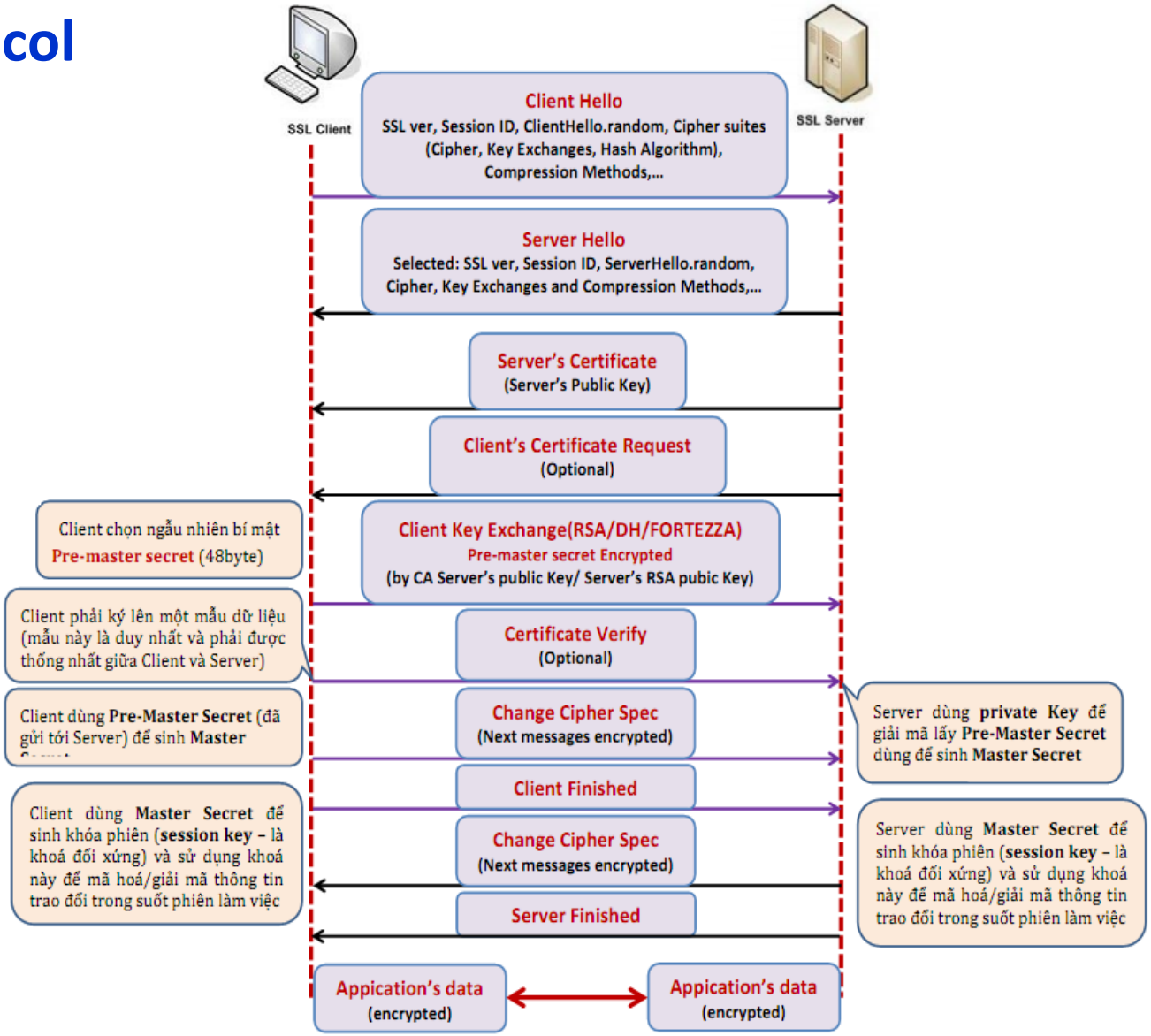
- **Riêng tư**: toàn bộ dữ liệu truyền qua kết nối đều được mã hoá.
- **Xác thực**: việc xác thực định danh được thực hiện nhờ sử dụng chứng thư số của các đối tượng tham gia kết nối.
- **Tin cậy**: duy trì kết nối tin cậy bằng việc kiểm tra tính toàn vẹn của thông điệp.

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI



CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

Handshake Protocol



CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

Handshake Protocol

```
master_secret =
MD5(pre_master_secret      ||      SHA('A'      ||
pre_master_secret    ||    ClientHello.random    ||
ServerHello.random)) ||
MD5(pre_master_secret      ||      SHA('BB'     ||
pre_master_secret    ||    ClientHello.random    ||
ServerHello.random)) ||
MD5(pre_master_secret      ||      SHA('CCC'    ||
pre_master_secret    ||    ClientHello.random    ||
ServerHello.random));
```

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

Handshake Protocol

```
Key_Block =
MD5(master_secret || SHA('A' || master_secret
|| ServerHello.random || ClientHello.random))
|| MD5(master_secret || SHA('BB' ||
master_secret || ServerHello.random ||
ClientHello.random)) || MD5(master_secret ||
SHA('CCC' || master_secret ||
ServerHello.random || ClientHello.random)) ||
[...];
```

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

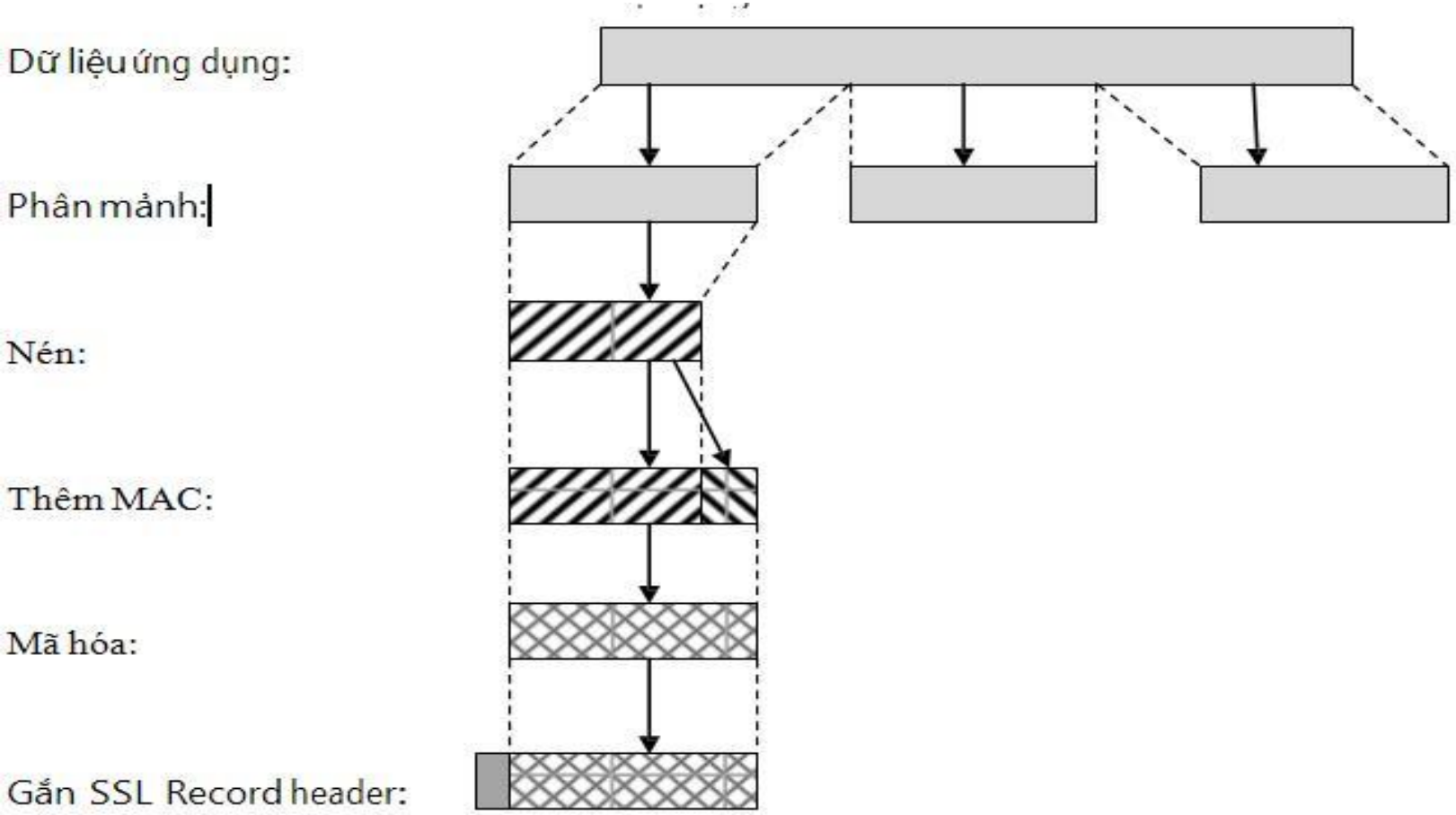
Handshake Protocol

Key_Block chia thành các phần lần lượt là:

- client_write_MAC_secret[CipherSpec.hash_size]
- server_write_MAC_secret[CipherSpec.hash_size]
- client_write_key[CipherSpec.key_material]
- server_write_key[CipherSpec.key_material]

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

Record Layer Protocol



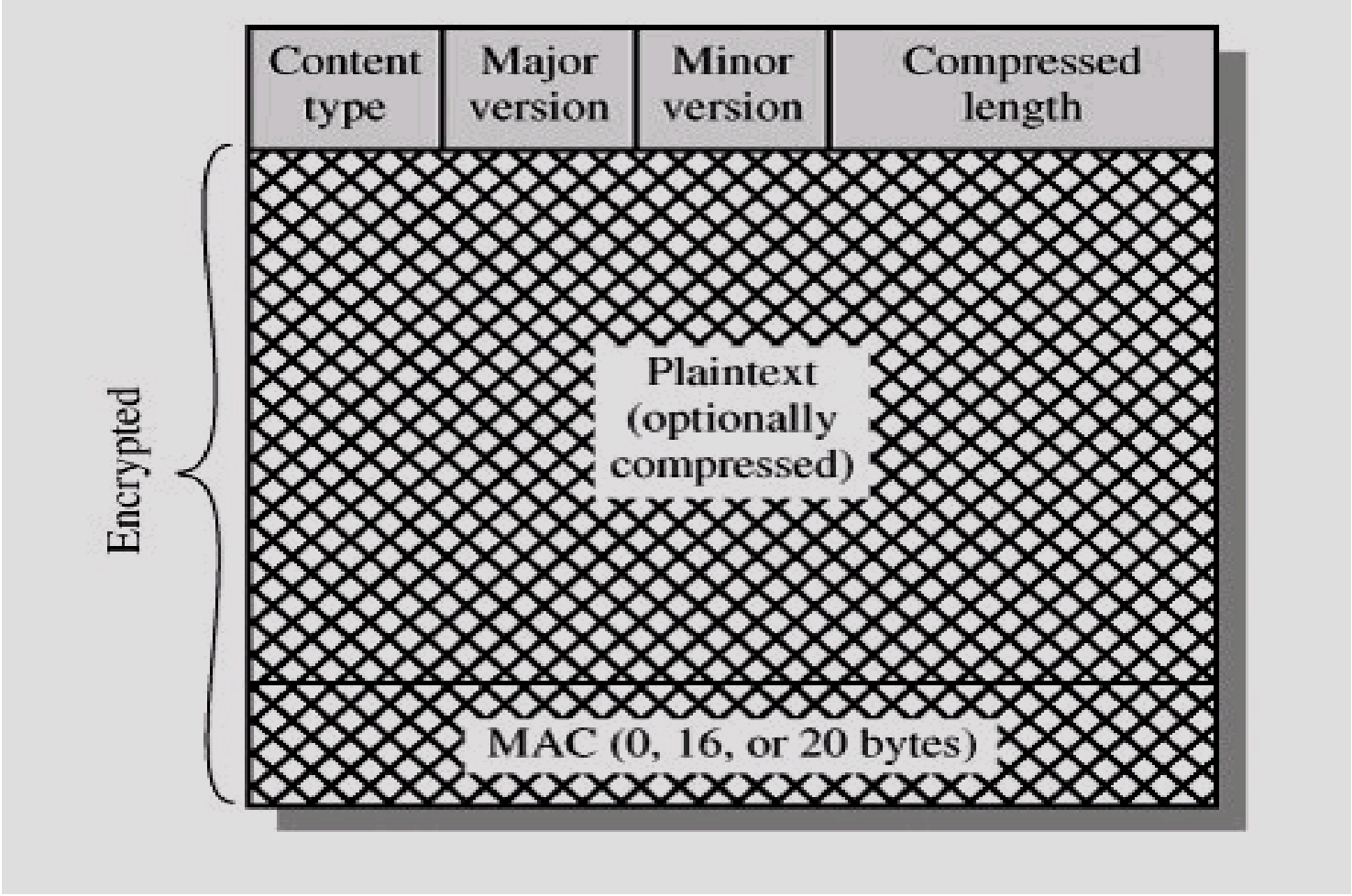
CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

Record Layer Protocol

- **Nén**: sử dụng một hàm nén dữ liệu (Compression Method)
- **MAC:** mã xác thực thông điệp với mật khẩu (Message Authentication Code) sử dụng hàm băm MD5 và SHA-1.
- **Mã hóa:** sử dụng một hệ mã hóa khóa đối xứng DES/3DES

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

Record Layer Protocol



CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

Record Layer Protocol

- **Content Type:** chỉ giao thức tầng cao hơn được sử dụng để đóng gói các phân mảnh.
- **Major Version:** số phiên bản chính của giao thức (3)
- **Minor Version:** số phiên bản phụ của giao thức (1)
- **Compressed Length:** độ dài (tính bằng byte) của phần dữ liệu phân mảnh.

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

- **Change Cipher Spec Protocol**: tạo ra một thông điệp trạng thái thông báo rằng bắt đầu truyền thông an toàn giữa Server và Client. Thông điệp này chứa byte 1 duy nhất.

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

- **Alert Protocol**: giao thức thông báo lỗi hoặc những cảnh báo về kết nối giữa các thành viên. Tầng này có cấu trúc bao gồm hai trường: **Severity Level** và **Alert Description**.
  - **Severity Level**: có vai trò gửi thông điệp cùng với giá trị ‘1’ hoặc ‘2’. Giá trị ‘1’ tương ứng với thông điệp cảnh báo lỗi; Giá trị ‘2’ là những cảnh báo quan trọng, yêu cầu các bên tham gia chấm dứt phiên kết nối.
  - **Alert Description:** chỉ ra các lỗi cụ thể, trường này chỉ có độ dài 1 byte, có miền giá trị từ 1 đến 12 tương ứng với 12 lỗi nghiêm trọng.

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

- **Một số lỗ hổng của OpenSSL**
  - **Heartbleed (4/2014):** dựa trên mỗi thông điệp mang tên **heartbeat** cho phép kẻ tấn công đọc được từng 64KB bộ nhớ trên Server do đó chúng dễ dàng thu được thông tin bí mật.
  - **Poodle (10/2014):** cho phép tin tặc có thể đánh cắp "cookies" duyệt web và thực hiện tấn công **man-in-the-middle** để thu được thông tin bí mật.
  - **Freak (2015):** cho phép kẻ tấn công can thiệp vào các kết nối bảo mật HTTPS giữa Server và Client, sau đó buộc website hạ cấp độ an toàn để dễ giải mã các thông điệp.

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

- Transport Layer Security (TLS) được phát triển dựa trên tiêu chuẩn SSL v3.0.
- **TLS v1.3** là phiên bản mới nhất, cải tiến một số vấn đề:
  - Không hỗ trợ hệ mật trên đường cong Elliptic "yếu"
  - Không còn hỗ trợ hàm băm MD5 và SHA-224
  - Yêu cầu chữ ký số ngay cả khi trước đó đã được sử dụng
  - Sử dụng hàm tính khóa bí mật HKDF (thay thế cho PRF)
  - Thay đổi/cập nhật một số công cụ mã hóa khác

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

- **Sự khác biệt của TLS với SSL**
  - **TLS không còn cảnh báo lỗi thiếu chứng thư:** Trong SSLv3.0 (RFC 6101), một Client thường phản hồi với một thông điệp ***no_certificate error alert*** mỗi khi Server yêu cầu chứng thư số nhưng Client không có. Trong TLS, cảnh báo này là không cần thiết. Tuy nhiên, Client phải gửi một thông điệp xác nhận không có chứng chỉ.

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

❑ Sự khác biệt của TLS với SSL

○ TLS có nhiều Alert descriptions hơn SSL

SSL Alert Descriptions

- Close Notify,
- Unexpected Message,
- Bad Record MAC,
- Decompression Failure,
- Handshake Failure,
- No Certificate,
- Bad Certificate,
- Unsupported Certificate,
- Certificate Revoked,
- Certificate Expired,
- Certificate Unknown, and
- Illegal Parameter.

Additional Alert Descriptions only found in TLS

- Decryption Failed,
- Record Overflow,
- Unknown CA (Certificate Authority),
- Access Denied,
- Decode Error,
- Decrypt Error,
- Export Restriction,
- Protocol Version,
- Insufficient Security,
- Internal Error,
- User Canceled,
- No Renegotiation,
- Unsupported Extension,
- Certificate Unobtainable,
- Unrecognized Name,
- Bad Certificate Status Response,
- Bad Certificate Hash Value,
- Unkown PSK, and
- No Application Protocol.

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

- **Sự khác biệt của TLS với SSL**
  - **TLS sử dụng HMAC tạo mã xác thực thông điệp:** SSL sử dụng hàm băm MD5, SHA để tạo ra mã xác thực thông điệp (MACs). Còn với TLS, ngoài hai hàm băm MD5 và SHA còn sử dụng HMAC với nhiều hàm băm khác. Thậm chí TLS v1.3 đã loại bỏ hai hàm băm MD5, SHA-224.

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

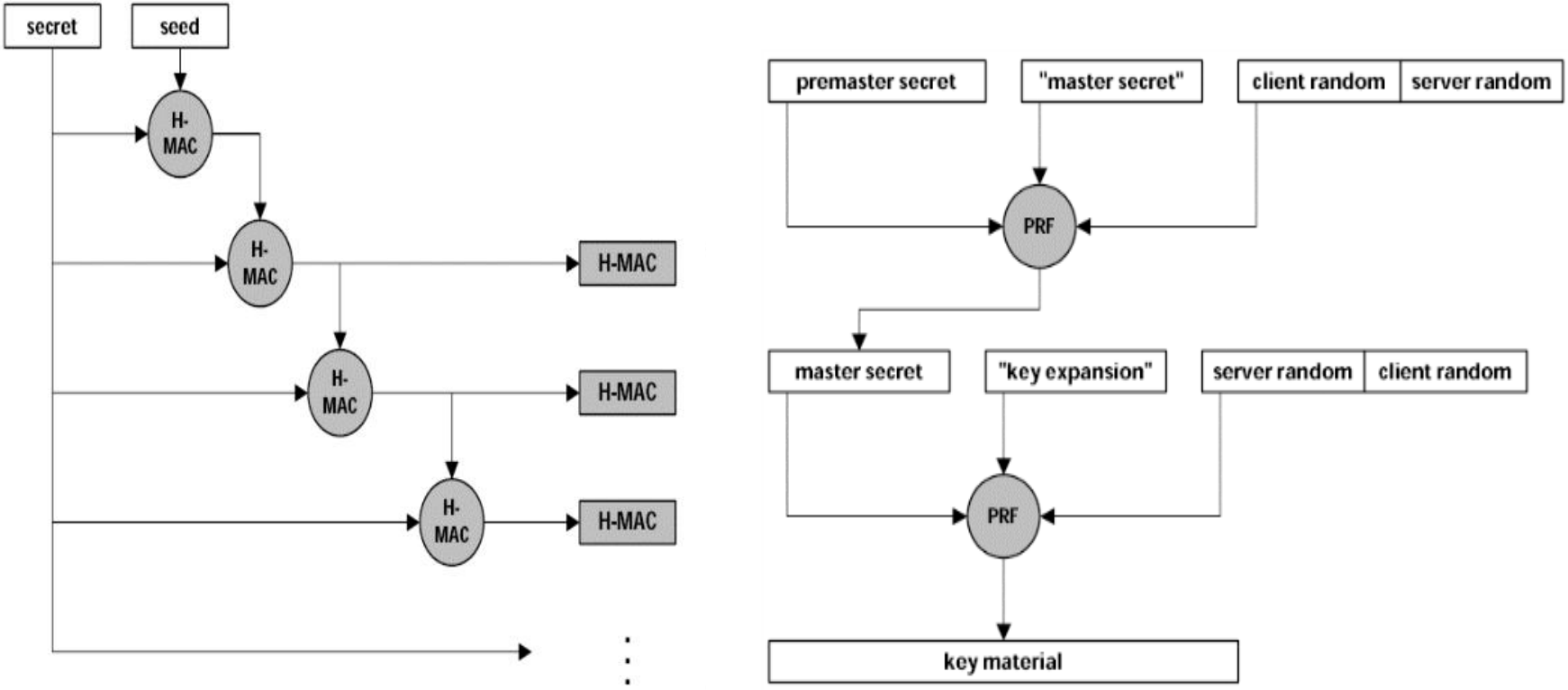
Sự khác biệt của TLS với SSL

- **TLS dùng PRF để tạo ra "key material"**
  - P_hash(secret, seed) = HMAC(secret, A(1) || seed) ||
  - HMAC (secret, A(2) || seed) ||... cho đến khi đủ số Byte.
    - ✓ **A(0) = seed và A(i) = HMAC_hash(secret, A(i-1))**
  - PRF(secret, label, seed) = P_hash(secret, label || seed)
  - **master_secret** = PRF(**pre_master_secret**, "master secret", ClientHello.random || ServerHello.random) → 48 byte
  - **key_block** = PRF(master_secret, "key expansion", ClientHello.random || ServerHello.random)

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

Sự khác biệt của TLS với SSL

- TLS dùng PRF để tạo ra "key material"



CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

Sự khác biệt của TLS với SSL

Xác thực chứng thư -CertificateVerify

- ✓ Trong TLS, thông tin được ký trong hàm Certificate Verify chỉ là các thông điệp **HandShake** trước đó được trao đổi.
- ✓ Trong SSL, thông tin được ký trong hàm Certificate Verify khá phức tạp, nó là sự kết hợp hai hàm băm MD5 và SHA với các thông điệp **HandShake**, **master secret** cùng các thành phần phụ khác.

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

- **Sự khác biệt của TLS với SSL**
  - **Bộ mã hóa**
    - ✓ Tên gọi của bộ mã hóa trong TLS bắt đầu với TLS_ còn trong SSL bắt đầu với SSL_
    - ✓ TLS không sử dụng FORTEZZA cho quá trình trao đổi khóa trong khi SSL v3 có hỗ trợ.
    - ✓ TLS sử dụng chuẩn mã hóa khóa đối xứng AES còn SSL chỉ sử dụng chuẩn DES, 3DES.

CÔNG NGHỆ ĐẢM BẢO AN TOÀN KẾT NỐI

- **Sự khác biệt của TLS với SSL**
  - **Thông điệp hoàn thành (Finished Message)**
    - ✓ Trong TLS:
    - ✓ PRF(master_secret, “client finished”/ “server finished”, Hash(HS_msg))
    - ✓ Trong SSL:
    - ✓ MD5(master_secret || pad2 || MD5(HS_msg || “SRVR” || master_secret || pad1))
    - ✓ SHA(master_secret || pad2 || SHA(HS_msg || “SRVR” || master_secret || pad1))
    - ✓ MD5(master_secret|| pad2 || MD5(HS_msg || “CLNT” || master_secret || pad1))
    - ✓ SHA(master_secret || pad2 || SHA(HS_msg || “CLNT” || master_secret || pad1))

SECURE ELECTRONIC TRANSACTION

- Sự cần thiết phải tạo ra phương thức thanh toán an toàn dành riêng cho các giao dịch thương mại điện tử:
  - Một giao dịch thanh toán trong thương mại điện tử có sự tham gia của các bên: **Bên mua, bên bán, Ngân hàng của bên mua, Ngân hàng của bên bán, Cổng thanh toán**...
  - SSL/TLS đơn giản chỉ là đảm bảo các thông tin truyền trên mạng Internet được: riêng tư, xác thực và toàn vẹn không đáp ứng được nhu cầu thanh toán điện tử.

SECURE ELECTRONIC TRANSACTION

- SET không phải là HTTT, nó là một tập những giao thức an ninh và định dạng cho phép người dùng thẻ tín dụng để thanh toán qua mạng mở (Internet) được an toàn.
- SET cung cấp ba dịch vụ chính:
  - Cung cấp một kênh truyền thông **an toàn** cho những bên tham gia trong một giao dịch thanh toán
  - Cung cấp sự **tin cậy** bằng chứng thư số X.509v3
  - Bảo đảm tính **riêng tư** do thông tin chỉ sẵn có cho những người tham gia trong giao dịch khi nào cần thiết (VD: Người bán không biết PI, Ngân hàng không biết OI).

SECURE ELECTRONIC TRANSACTION

- SET phải được đảm bảo các yêu cầu sau:
  - **Cung cấp sự tin cậy cho người mua hàng**: SET sử dụng phương thức mã hóa để bảo mật thông tin và tránh được rủi ro gian lận cho người mua hàng.
  - **Bảo đảm sự toàn vẹn của dữ liệu truyền**: SET sử dụng chữ ký số đảm bảo không có sự thay đổi nội dung trong các thông điệp trao đổi giữa hai bên tham gia giao dịch.
  - **Cung cấp việc chứng thực cho người mua hàng** là người dùng hợp pháp của tài khoản thẻ tín dụng (chữ ký số và chứng thư số được sử dụng để kiểm tra tính hợp pháp của người mua hàng).

SECURE ELECTRONIC TRANSACTION

- SET phải được đảm bảo các yêu cầu sau:
  - **Cung cấp sự chứng thực rằng người bán có thể giao dịch bằng thẻ tín dụng qua MQH với một NH/TCTD**: SET cũng sử dụng chữ ký số và chứng thư số để giúp người mua hàng xác thực được người bán.
  - **Bảo vệ an toàn** cho những người tham gia hợp pháp trong giao dịch điện tử bằng những công cụ tốt nhất.
  - **Tạo ra một phương thức** mà không phụ thuộc giao thức truyền tin. Điều này làm cho SET khác biệt với SSL/TLS.
  - **Mềm dẻo và dễ dàng thích nghi**: định dạng và giao thức của SET độc lập với nền tảng phần cứng, hệ điều hành và phần mềm web.

SECURE ELECTRONIC TRANSACTION

Đặc trưng khóa của SET

- **Sự tin cậy của thông tin:** thông tin về tài khoản (số thẻ tín dụng) và thanh toán của người mua được bảo mật. Để thực hiện điều này, SET sử dụng hệ mã hóa DES
- **Sự toàn vẹn của dữ liệu:** SET đảm bảo sự toàn vẹn cho thông tin thanh toán gửi từ người mua đến người bán bao gồm: thông tin đặt hàng, dữ liệu cá nhân...Để thực hiện điều này, SET sử dụng chữ ký số RSA, hàm băm SHA-1 và HMAC.

SECURE ELECTRONIC TRANSACTION

Đặc trưng khóa của SET

- Chứng thực tài khoản Cardholder: SET cho phép người bán có thể kiểm tra người mua hợp lệ của số tài khoản trên thẻ. SET dùng chứng thư số X.509v3 với chữ ký số RSA để thực hiện mục đích này.
- Chứng thực người bán: SET cũng cho phép người dùng kiểm tra được người bán có mối quan hệ tài chính với một ngân hàng hoặc một tổ chức tín dụng nào đó chấp nhận thanh toán thẻ. SET cũng dùng chứng thư số X.509v3 với chữ ký số RSA để thực hiện mục đích này

SECURE ELECTRONIC TRANSACTION

Các thành phần tham gia thanh toán

-Thẻ của một tổ chức phát hành
- Có khả năng thanh toán bằng thẻ



Internet

Merchant

Có tk tại NH thu

Phát hành chứng thư số cho các bên



Internet

Xác thực và xử lý một y/c TT bằng thẻ cho người bán



Payment Network





Người bán trao đổi thông điệp SET với cổng P/G, P/G kết nối trực tiếp tới tổ chức tài chính thu để yêu cầu xử lý thanh toán

SECURE ELECTRONIC TRANSACTION

Quy trình thực hiện giao dịch điện tử sử dụng SET

- Yêu cầu trước khi thực hiện thanh toán







CardHolder's Certificate X509v3 (PUBLIC KEY-RSA, VALID DATE…)



Merchant's Certificate X509v3 (**PUBLIC KEY**-RSA, VALID DATE…)

P/G's Certificate X509v3 (PUBLIC KEY-RSA, VALID DATE…)

SECURE ELECTRONIC TRANSACTION

❑ Quy trình thực hiện giao dịch điện tử sử dụng SET

○ Các chú ý thực hiện giao dịch điện tử sử dụng SET

Các loại thông điệp giao dịch

Tên thông điệp	Nội dung thông điệp
Capture Reversal	Cho phép người bán sửa những lỗi trong việc nắm bắt các giao dịch (VD: tổng giá trị giao dịch) do có lỗi khi nhập.
Credit	Cho phép người bán trả lại tiền vào tài khoản của người mua khi hàng hóa bị trả lại hoặc giao hàng không thành công.
Credit Reversal	Cho phép người bán sửa yêu cầu tín dụng trước đó.
P/G Certificate Request	Cho phép người bán có thể truy vấn và nhận một bản sao chứng thư số gồm chữ ký và trao đổi khóa hiện tại của Cổng thanh toán.
Batch Administration	Cho phép người bán kết nối thông tin đến Cổng thanh toán

SECURE ELECTRONIC TRANSACTION

❑ Quy trình thực hiện giao dịch điện tử sử dụng SET

○ Các chú ý thực hiện giao dịch điện tử sử dụng SET

Các loại thông điệp giao dịch

Tên thông điệp	Nội dung thông điệp
Error Message	Phản hồi lại một thông điệp khi nó bị lỗi định dạng hoặc nội dung
CardHolder Registration	Người mua đăng ký sử dụng với một CA trước khi có thể gửi các thông điệp SET đến người bán
Merchant Registration	Người bán đăng ký sử dụng với một CA trước khi có thể trao đổi thông điệp SET đến người mua và Cổng thanh toán.
Purchase Request	Thông điệp của người mua gửi đến người bán bao gồm: OI cho người bán và PI cho ngân hàng.
Payment Authorization	Trao đổi giữa người bán và Cổng thanh toán để ủy quyền bán một lượng hàng hóa với giá trị biết trước cho một tài khoản thẻ tín dụng.

SECURE ELECTRONIC TRANSACTION

❑ Quy trình thực hiện giao dịch điện tử sử dụng SET

○ Các chú ý thực hiện giao dịch điện tử sử dụng SET

Các loại thông điệp giao dịch

Tên thông điệp	Nội dung thông điệp
Payment Capture	Cho phép người bán gửi yêu cầu thanh toán tới Cổng thanh toán.
Certificate inquiry and status	Nếu CA không thể hoàn thành ngay việc xử lý yêu cầu cấp chứng thư, nó sẽ gửi phản hồi đến người bán và người mua để gửi lại yêu cầu sau. Người bán hoặc người mua gửi thông điệp **Certificate inquiry** để xác nhận trạng thái của yêu cầu cấp chứng thư và nhận chứng thư nếu yêu cầu được chấp nhận.
Purchase inquiry	Cho phép người mua kiểm tra trạng thái của đơn hàng sau khi đã được người bán chấp nhận
Authorization Reversal	Cho phép người bán sửa yêu cầu ủy quyền. Nếu đơn hàng không được xử lý thành công, người bán lấy lại toàn bộ quyền; còn nếu một phần đơn hàng không được xử lý thành công thì người bán lấy lại giá trị của phần đó.

SECURE ELECTRONIC TRANSACTION

- Quy trình thực hiện giao dịch điện tử sử dụng SET

b. Purchase Request Message-Yêu cầu mua hàng

- PI: PAYMENT INFORMATION (TID, Credit Card Number…)
- OI: ORDER INFORMATION, PIMD = SHA-1(PI)
- OIMD = SHA-1(OI), POMD = SHA-1(PIMD||OIMD)
- DUAL SIGNATURE = $E_{PRIV_CARDHOLDER}$ (POMD)
- K_S: SESSION KEY (C-I/M-P)
- DIGITAL ENVELOPE(CI) = $E_{PUB_ISSUER}(K_{S1})$
- DIGITAL ENVELOPE(MP) = $E_{PUB_PG}(K_{S2})$

SECURE ELECTRONIC TRANSACTION

Quy trình thực hiện giao dịch điện tử sử dụng SET



Cardholder





Merchant

(1)

Gửi lại Form đơn đặt hàng: TID, Danh sách SP, đơn giá, tổng giá trị đơn hàng

(2)

Xác nhận lại đơn hàng và đề nghị TT

(3)

Merchant's Certificate

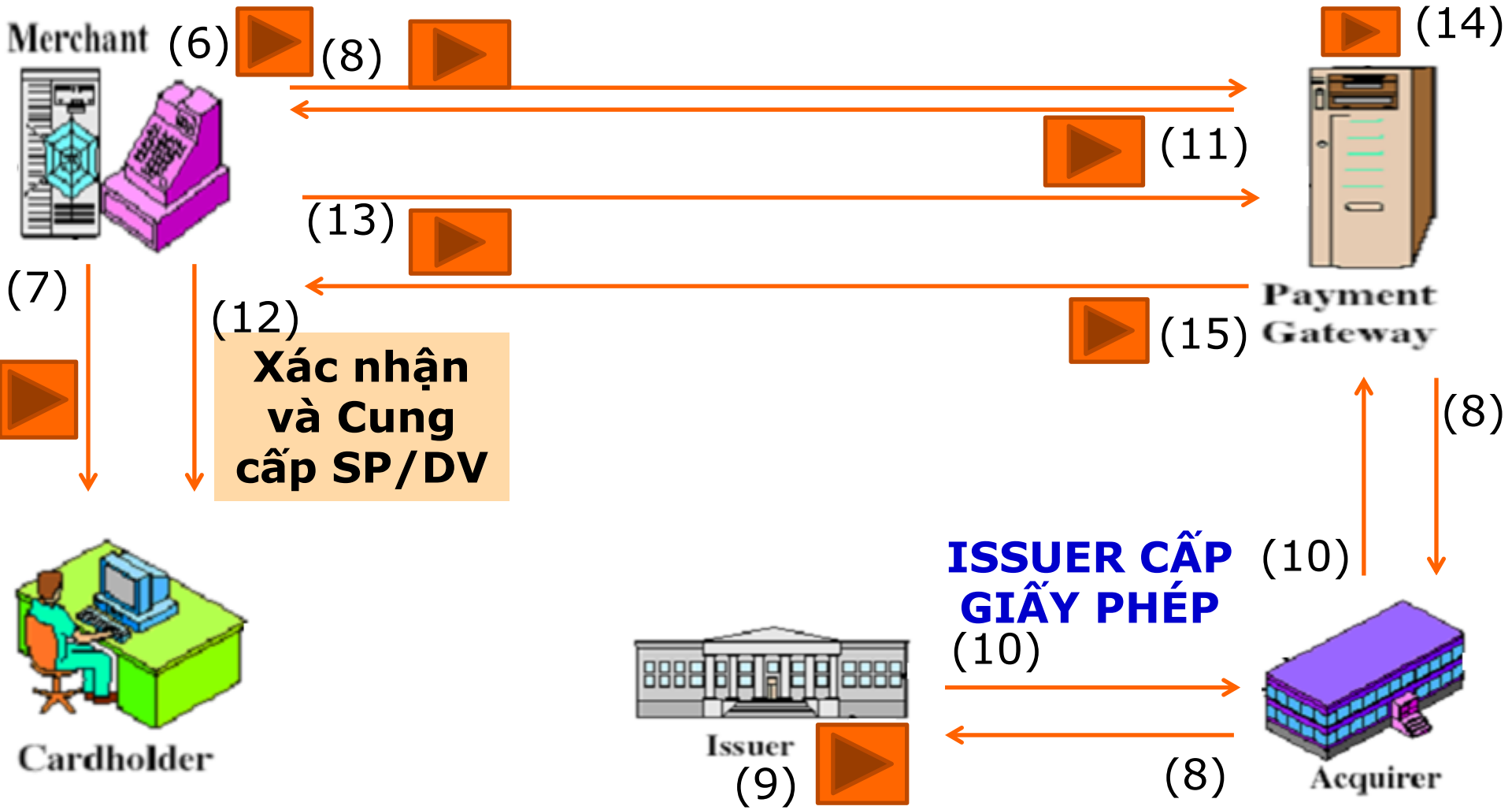
P/G's Certificate

(4)

(5)

SECURE ELECTRONIC TRANSACTION

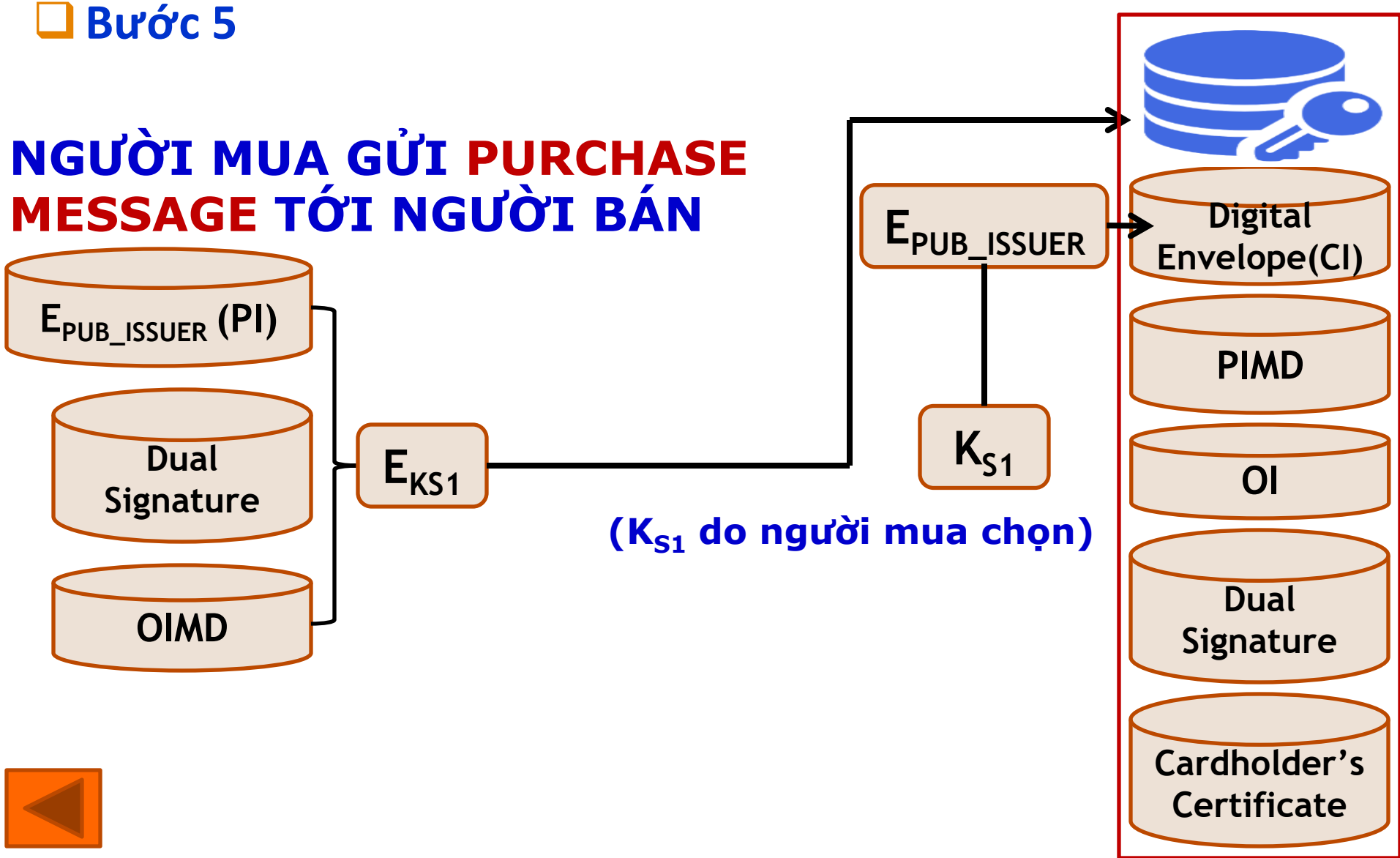
Quy trình thực hiện giao dịch điện tử sử dụng SET



SECURE ELECTRONIC TRANSACTION

- Bước 5

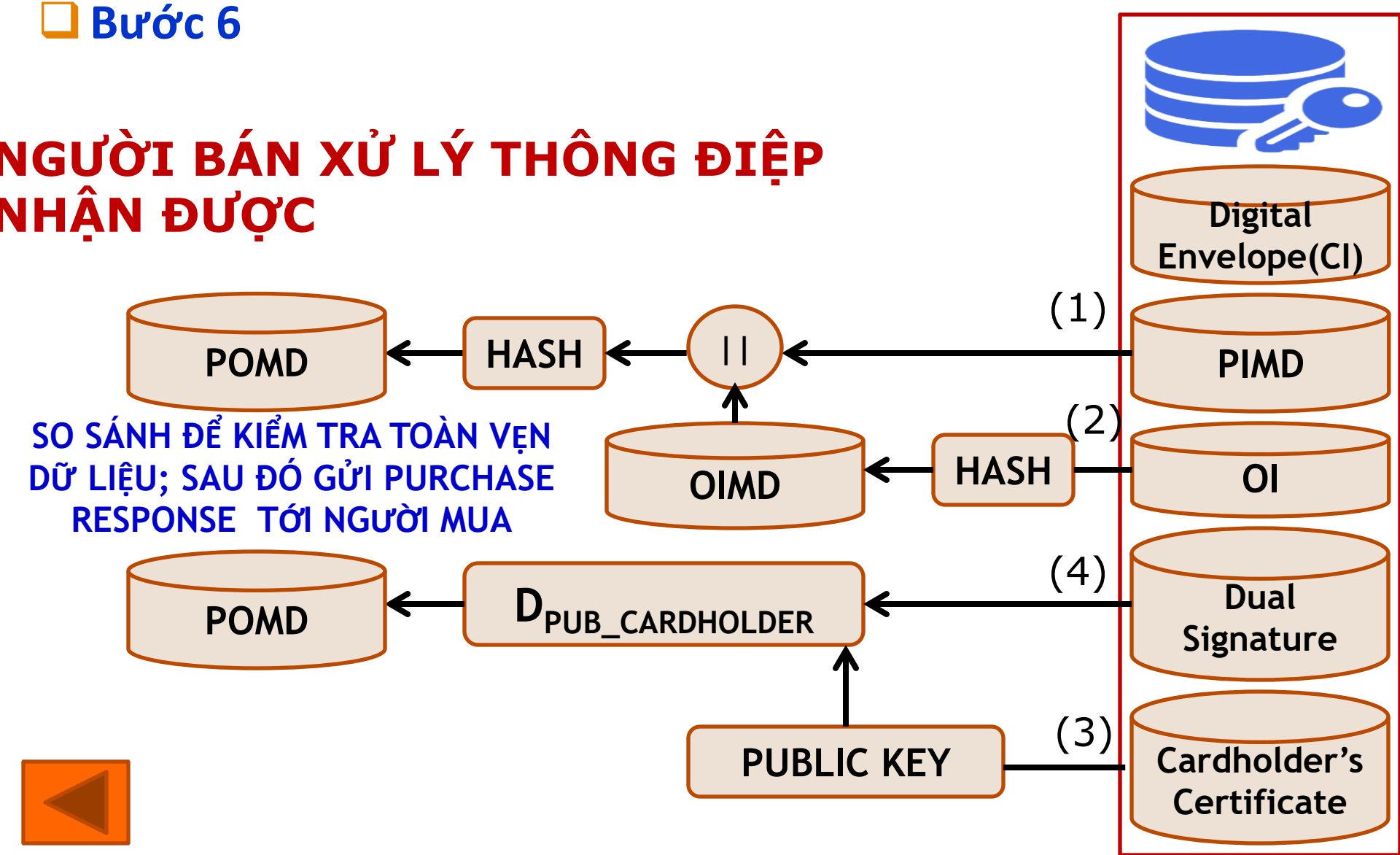
NGƯỜI MUA GỬI PURCHASE MESSAGE TỚI NGƯỜI BÁN



SECURE ELECTRONIC TRANSACTION

Bước 6

NGƯỜI BÁN XỬ LÝ THÔNG ĐIỆP NHẬN ĐƯỢC



SECURE ELECTRONIC TRANSACTION

- Bước 7

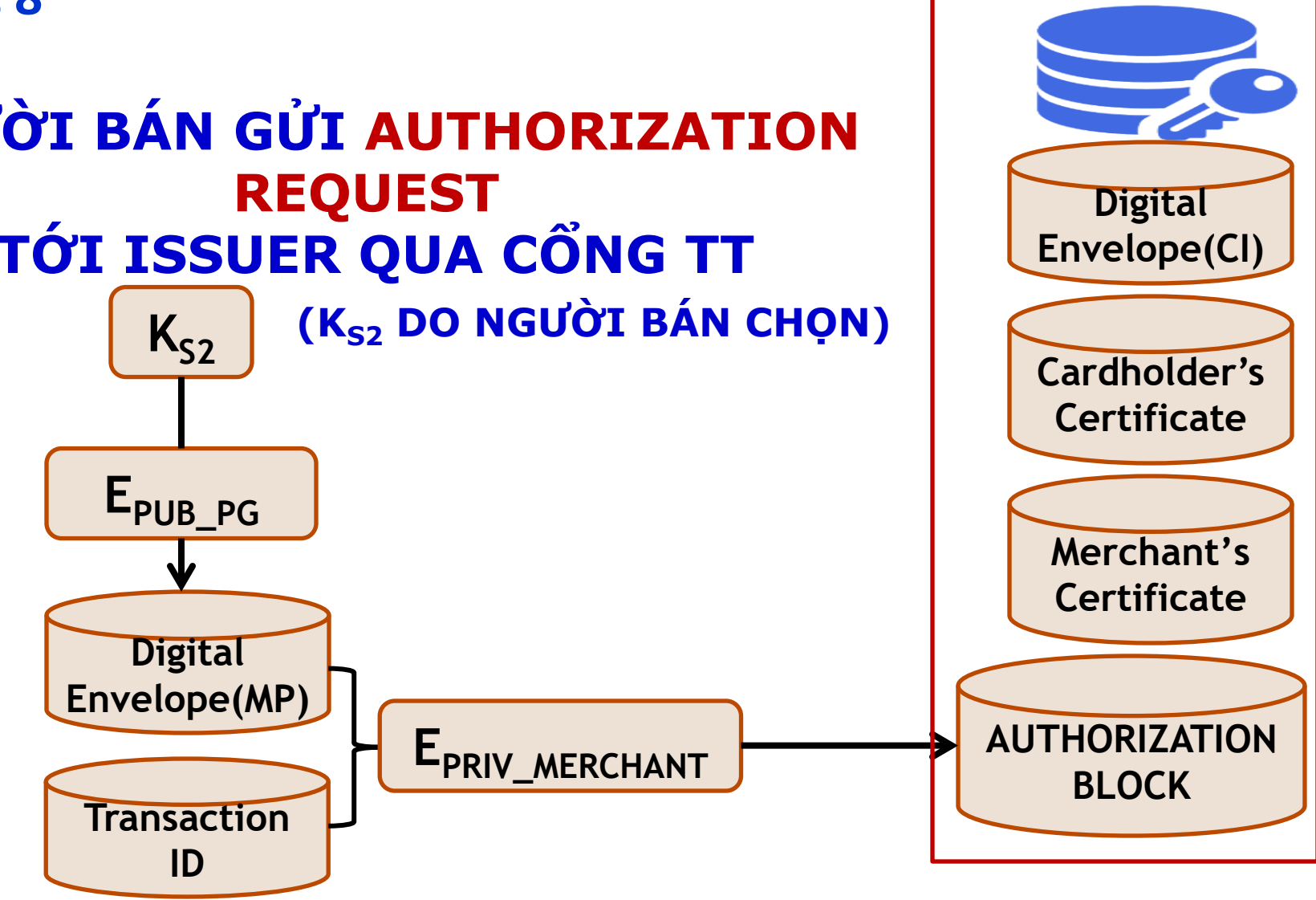
NGƯỜI BÁN GỬI LẠI PURCHASE RESPONSE CHO NGƯỜI MUA



SECURE ELECTRONIC TRANSACTION

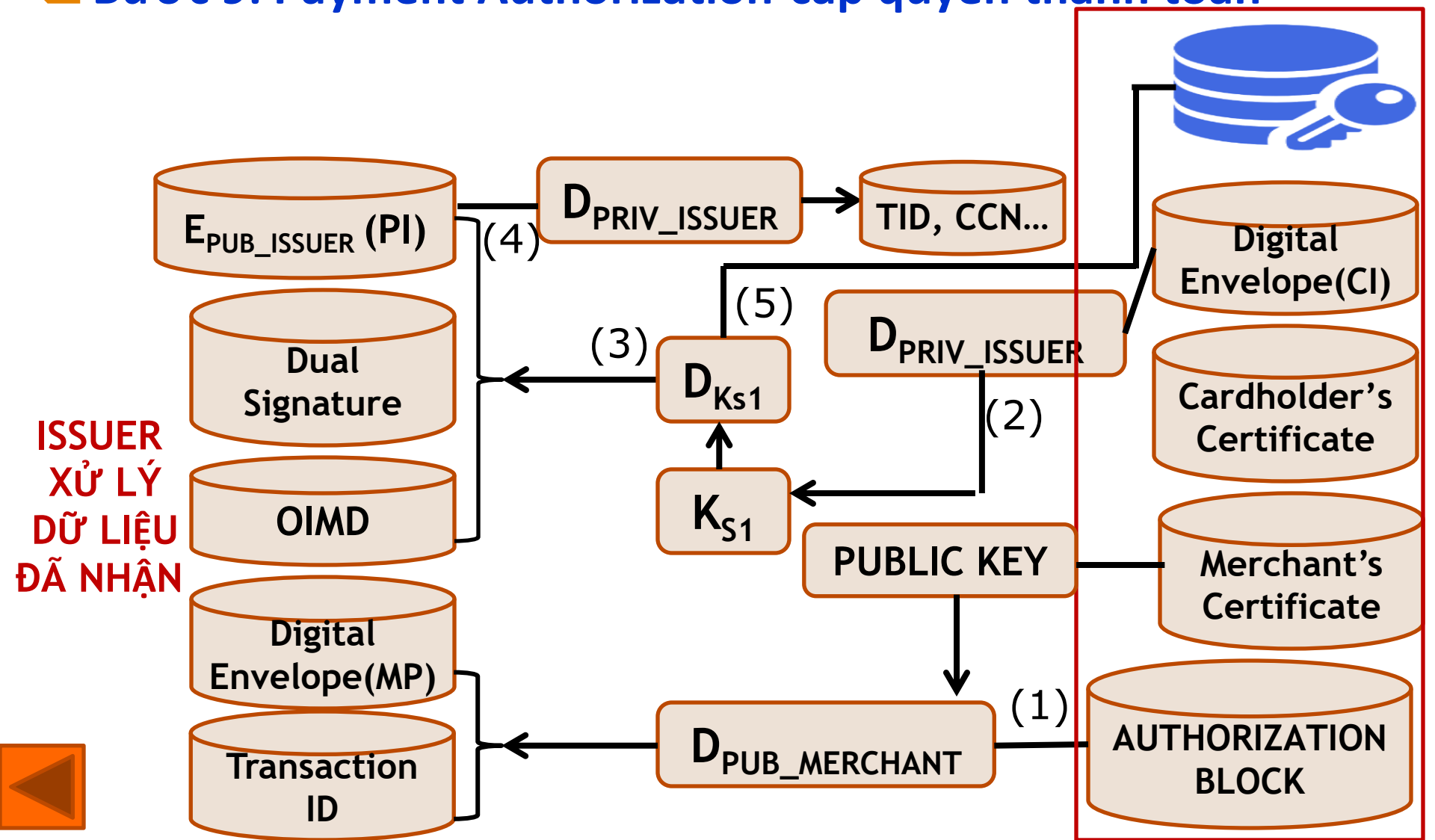
- Bước 8

NGƯỜI BÁN GỬI AUTHORIZATION REQUEST TỚI ISSUER QUA CỔNG TT



SECURE ELECTRONIC TRANSACTION

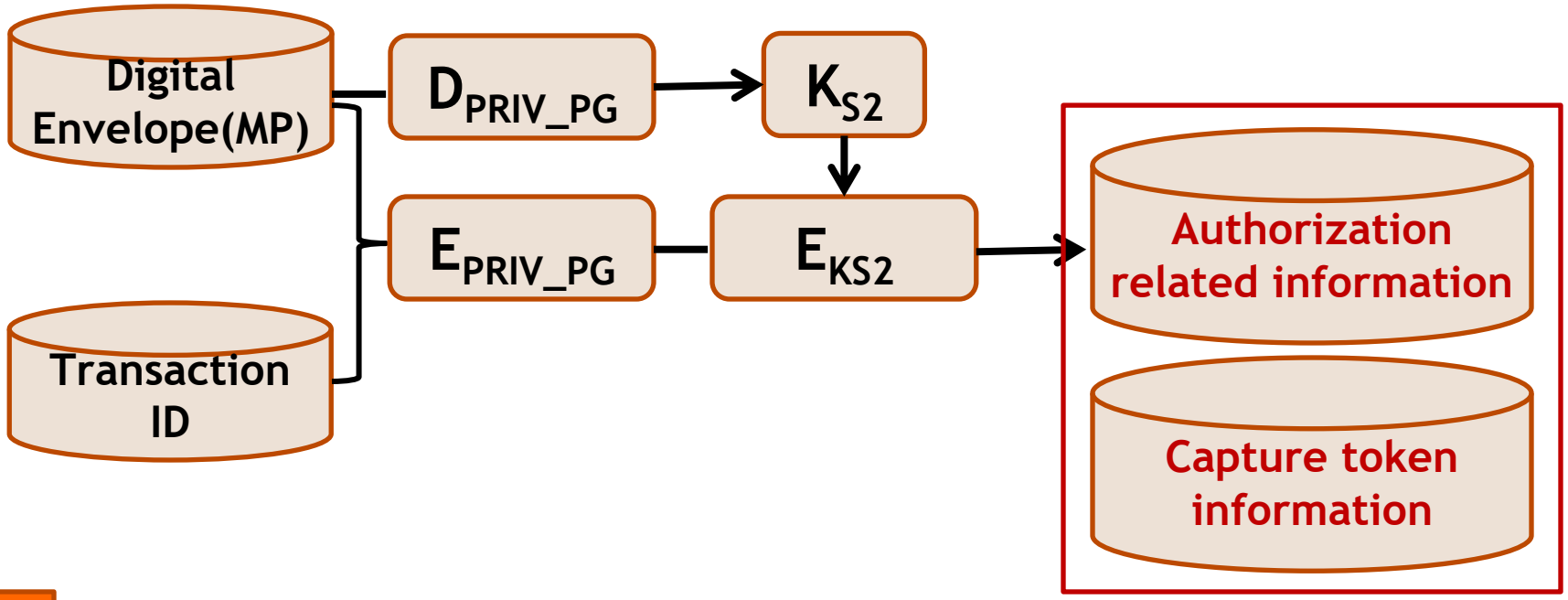
Bước 9: Payment Authorization-cấp quyền thanh toán



SECURE ELECTRONIC TRANSACTION

- **Bước 11:**

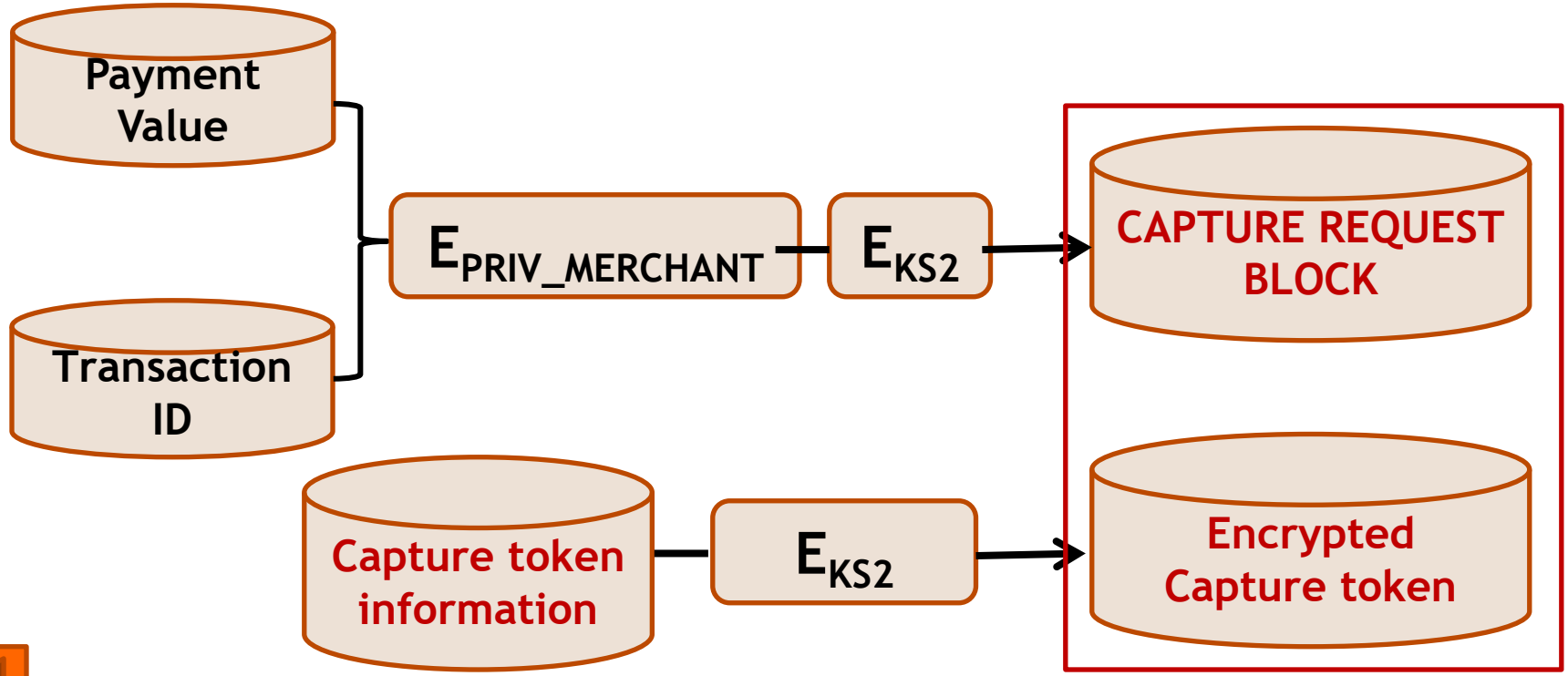
CỔNG TT GỬI AUTHORIZATION RESPONSE TỚI NGƯỜI BÁN



SECURE ELECTRONIC TRANSACTION

- **Bước 13:**

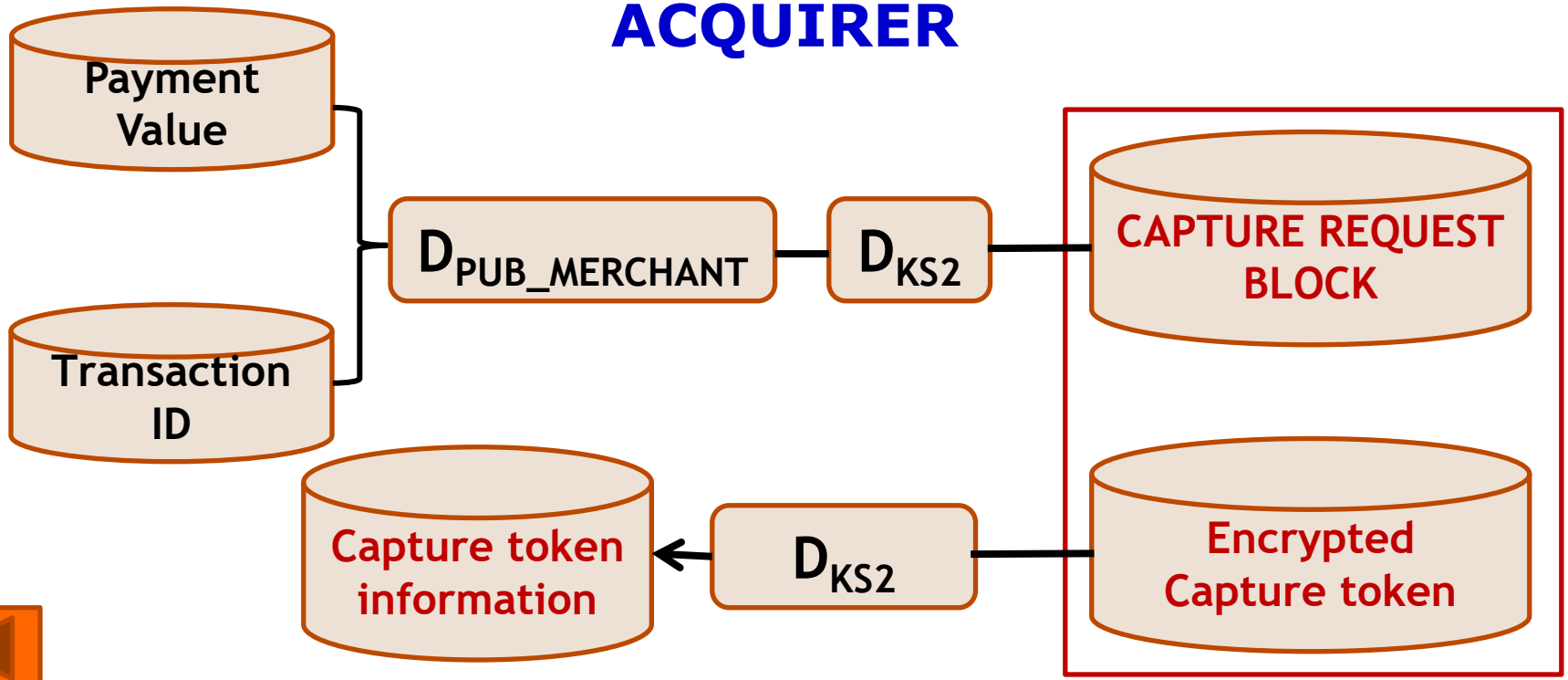
NGƯỜI BÁN GỬI CAPTURE REQUEST MESSAGE TỚI CỔNG TT



SECURE ELECTRONIC TRANSACTION

- **Bước 14:**

CỔNG TT XỬ LÝ CAPTURE REQUEST MESSAGE: KIỂM TRA TID&CAPTURE TOKEN VÀ GỬI CLEARING REQUEST TỚI ISSUER ĐỂ CK CHO ACQUIRER



SECURE ELECTRONIC TRANSACTION

- **Bước 15:**

CỔNG TT GỬI CAPTURE RESPONSE MESSAGE TỚI NGƯỜI BÁN LÀM CĂN CỨ CHO VIỆC THANH TOÁN TỪ ACQUIRER.

ĐIỀU KHIỂN TRUY NHẬP

1. Khái niệm điều khiển truy nhập
2. Các biện pháp điều khiển truy nhập
3. Một số công nghệ điều khiển truy nhập

1. Khái niệm điều khiển truy nhập

- Điều khiển truy nhập là quá trình mà trong đó người dùng được *nhận dạng* và *trao quyền* truy nhập đến các thông tin, các hệ thống và tài nguyên.



5.1.1 Khái niệm điều khiển truy nhập

- Một hệ thống điều khiển truy nhập có thể được cấu thành từ 3 dịch vụ:
  - Xác thực (Authentication):
    - Là quá trình xác minh tính chân thực của các thông tin nhận dạng mà người dùng cung cấp.
  - Trao quyền (Authorization):
    - Trao quyền xác định các tài nguyên mà người dùng được phép truy nhập sau khi người dùng đã được xác thực.
  - Quản trị (Administration):
    - Cung cấp khả năng thêm, bớt và sửa đổi các thông tin tài khoản người dùng, cũng như quyền truy nhập của người dùng.
- Trong 3 dịch vụ trên, 2 dịch vụ thiết yếu của một hệ thống điều khiển truy nhập là xác thực và trao quyền.

5.1.1 Khái niệm điều khiển truy nhập

- Mục đích chính của điều khiển truy nhập là để đảm bảo tính bí mật, toàn vẹn và sẵn dùng của thông tin, hệ thống và các tài nguyên:
  - Tính bí mật (confidentiality): đảm bảo chỉ những người có thẩm quyền mới có khả năng truy nhập vào dữ liệu và hệ thống.
  - Tính toàn vẹn (Integrity): đảm bảo dữ liệu không bị sửa đổi bởi các bên không có đủ thẩm quyền.
  - Tính sẵn dùng: đảm bảo tính sẵn sàng (đáp ứng nhanh/kịp thời) của dịch vụ cung cấp cho người dùng thực sự.

5.1.2 Các biện pháp điều khiển truy nhập

- Điều khiển truy nhập tuỳ chọn – Discretionary Access Control (DAC)
- Điều khiển truy nhập bắt buộc – Mandatory Access Control (MAC)
- Điều khiển truy nhập dựa trên vai trò – Role-Based Access Control (RBAC)
- Điều khiển truy nhập dựa trên luật – Rule-Based Access Control.

5.1.2 Các biện pháp điều khiển truy nhập - DAC

- Điều khiển truy nhập tuỳ chọn được định nghĩa là các cơ chế hạn chế truy nhập đến các đối tượng dựa trên thông tin nhận dạng của các chủ thể và/hoặc nhóm của các chủ thể.
- Thông tin nhận dạng có thể gồm:
  - Bạn là ai? (CMND, bằng lái xe, vân tay,...)
  - Những cái bạn biết (tên truy nhập, mật khẩu, số PIN...)
  - Bạn có gì? (Thẻ ATM, thẻ tín dụng, ...)

5.1.2 Các biện pháp điều khiển truy nhập - DAC

- DAC cho phép người dùng có thể cấp hoặc huỷ quyền truy nhập cho các người dùng khác đến các đối tượng thuộc quyền điều khiển của họ.
- Chủ sở hữu của các đối tượng (owner of objects) là người dùng có toàn quyền điều khiển các đối tượng này.

5.1.2 Các biện pháp điều khiển truy nhập - DAC

- Ví dụ: Với DAC:
  - Người dùng được cấp 1 thư mục riêng và là chủ sở hữu của thư mục này;
  - Người dùng có quyền tạo, sửa đổi và xoá các files trong thư mục của riêng mình (home directory);
  - Họ cũng có khả năng trao hoặc huỷ quyền truy nhập vào các files của mình cho các người dùng khác.

5.1.2 Các biện pháp điều khiển truy nhập - DAC

- Hai kỹ thuật được sử dụng phổ biến đề cài đặt DAC:
  - Ma trận điều khiển truy nhập (Access Control Matrix - ACM);
  - Danh sách điều khiển truy nhập (Access Control List - ACL).

5.1.2 Các biện pháp điều khiển truy nhập – DAC - ACM

- Ma trận điều khiển truy nhập (Access Control Matrix - ACM) là một phương pháp mô tả điều khiển truy nhập thông qua 1 ma trận 2 chiều gồm chủ thể (subject), đối tượng (object) và các quyền truy nhập.
  - Đối tượng/Khách thể (Objects) là các thực thể cần bảo vệ. Objects có thể là các files, các tiến trình (processes).
  - Chủ thể (Subjects) là người dùng (users), tiến trình tác động lên objects.
  - Quyền truy nhập là hành động mà Subject thực hiện trên Object.

5.1.2 Các biện pháp điều khiển truy nhập – DAC - ACM

Objects / Subjects	O1	O2	O3	O4
S1	rw	rwxo	r	rwxo
S2	rw	rx	rw	rwx
S3	r	rw	rwo	rw

Các chủ thể: S1, S2, S3

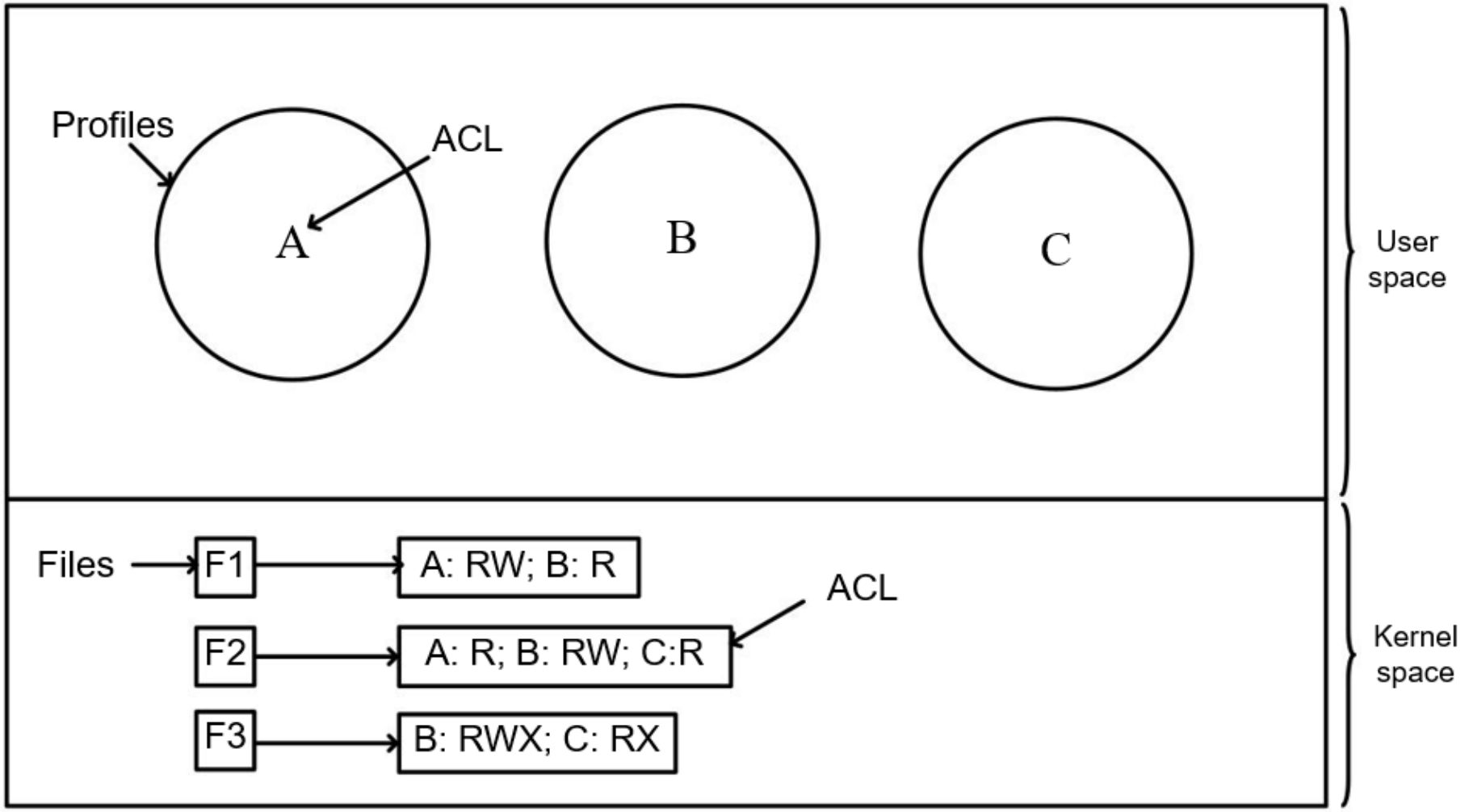
Các đối tượng: O1, O2, O3

Các quyền: r(read), w(write), x(execute) và o(own)

5.1.2 Các biện pháp điều khiển truy nhập – DAC - ACL

- Danh sách điều khiển truy nhập (Access Control List - ACL) là một danh sách các quyền truy nhập của một chủ thể đối với một đối tượng.
  - Một ACL chỉ ra các người dùng hoặc tiến trình được truy nhập vào đối tượng nào và các thao tác cụ thể (quyền) được thực hiện trên đối tượng đó.
  - Một bản ghi điển hình của ACL có dạng (subject, operation). Ví dụ bản ghi (Alice, write) của 1 file có nghĩa là Alice có quyền ghi vào file đó.
  - Khi chủ thể yêu cầu truy nhập, hệ điều hành sẽ kiểm tra ACL xem yêu cầu đó có được phép hay không.
  - ACL có thể được áp dụng cho một hoặc 1 nhóm đối tượng.

5.1.2 Các biện pháp điều khiển truy nhập – DAC - ACL



Sử dụng ACL để quản lý việc truy cập file

5.1.2 Các biện pháp điều khiển truy nhập - MAC

- Điều khiển truy bắt buộc được định nghĩa là các cơ chế hạn chế truy nhập đến các đối tượng dựa trên
  - Tính nhạy cảm (sensitivity) của thông tin (thường được gán nhãn) chứa trong các đối tượng, và
  - Sự trao quyền chính thức (formal authorization) cho các chủ thể truy nhập các thông tin nhạy cảm này.

5.1.2 Các biện pháp điều khiển truy nhập - MAC

- Các mức nhạy cảm của thông tin:
  - Tối mật (Top Secret - T): Được áp dụng với thông tin mà nếu bị lộ có thể dẫn đến những thiệt hại trầm trọng đối với an ninh quốc gia.
  - Tuyệt mật (Secret - S): Được áp dụng với thông tin mà nếu bị lộ có thể dẫn đến một loạt thiệt hại đối với an ninh quốc gia.
  - Mật (Confidential - C): Được áp dụng với thông tin mà nếu bị lộ có thể dẫn đến thiệt hại đối với an ninh quốc gia.
  - Không phân loại (Unclassified - U): Những thông tin không gây thiệt hại đối với an ninh quốc gia nếu bị tiết lộ.

5.1.2 Các biện pháp điều khiển truy nhập - MAC

- MAC không cho phép người tạo ra các đối tượng (thông tin/tài nguyên) có toàn quyền truy nhập các đối tượng này.
- Quyền truy nhập đến các đối tượng (thông tin/tài nguyên) do người quản trị hệ thống định ra trước trên cơ sở chính sách an toàn thông tin của tổ chức đó.
- MAC thường được sử dụng phổ biến trong các cơ quan an ninh, quân đội và ngân hàng.

5.1.2 Các biện pháp điều khiển truy nhập - MAC

- Ví dụ: một tài liệu được tạo ra và được đóng dấu “Mật”:
  - Chỉ những người có trách nhiệm trong tổ chức mới được quyền xem và phổ biến cho người khác;
  - Tác giả của tài liệu không được quyền phổ biến đến người khác.

5.1.2 Các biện pháp điều khiển truy nhập - MAC

- Mô hình điều khiển truy nhập Bell-LaPadula:
  - Mô hình Bell-LaPadula là mô hình bảo mật đa cấp thường được sử dụng trong quân sự, nhưng nó cũng có thể áp dụng cho các lĩnh vực khác.
  - Trong quân sự, các tài liệu được gán một mức độ bảo mật, chẳng hạn như không phân loại, mật, bí mật và tối mật. Người dùng cũng được ấn định các cấp độ bảo mật tương ứng, tùy thuộc vào những tài liệu mà họ được phép xem.
    - Một vị tướng quân đội có thể được phép xem tất cả các tài liệu, trong khi một trung úy có thể bị hạn chế chỉ được xem các tài liệu mật và thấp hơn.
    - Một tiến trình chạy nhân danh một người sử dụng có được mức độ bảo mật của người dùng đó.

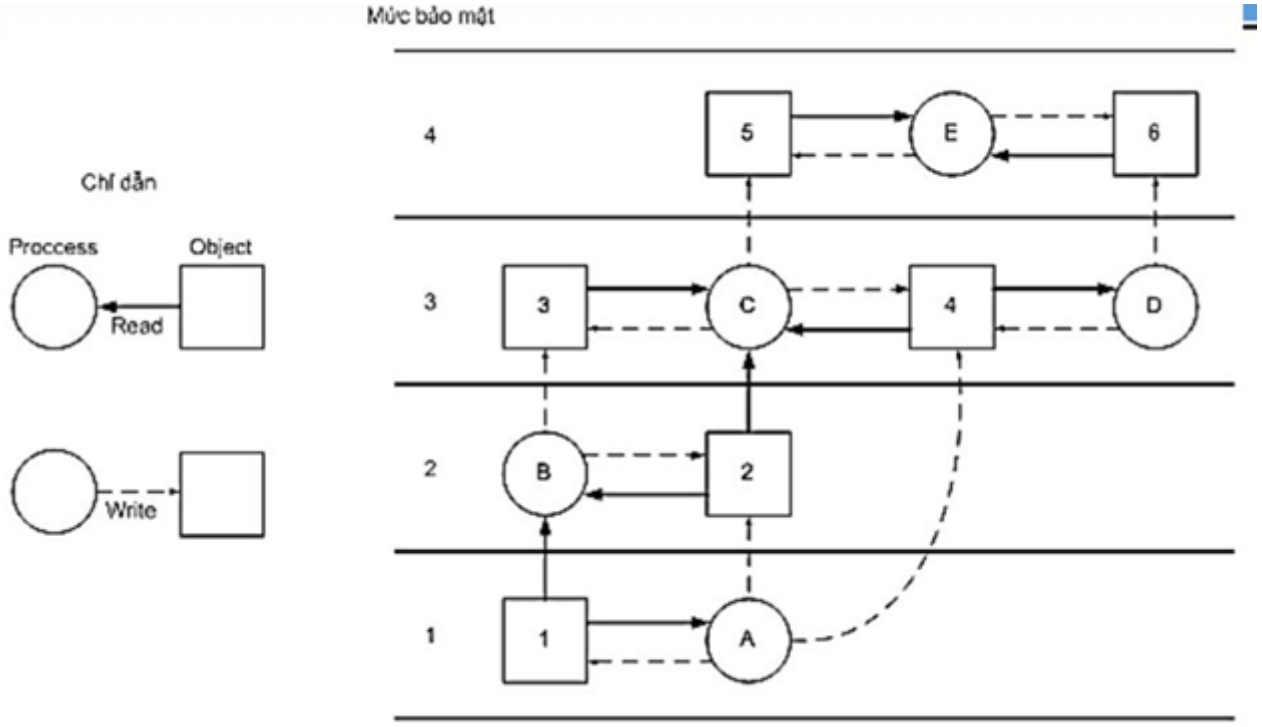
5.1.2 Các biện pháp điều khiển truy nhập - MAC

- Nguyên tắc bảo mật tài nguyên của mô hình Bell-LaPadula:
  - Nguyên tắc đọc xuống:
    - Một người dùng ở mức độ bảo mật k chỉ có thể đọc các đối tượng ở cùng mức bảo mật hoặc thấp hơn.
    - Ví dụ:
      - Một vị tướng có thể đọc các tài liệu của một trung úy;
      - Nhưng một trung úy không thể đọc các tài liệu của vị tướng đó.

5.1.2 Các biện pháp điều khiển truy nhập - MAC

- Nguyên tắc bảo mật tài nguyên của mô hình Bell-LaPadula:
  - Nguyên tắc ghi lên:
    - Một người dùng ở mức độ bảo mật k chỉ có thể ghi các đối tượng ở cùng mức bảo mật hoặc cao hơn.
    - Ví dụ:
      - Một trung úy có thể nối thêm một tin nhắn vào hộp thư của chung về tất cả mọi thứ ông biết;
      - Nhưng một vị tướng không thể ghi thêm một tin nhắn vào hộp thư của trung úy với tất cả mọi thứ ông ấy biết vì vị tướng có thể đã nhìn thấy tài liệu có mức độ bảo mật cao mà không thể được tiết lộ cho một trung úy.

5.1.2 Các biện pháp điều khiển truy nhập - MAC



Mô hình bảo mật đa cấp Bell-LaPadula

5.1.2 Các biện pháp điều khiển truy nhập - RBAC

- Điều khiển truy nhập dựa trên vai trò cho phép người dùng truy nhập vào thông tin và hệ thống dựa trên vai trò (role) của họ trong công ty/tổ chức đó.
- Điều khiển truy nhập dựa trên vai trò có thể được áp dụng cho một nhóm người dùng hoặc từng người dùng riêng lẻ.
- Quyền truy nhập được tập hợp thành các nhóm “vai trò” với các mức quyền truy nhập khác nhau.

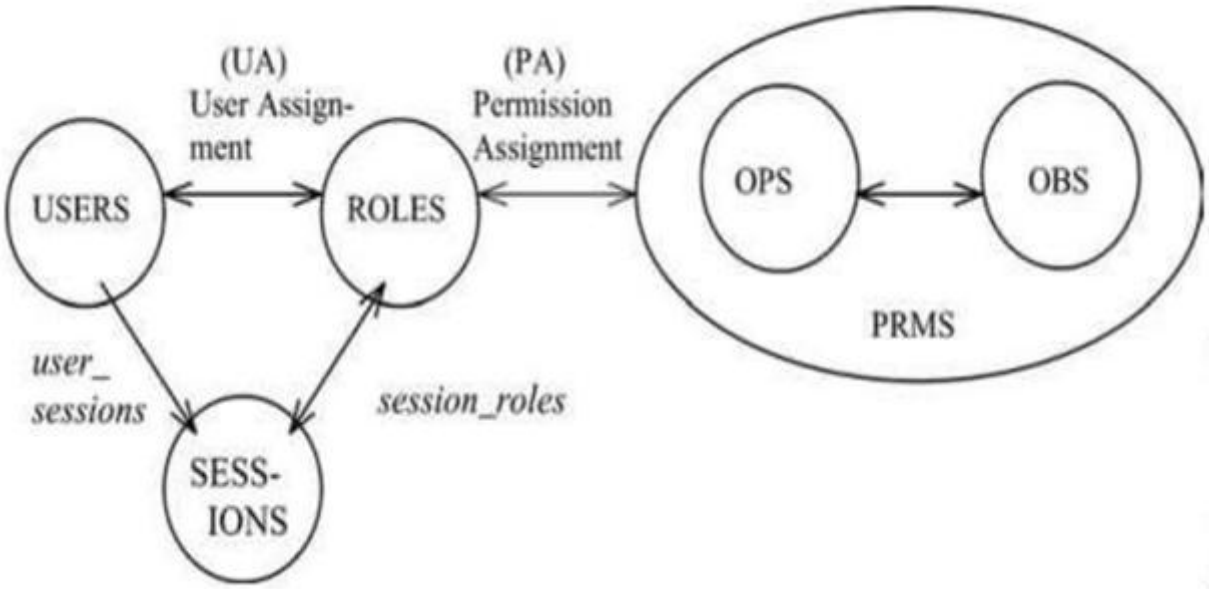
5.1.2 Các biện pháp điều khiển truy nhập - RBAC

- Ví dụ: một trường học chia người dùng thành các nhóm gán sẵn quyền truy nhập vào các phần trong hệ thống:
  - Nhóm Quản lý được quyền truy nhập vào tất cả các thông tin trong hệ thống;
  - Nhóm Giáo viên được truy nhập vào CSDL các môn học, bài báo khoa học, cập nhật điểm các lớp phụ trách;
  - Nhóm Sinh viên chỉ được quyền xem nội dung các môn học, tải tài liệu học tập và xem điểm của mình.

5.1.2 Các biện pháp điều khiển truy nhập - RBAC

- Liên kết giữa người dùng và vai trò:
  - Người dùng được cấp "thẻ thành viên" của các nhóm "vai trò" trên cơ sở năng lực và vai trò, cũng như trách nhiệm của họ trong một tổ chức.
- Trong nhóm "vai trò", người dùng được cấp vừa đủ quyền để thực hiện các thao tác cần thiết cho công việc được giao.
- Liên kết giữa người dùng và vai trò có thể được tạo lập và huỷ bỏ dễ dàng.
- Quản lý phân cấp vai trò: các vai trò được tổ chức thành một cây theo mô hình phân cấp tự nhiên của các công ty/tổ chức.

5.1.2 Các biện pháp điều khiển truy nhập - RBAC



Một mô hình
RBAC đơn giản

5.1.2 Các biện pháp điều khiển truy nhập – Rule-Based AC

- Điều khiển truy nhập dựa trên luật cho phép người dùng truy nhập vào hệ thống và thông tin dựa trên các luật (rules) đã được định nghĩa trước.
- Các luật có thể được thiết lập để hệ thống cho phép truy nhập đến các tài nguyên của mình cho người dùng thuộc một tên miền, một mạng hay một dải địa chỉ IP.

5.1.2 Các biện pháp điều khiển truy nhập – Rule-Based AC

- Firewalls/Proxies là ví dụ điển hình về điều khiển truy nhập dựa trên luật;
- Các hệ thống này sử dụng một tập các luật (rules) để điều khiển truy nhập. Các thông tin sử dụng trong các luật có thể gồm:
  - Địa chỉ IP nguồn và đích của các gói tin;
  - Phần mở rộng các files để lọc các mã độc hại;
  - Địa chỉ IP hoặc các tên miền để lọc/chặn các website bị cấm;
  - Tập các từ khoá để lọc các nội dung bị cấm.

5.1.3 Một số công nghệ điều khiển truy nhập

- Điều khiển truy nhập dựa trên mật khẩu (password)
- Điều khiển truy nhập dựa trên các khoá mã (encrypted keys)
- Điều khiển truy nhập dựa trên thẻ thông minh (smart card)
- Điều khiển truy nhập dựa trên thẻ bài (token)
- Điều khiển truy nhập dựa trên các đặc điểm sinh trắc học (biometric).

5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên mật khẩu

- Thông thường mỗi người dùng được cấp 1 tài khoản (account) để truy nhập vào hệ thống. Để truy nhập tài khoản, thường cần có:
  - Tên người dùng (username), email, số điện thoại,…
  - Mật khẩu (password)
    - Mật khẩu có thể ở dạng nguyên bản (plain text)
    - Mật khẩu có thể ở dạng mã hoá (encrypted text)
      - Các thuật toán thường dùng để mã hoá mật khẩu: MD4, MD5, SHA-1, SHA256,...
    - Mật khẩu có thể được dùng nhiều lần hoặc 1 lần (one time password).

5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên mật khẩu

- Tính bảo mật của kỹ thuật điều khiển truy nhập sử dụng mật khẩu dựa trên:
  - Độ khó đoán của mật khẩu
    - Dùng nhiều loại ký tự
      - Chữ thường, hoa, chữ số, ký tự đặc biệt:
        - abc1234: mật khẩu tồi
        - aBc*1#24: mật khẩu tốt (về mặt tính toán)
    - Độ dài của mật khẩu
      - Mật khẩu tốt có chiều dài >= 8 ký tự
  - Tuổi thọ của mật khẩu
    - Mật khẩu không hết hạn
    - Mật khẩu có thời hạn sống
    - Mật khẩu dùng 1 lần

5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên mật khẩu

- Mật khẩu một lần (OTP-One Time Password):
  - Mật khẩu được sinh ra và chỉ được dùng 1 lần cho 1 phiên làm việc hoặc 1 giao dịch;
  - Mật khẩu thường được sinh ngẫu nhiên
  - Chuyển giao OTP:
    - In ra giấy một danh sách mật khẩu để dùng dần
    - Gửi qua các phương tiện khác như SMS
    - Sử dụng các thiết bị chuyên dụng, như các token,...
  - Ưu điểm: an toàn hơn, tránh được tấn công kiểu replay (lấy được mật khẩu dùng lại).
  - Nhược điểm: người sử dụng khó nhớ mật khẩu.

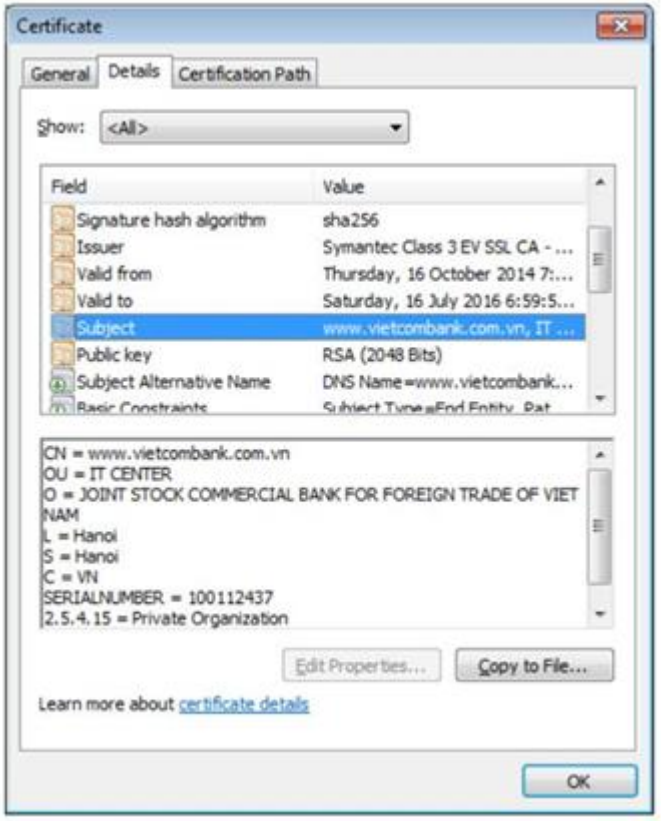
5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên các khóa mã

- Khoá mã là các giải thuật cho phép:
  - Đảm bảo an toàn thông tin bí mật
  - Cho phép kiểm tra thông tin nhận dạng của các bên tham gia giao dịch.
- Ứng dụng rộng rãi nhất là chứng chỉ số (Digital Certificate). Một chứng chỉ số thường gồm các thuộc tính:
  - Thông tin nhận dạng của chủ thể
  - Khoá công khai của chủ thể
  - Các thông tin nhận dạng và khoá công khai của chủ thể được mã hoá (ký) bởi một tổ chức có thẩm quyền (Certificate Authority – CA).

5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên các khóa mã

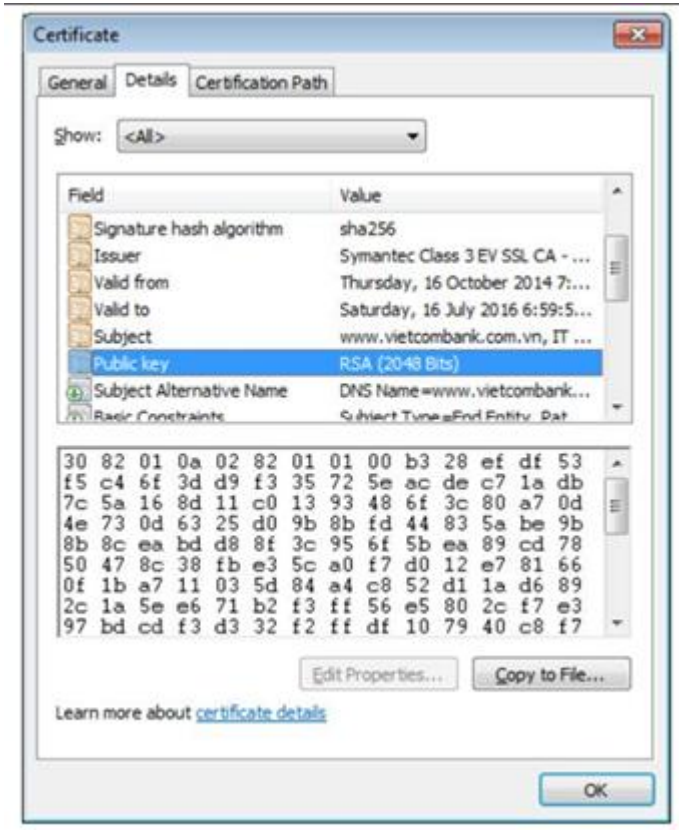
Biểu diễn chứng chỉ số của ngân hàng VCB





5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên các khóa mã

Biểu diễn chứng chỉ số của ngân hàng VCB



5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên thẻ thông minh

- Thẻ thông minh (Smartcard) là các thẻ nhựa có gắn các chip điện tử
- Có khả năng tính toán và các thông tin lưu trong thẻ được mã hoá
- Smartcard sử dụng hai yếu tố (two-factors) để xác thực và nhận dạng chủ thể:
  - Cái bạn có (what you have): thẻ
  - Cái bạn biết (what you know): số PIN

5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên thẻ thông minh





Một loại thẻ thông minh (thẻ tiếp xúc)

5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên thẻ thông minh



Một loại thẻ thông minh (thẻ không tiếp xúc)

5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên thẻ bài (token)

- Các thẻ bài thường là các thiết bị cầm tay được thiết kế nhỏ gọn để có thể dễ dàng mang theo;
  - Được tích hợp pin cung cấp nguồn nuôi.
- Thẻ bài có thể được sử dụng để lưu:
  - Mật khẩu
  - Thông tin cá nhân
  - Các thông tin khác

5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên thẻ bài (token)

- Thẻ bài thường được trang bị cơ chế xác thực 2 yếu tố tương tự smartcards:
  - Thẻ bài
  - Mật khẩu (thường dùng 1 lần)
- Thẻ bài thường có cơ chế xác thực mạnh hơn smartcards do năng lực tính toán cao hơn:
  - CPU có năng lực xử lý cao hơn smartcard;
  - Bộ nhớ lưu trữ lớn hơn.

5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên thẻ bài (token)

Thẻ bài (token) của hãng RSA Security



RSA SecurID SD600



RSA SecurID SID700



RSA SecurID SD200



RSA SecurID SID800



RSA SecurID SD520



BlackBerry with
RSA SecurID software token

5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên thẻ bài (token)

Thẻ bài (ví điện tử) của PayPal dùng trong thanh toán trực tuyến



5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên thẻ bài (token)



Hệ thống ApplePay tích hợp vào điện thoại di động

5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên các đặc điểm sinh trắc

- Điều khiển truy nhập có thể sử dụng các đặc điểm sinh trắc học để nhận dạng chủ thể:
  - Dấu vân tay
  - Tròng mắt
  - Khuôn mặt
  - Tiếng nói
  - Chữ ký tay

5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên các đặc điểm sinh học

- Ưu điểm:
  - Có khả năng bảo mật cao
  - Luôn đi cùng chủ thể
- Nhược điểm:
  - Chi phí đắt
  - Chậm do đòi hỏi khối lượng tính toán lớn
  - Tỷ lệ nhận dạng sai tương đối lớn do có nhiều yếu tố nhiễu ảnh hưởng.

5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên các đặc điểm sinh học

Khoá sử dụng vân tay



5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên các đặc điểm sinh học

Khoá sử dụng vân tay



5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên các đặc điểm sinh học

Bộ phận đọc vân tay trên laptop



5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên các đặc điểm sinh học

Bộ phận
đọc
vân tay
trên
điện thoại
iPhone



5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên các đặc điểm sinh học

Bộ phận đọc vân tay trên điện thoại Samsung



5.1.3 Một số công nghệ điều khiển truy nhập – Điều khiển truy nhập dựa trên các đặc điểm sinh học

Quét nhận dạng tròng mắt/ con ngươi của người dùng



5.2 Tường lửa – Giới thiệu

- Tường lửa (firewall) có thể là thiết bị phần cứng hoặc công cụ phần mềm được dùng để bảo vệ hệ thống và mạng cục bộ tránh các đe doạ từ bên ngoài.
- Tường lửa thường được đặt ở vị trí cổng vào của mạng nội bộ của công ty hoặc tổ chức.

5.2 Tường lửa – Giới thiệu

- Tất cả các gói tin từ trong ra và từ ngoài vào đều phải đi qua tường lửa.
- Chỉ các gói tin hợp lệ được phép đi qua tường lửa (xác định bởi chính sách an ninh – cụ thể hóa bằng các luật).
- Bản thân tường lửa phải miễn dịch với các loại tấn công.
- Tường lửa có thể ngăn chặn nhiều hình thức tấn công mạng, như IP spoofing.

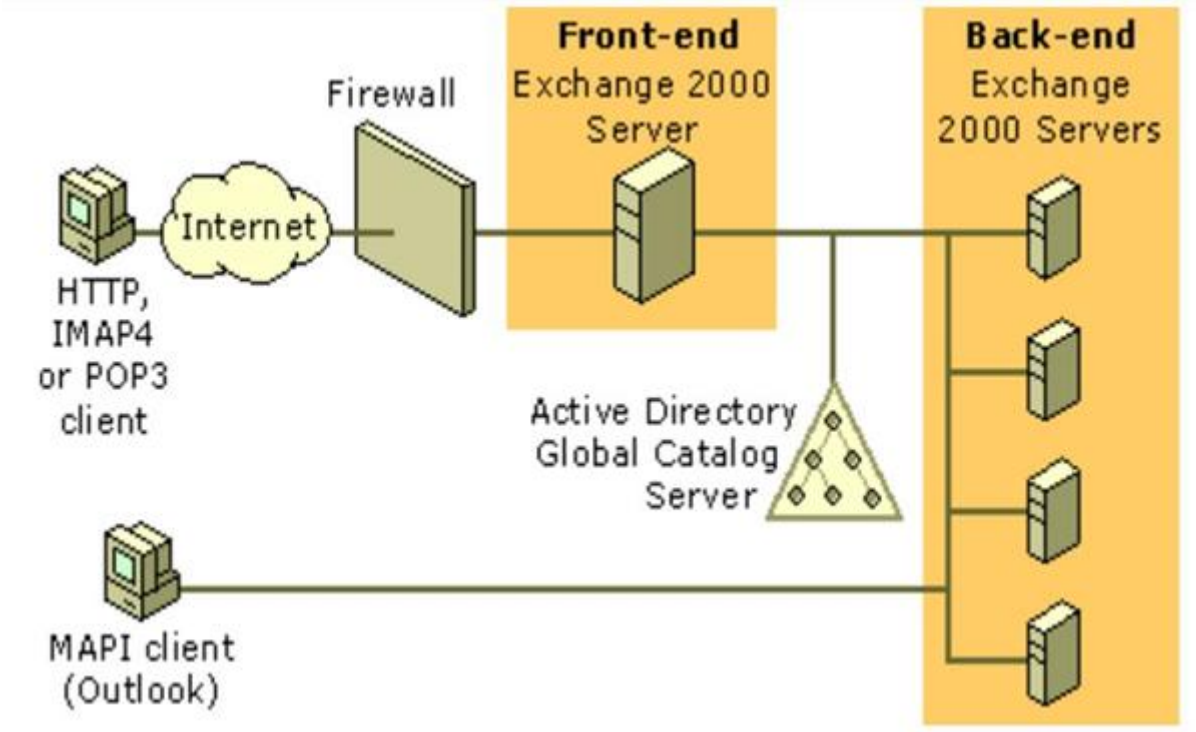
5.2 Tường lửa – Tôpô mạng với tường lửa



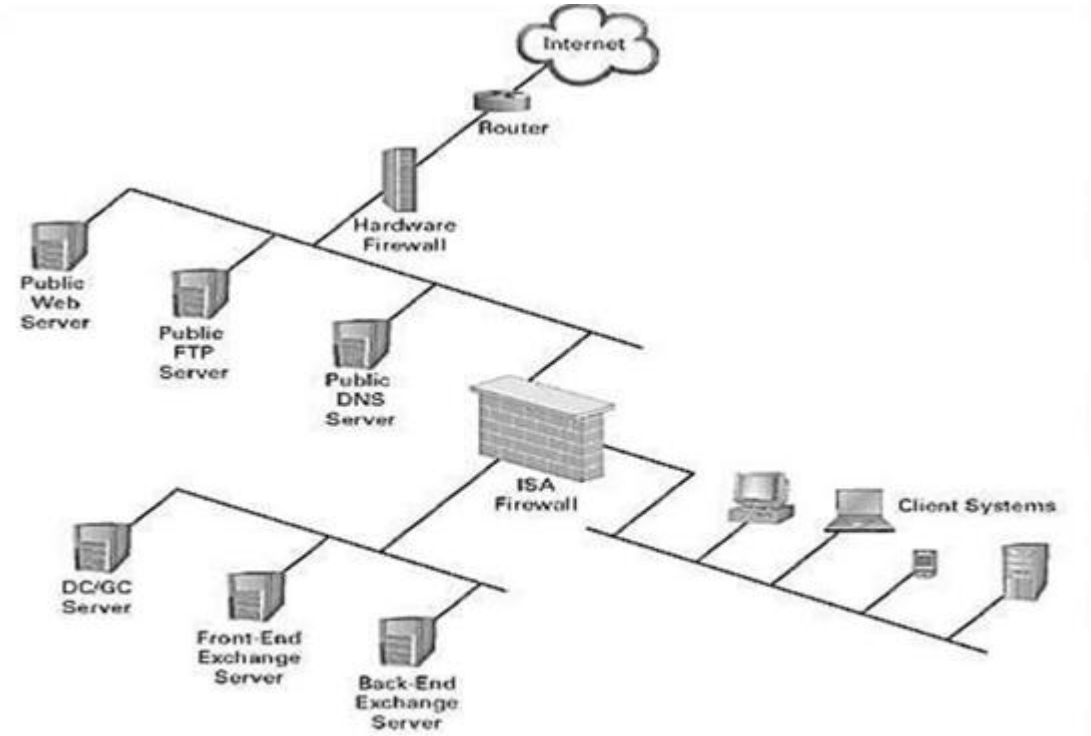
Tường lửa với mạng gia đình hoặc văn phòng nhỏ

5.2 Tường lửa – Tôpô mạng với tường lửa

Tường lửa bảo vệ các
máy chủ dịch vụ



5.2 Tường lửa – Tôpô mạng với tường lửa



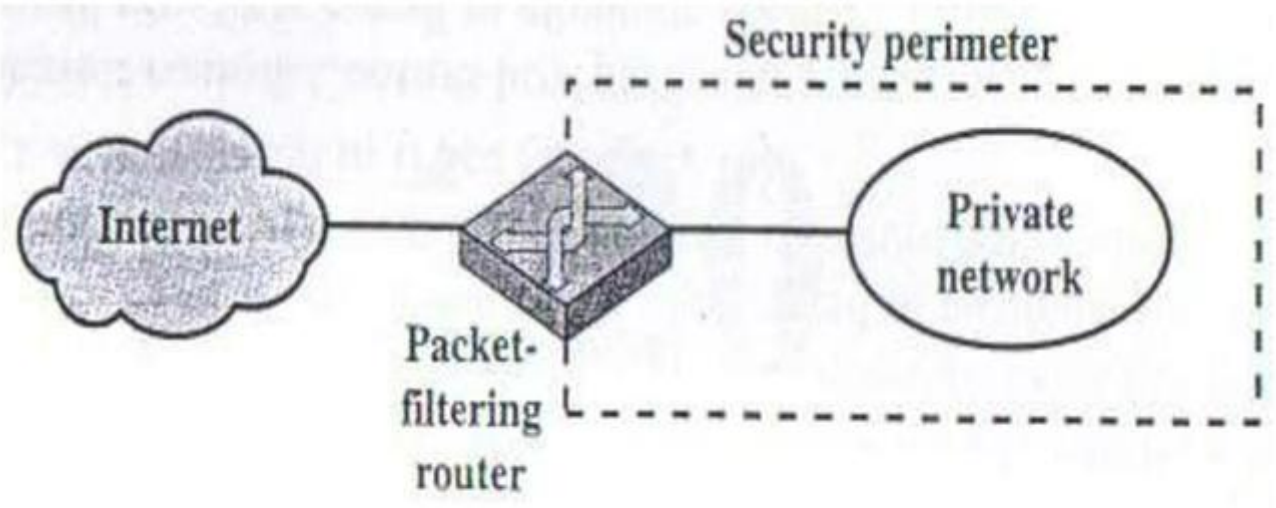
Back-to-back firewall network protecting an OWA Web site.

Hệ thống tường lửa bảo vệ các máy chủ dịch vụ và máy trạm

5.2 Tường lửa – Các loại tường lửa

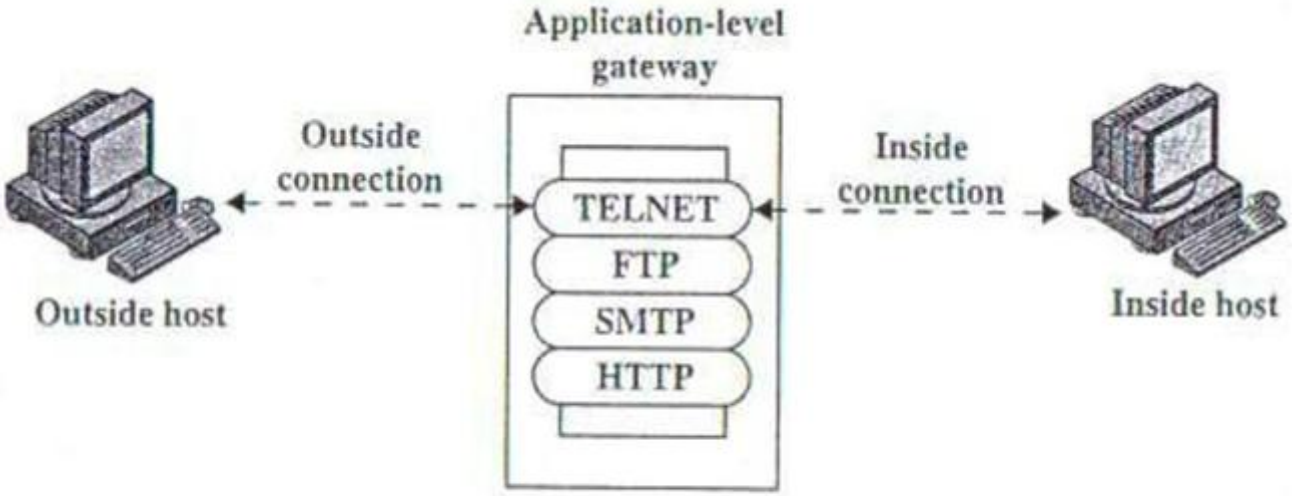
- Lọc gói tin (Packet-Filtering):
  - Áp dụng một tập các luật cho mỗi gói tin đi/đến để quyết định chuyển tiếp hay loại bỏ gói tin.
  - Các tường lửa dạng này thường lọc gói tin lớp IP.
- Các cổng ứng dụng (Application-level gateway):
  - Còn gọi là proxy server, thường dùng để phát lại (relay) traffic của mức ứng dụng.
  - Tường lửa ứng dụng web (WAF – Web Application Firewall) là dạng cổng ứng dụng được sử dụng rộng rãi.
- Cổng chuyển mạch (Circuit-level gateway):
  - Hoạt động tương tự các bộ chuyển mạch.

5.2 Tường lửa – Các loại tường lửa – Lọc gói tin



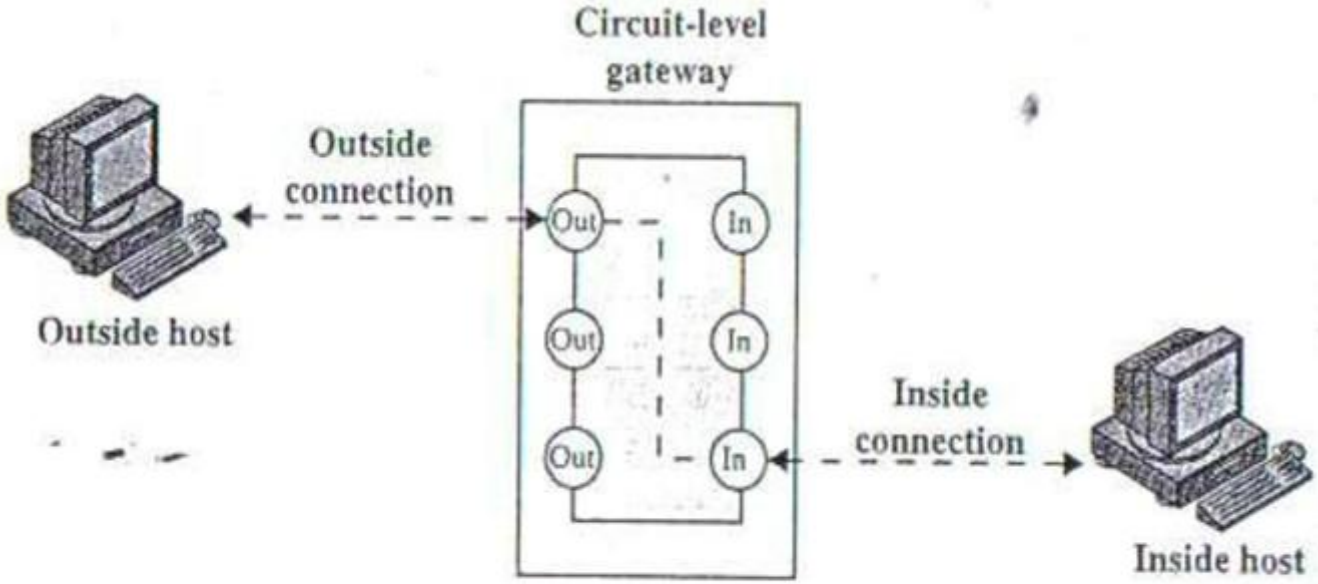
(a) Packet-filtering router

5.2 Tường lửa – Các loại tường lửa – Cổng ứng dụng



(b) Application-level gateway

5.2 Tường lửa – Các loại tường lửa – Cổng chuyển mạch

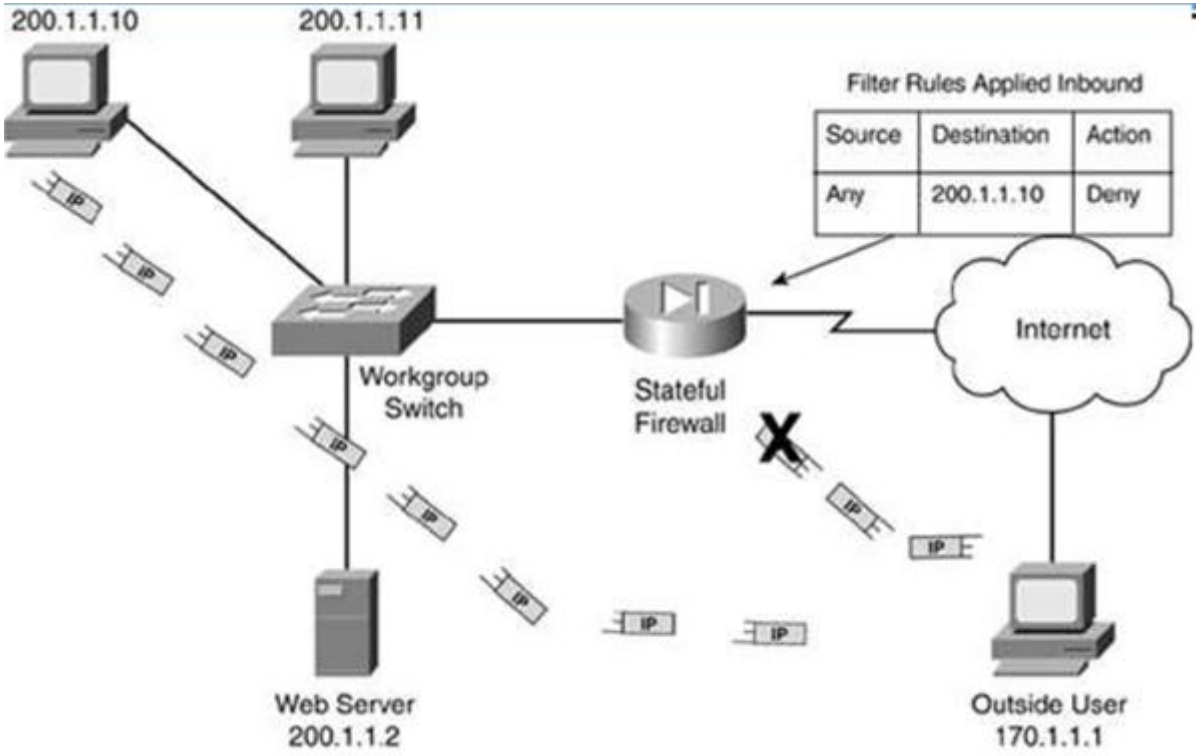


(c) Circuit-level gateway

5.2 Tường lửa – Lọc có trạng thái

- Tường lửa có trạng thái (Stateful firewall):
  - Có khả năng lưu trạng thái của các kết nối mạng đi qua nó;
  - Nó được lập trình để phân biệt các gói tin thuộc về các kết nối mạng khác nhau;
  - Chỉ những gói tin thuộc các kết nối mạng đang hoạt động mới được đi qua tường lửa, còn các gói tin khác (không thuộc kết nối đang hoạt động) sẽ bị chặn lại.

5.2 Tường lửa – Lọc có trạng thái



5.2 Tường lửa – Lọc không trạng thái

- Tường lửa không trạng thái (Stateless firewall):
  - Lọc các gói tin riêng rẽ mà không quan tâm đến mỗi gói tin thuộc về kết nối mạng nào;
  - Dễ bị tấn công bởi kỹ thuật giả mạo địa chỉ, giả mạo nội dung gói tin do tường lửa không có khả năng nhớ các gói tin đi trước thuộc cùng một kết nối mạng.

5.2 Tường lửa – Kỹ thuật kiểm soát truy nhập

- Kiểm soát dịch vụ:
  - Xác định dịch vụ nào có thể được truy nhập, hướng đi ra hay đi vào.
- Kiểm soát hướng:
  - Điều khiển hướng được phép đi của các gói tin của mỗi dịch vụ
- Kiểm soát người dùng:
  - Xác định người dùng nào được quyền truy nhập;
  - Thường áp dụng cho người dùng mạng nội bộ.
- Kiểm soát hành vi:
  - Kiểm soát việc sử dụng các dịch vụ cụ thể. Ví dụ: tường lửa có thể lọc để loại bỏ các thư rác, hoặc hạn chế truy nhập đến một bộ phận thông tin của máy chủ web.

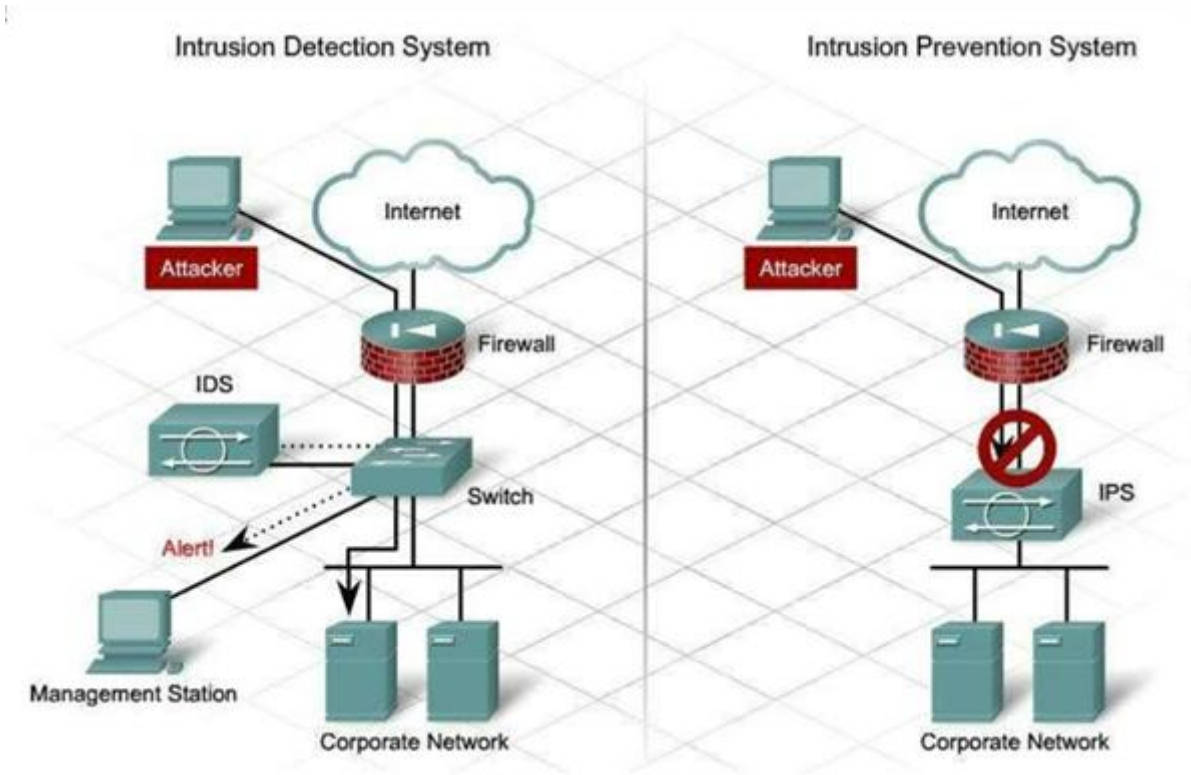
5.2 Tường lửa – Các hạn chế

- Không thể chống lại các tấn công không đi qua nó.
- Không thể chống lại các tấn công hướng dữ liệu, hoặc tấn công vào các lỗ hổng an ninh của các phần mềm.
- Không thể chống lại các hiểm hoạ từ bên trong (mạng nội bộ).
- Không thể ngăn chặn việc vận chuyển các chương trình hoặc các file bị nhiễm virus hoặc các phần mềm độc hại.

5.3 Các hệ thống ngăn chặn/phát hiện tấn công, xâm nhập

- Các hệ thống phát hiện/ngăn chặn tấn công, xâm nhập (IDS/IPS) thường được sử dụng như một lớp phòng vệ quan trọng trong các lớp giải pháp đảm bảo an toàn cho hệ thống thông tin và mạng;
  - IDS – Intrusion Detection System: hệ thống phát hiện tấn công, xâm nhập;
  - IPS - Intrusion Prevention System: hệ thống ngăn chặn tấn công, xâm nhập.
- Các hệ thống IDS/IPS có thể được đặt trước hoặc sau tường lửa, tùy theo mục đích sử dụng.

5.3 Các hệ thống ngăn chặn/phát hiện tấn công, xâm nhập



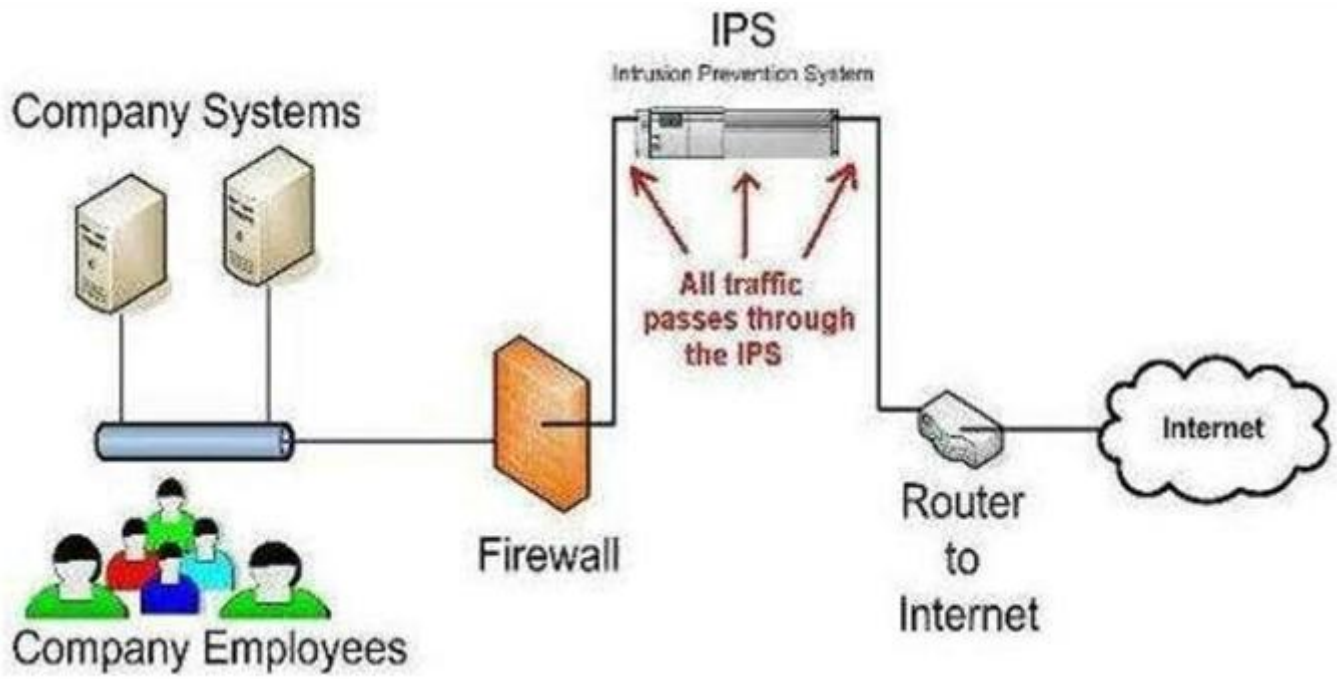
5.3 Các hệ thống ngăn chặn/phát hiện tấn công, xâm nhập

- Nhiệm vụ chính của các hệ thống IDS/IPS:
  - Giám sát lưu lượng mạng hoặc các hành vi trên một hệ thống để nhận dạng các dấu hiệu của tấn công, xâm nhập;
  - Khi phát hiện các hành vi tấn công, xâm nhập → ghi logs các hành vi này cho phân tích bổ sung sau này;
  - Ngăn chặn hoặc dừng các hành vi tấn công, xâm nhập;
  - Gửi thông báo cho người quản trị về các các hành vi tấn công, xâm nhập đã phát hiện được.

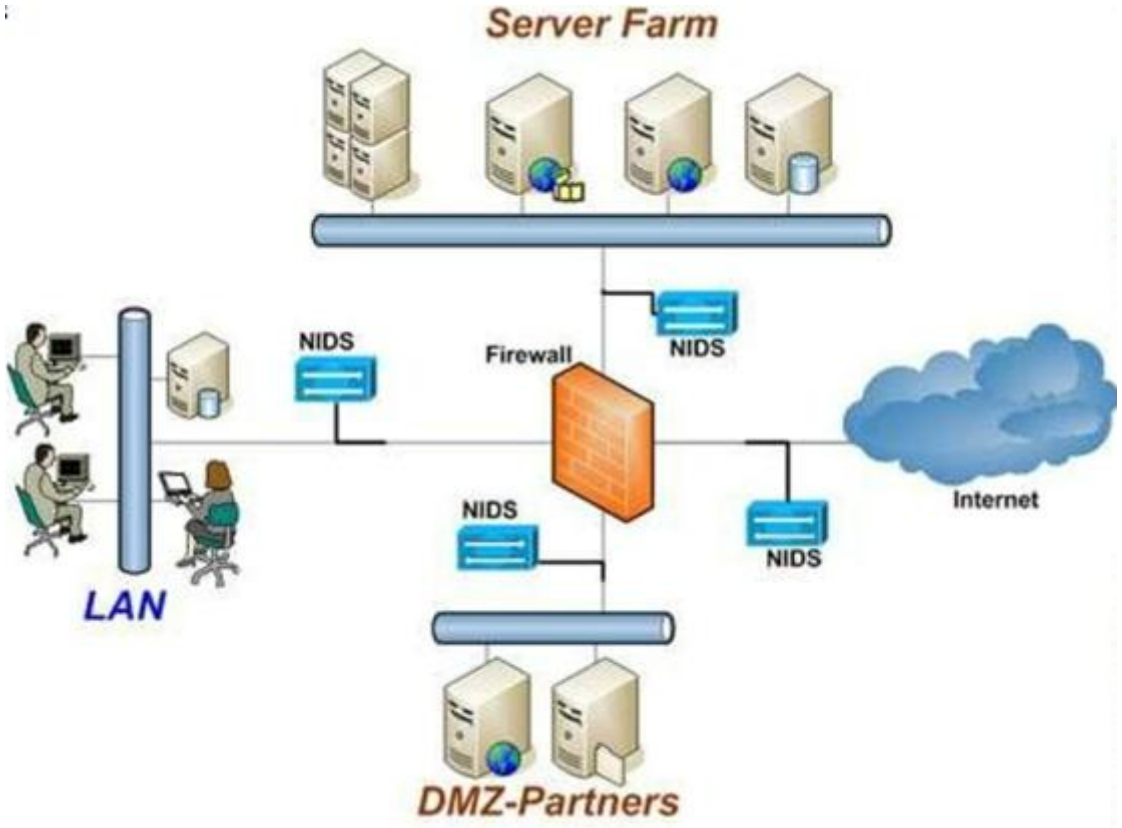
5.3 Các hệ thống ngăn chặn/phát hiện tấn công, xâm nhập

- So sánh IDS/IPS:
  - Giống: Về cơ bản IPS và IDS giống nhau về chức năng giám sát.
  - Khác:
    - IPS thường được đặt giữa đường truyền thông và có thể chủ động ngăn chặn các tấn công/xâm nhập bị phát hiện;
    - IDS thường được kết nối vào các bộ định tuyến, switch, card mạng và chủ yếu làm nhiệm vụ giám sát/cảnh bảo, không có khả năng chủ động ngăn chặn tấn công, xâm nhập.

5.3 Các hệ thống ngăn chặn/phát hiện tấn công, xâm nhập



5.3 Các hệ thống ngăn chặn/phát hiện tấn công, xâm nhập



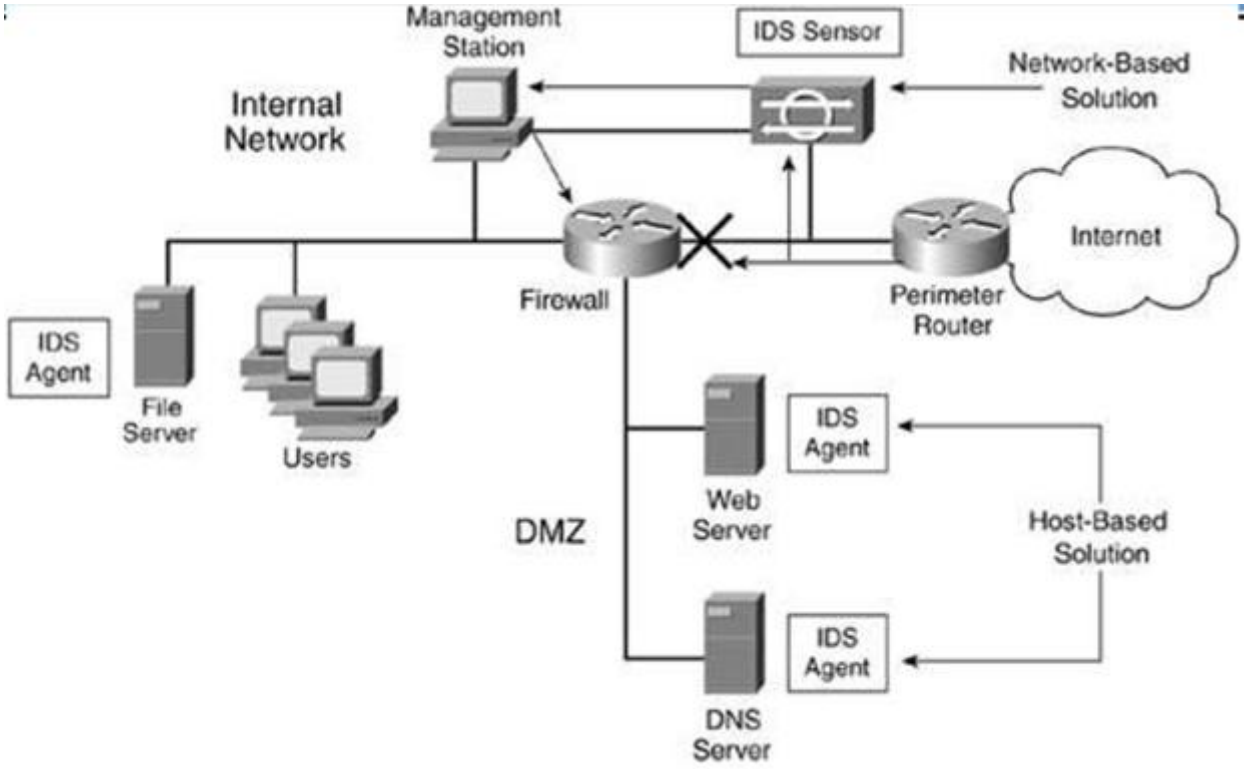
5.3 IDS/IPS – Phân loại

- Phân loại theo nguồn dữ liệu:
  - Hệ thống phát hiện xâm nhập mạng (NIDS – Network-based IDS): phân tích lưu lượng mạng để phát hiện tấn công, xâm nhập cho cả mạng hoặc một phần mạng.
  - Hệ thống phát hiện xâm nhập cho host (HIDS – Host-based IDS): phân tích các sự kiện xảy ra trong hệ thống/dịch vụ để phát hiện tấn công, xâm nhập cho hệ thống đó.

5.3 IDS/IPS – Phân loại

- Phân loại theo kỹ thuật phân tích:
  - Phát hiện xâm nhập dựa trên chữ ký hoặc phát hiện sự lạm dụng (Signature-based / misuse instrusion detection);
  - Phát hiện xâm nhập dựa trên các bất thường (Anomaly instrusion detection).

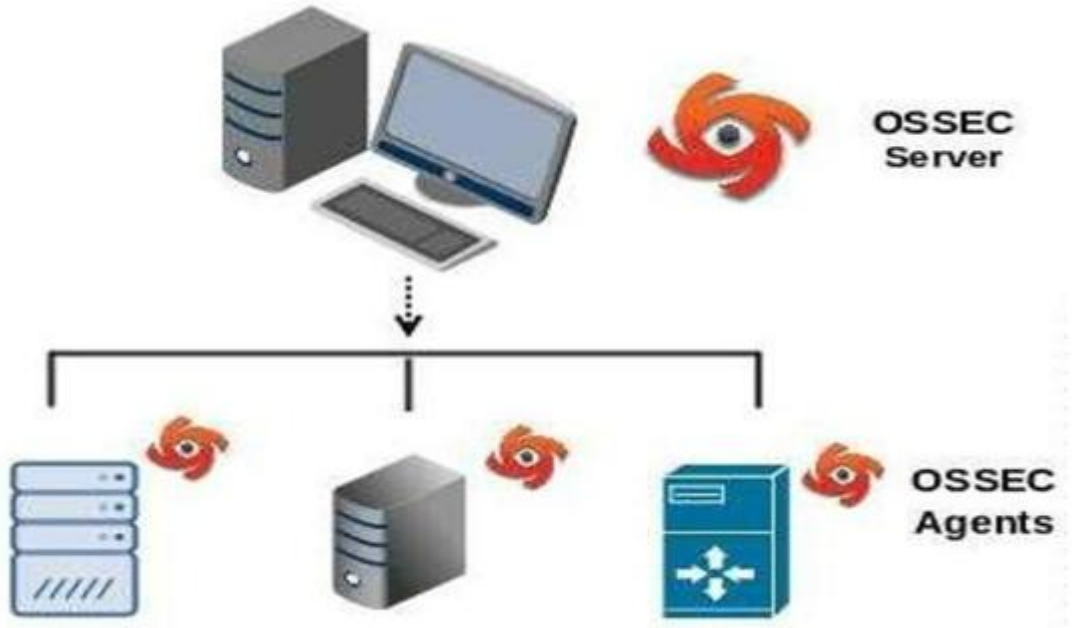
5.3 IDS/IPS – NIDS và HIDS



NIDS - Snort


Lưu lượng mạng
Giải mã gói tin
Tiền xử lý
Mô tơ phát hiện
Luật
Ghi log và cảnh báo
Kết xuất đầu ra
Cảnh báo hoặc log

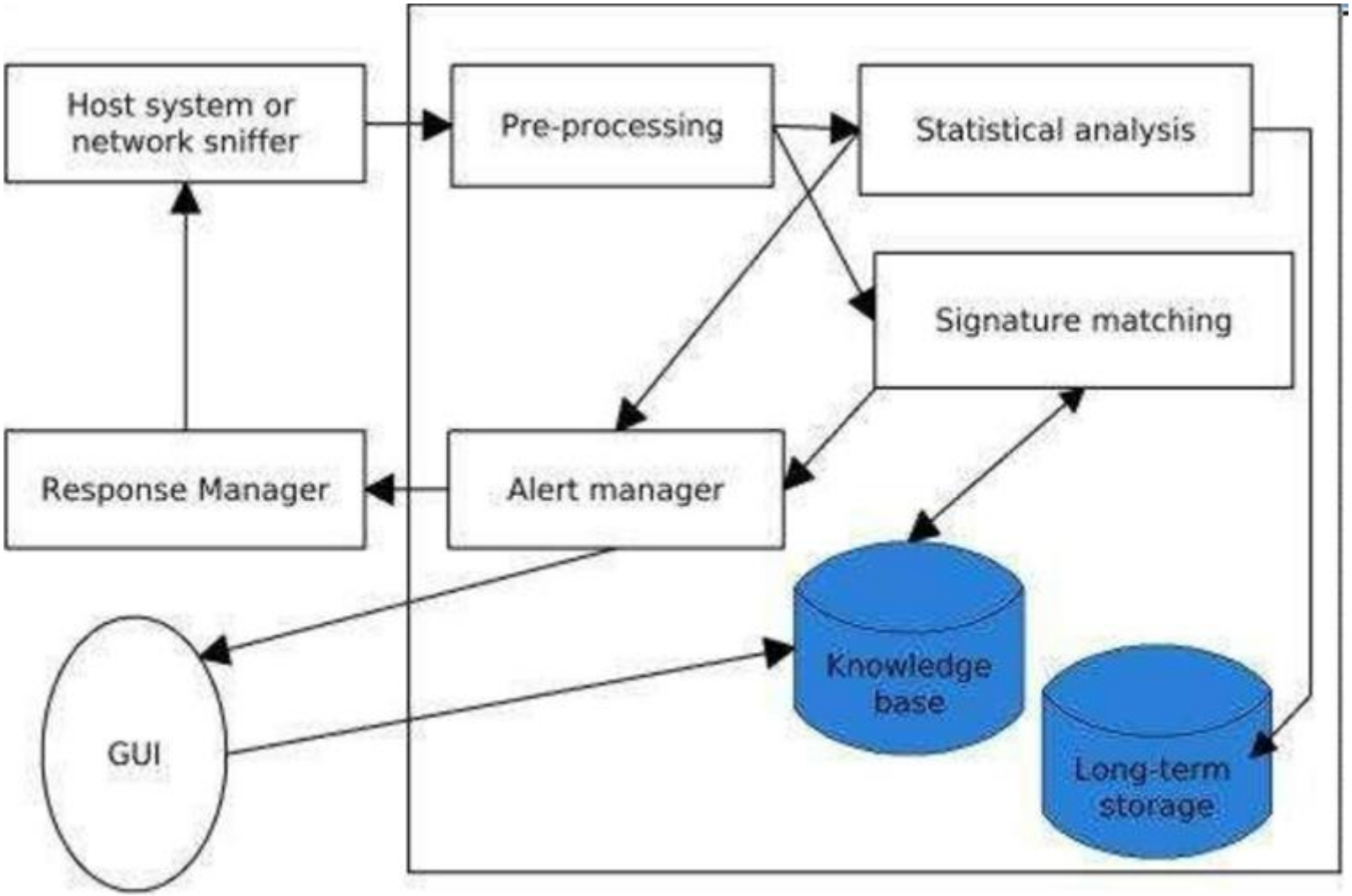
HIDS - OSSEC



5.3 IDS/IPS – Phát hiện xâm nhập dựa trên chữ ký

- Xây dựng cơ sở dữ liệu các chữ ký/dấu hiệu của các loại tấn công, xâm nhập đã biết;
  - Hầu hết các chữ ký/dấu hiệu được nhận dạng và mã hóa thủ công;
  - Dạng biểu diễn thường gặp là các luật (rule) phát hiện.
- Giám sát sát các hành vi của hệ thống, và cảnh báo nếu phát hiện chữ ký của tấn công, xâm nhập;

5.3 IDS/IPS – Phát hiện xâm nhập dựa trên chữ ký



5.3 IDS/IPS – Phát hiện xâm nhập dựa trên chữ ký

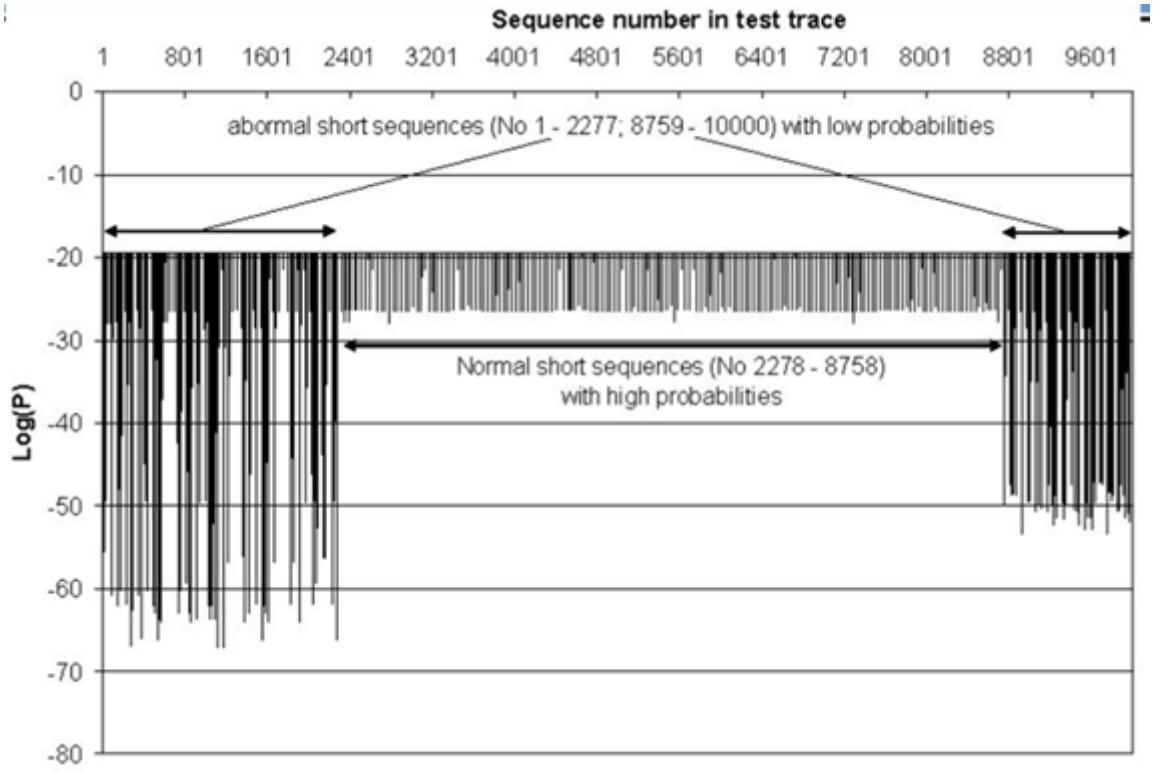
- Ưu điểm:
  - Có khả năng phát hiện các tấn công, xâm nhập đã biết một cách hiệu quả;
  - Tốc độ cao, yêu cầu tài nguyên tính toán tương đối thấp.
- Nhược điểm:
  - Không có khả năng phát hiện các tấn công, xâm nhập mới, do chữ ký của chúng chưa có trong cơ sở dữ liệu các chữ ký;
  - Đòi hỏi nhiều công sức xây dựng và cập nhật cơ sở dữ liệu chữ ký/dấu hiệu tấn công, xâm nhập.

5.3 IDS/IPS – Phát hiện xâm nhập dựa trên bất thường

- Phương pháp này dựa trên giả thiết: *các hành vi xâm nhập thường có quan hệ chặt chẽ với các hành vi bất thường*.
- Quá trình xây dựng và triển khai gồm 2 giai đoạn:
  - Xây dựng hồ sơ (profile) của đối tượng trong chế độ làm việc bình thường.
    - Cần giám sát đối tượng trong điều kiện bình thường trong một khoảng thời gian đủ dài để thu thập dữ liệu huấn luyện.
  - Giám sát hành vi hiện tại của hệ thống và cảnh báo nếu có khác biệt rõ nét giữa hành vi hiện tại và hồ sơ của đối tượng.

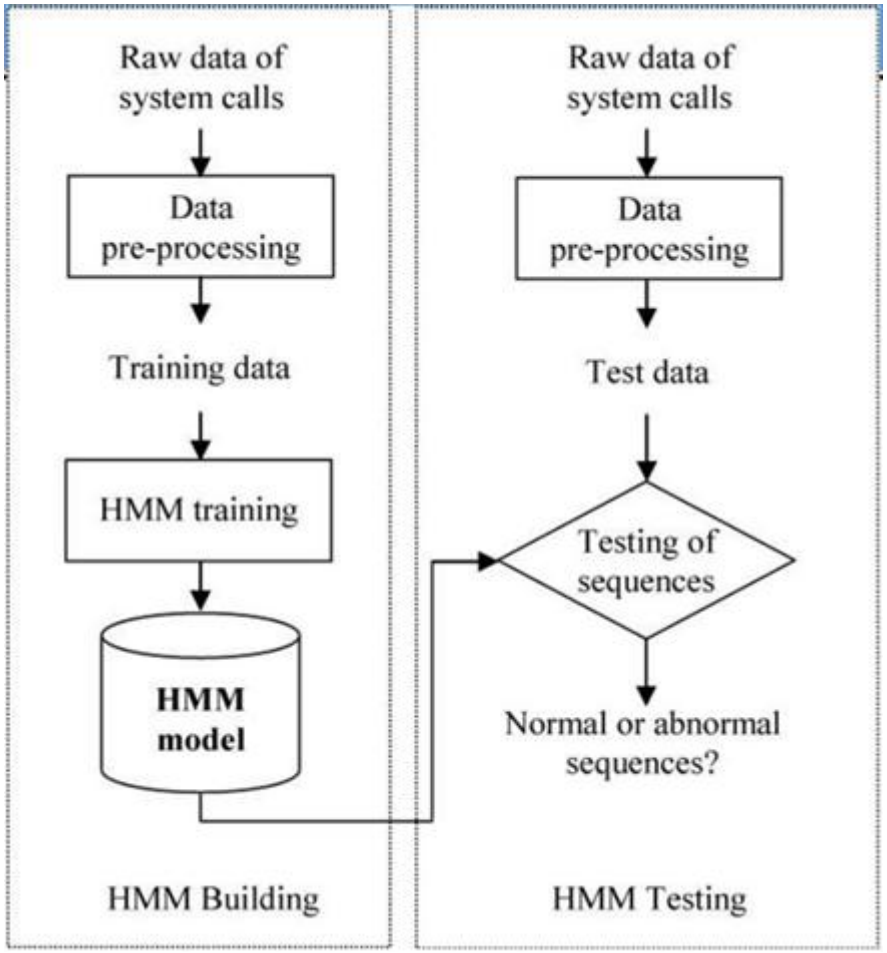
5.3 IDS/IPS – Phát hiện xâm nhập dựa trên bất thường

Một ví dụ về tình trạng bình thường (Log(P) lớn) và bất thường (Log(P) rất nhỏ)



5.3 IDS/IPS – Phát hiện xâm nhập dựa trên bất thường

HMM-Based Anomaly Detection



5.3 IDS/IPS – Phát hiện xâm nhập dựa trên bất thường

- Ưu điểm:
  - Có tiềm năng phát hiện các loại xâm nhập mới mà không yêu cầu biết trước thông tin về chúng.
- Nhược điểm:
  - Tỷ lệ cảnh báo sai tương đối cao so với phương pháp dựa trên chữ ký;
  - Tiêu tốn nhiều tài nguyên hệ thống cho việc xây dựng hồ sơ đối tượng và phân tích hành vi hiện tại.

5.3 IDS/IPS – Phát hiện xâm nhập dựa trên bất thường

- Các phương pháp xử lý, phân tích dữ liệu và mô hình hoá trong phát hiện xâm nhập dựa trên bất thường:
  - Thống kê (statistics).
  - Học máy (machine learning): HMM, máy trạng thái (state-based).
  - Khai phá dữ liệu (data mining).
  - Mạng nơ ron (neural networks).

TÀI LIỆU THAM KHẢO

1. Hoàng Xuân Dậu, *Giáo trình Cơ sở an toàn thông tin*, PTIT, 2018.

2. David Kim et al., Fundamentals of Information Systems Security, Jones & Bartlettlearning, 2023.

3. Bài giảng Cơ sở an toàn thông tin, PTIT.